

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
03.01.01	Account Management	Determine if:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.01.ODP[01]	Account Management	the time period for account inactivity before disabling is defined.	Functional	Subset Of	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	10		
A.03.01.01.ODP[01]	Account Management	the time period for account inactivity before disabling is defined.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5		
A.03.01.01.ODP[02]	Account Management	the time period within which to notify account managers and designated personnel or roles when accounts are no longer required is defined.	Functional	Subset Of	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	10		
A.03.01.01.ODP[03]	Account Management	the time period within which to notify account managers and designated personnel or roles when users are terminated or transferred is defined.	Functional	Subset Of	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	10		
A.03.01.01.ODP[04]	Account Management	the time period within which to notify account managers and designated personnel or roles when system usage or the need-to-know changes for an individual is defined.	Functional	Subset Of	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	10		
A.03.01.01.ODP[05]	Account Management	the time period of expected inactivity requiring users to log out of the system is defined.	Functional	Intersects With	Session Termination	IAC-25	Automated mechanisms exist to log out users, both locally on the network and for remote sessions, at the end of the session or after an organization-defined period of inactivity.	5		
A.03.01.01.ODP[06]	Account Management	circumstances requiring users to log out of the system are defined.	Functional	Intersects With	Session Termination	IAC-25	Automated mechanisms exist to log out users, both locally on the network and for remote sessions, at the end of the session or after an organization-defined period of inactivity.	5		
A.03.01.01.a[01]	Account Management	system account types allowed are defined.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Updated in 2026.2	
A.03.01.01.a[01]	Account Management	system account types allowed are defined.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5		
A.03.01.01.a[02]	Account Management	system account types prohibited are defined.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Updated in 2026.2	
A.03.01.01.a[02]	Account Management	system account types prohibited are defined.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5		
A.03.01.01.b[01]	Account Management	system accounts are created in accordance with organizational policy, procedures, prerequisites, and criteria.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5		
A.03.01.01.b[01]	Account Management	system accounts are created in accordance with organizational policy, procedures, prerequisites, and criteria.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5	Updated in 2026.2	
A.03.01.01.b[02]	Account Management	system accounts are enabled in accordance with organizational policy, procedures, prerequisites, and criteria.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5		
A.03.01.01.b[02]	Account Management	system accounts are enabled in accordance with organizational policy, procedures, prerequisites, and criteria.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5	Updated in 2026.2	
A.03.01.01.b[02]	Account Management	system accounts are enabled in accordance with organizational policy, procedures, prerequisites, and criteria.	Functional	Intersects With	Management Approval For New or Changed Accounts	IAC-28.1	Mechanisms exist to ensure management approvals are required for new accounts or changes in permissions to existing accounts.	5	Updated in 2026.2	
A.03.01.01.b[03]	Account Management	system accounts are modified in accordance with organizational policy, procedures, prerequisites, and criteria.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5		
A.03.01.01.b[03]	Account Management	system accounts are modified in accordance with organizational policy, procedures, prerequisites, and criteria.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5	Updated in 2026.2	
A.03.01.01.b[04]	Account Management	system accounts are disabled in accordance with organizational policy, procedures, prerequisites, and criteria.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5		
A.03.01.01.b[04]	Account Management	system accounts are disabled in accordance with organizational policy, procedures, prerequisites, and criteria.	Functional	Intersects With	System Account Reviews	IAC-15.7	Mechanisms exist to review all system accounts and disable any account that cannot be associated with a business process and owner.	5		
A.03.01.01.b[05]	Account Management	system accounts are removed in accordance with organizational policy, procedures, prerequisites, and criteria.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5		
A.03.01.01.b[05]	Account Management	system accounts are removed in accordance with organizational policy, procedures, prerequisites, and criteria.	Functional	Intersects With	System Account Reviews	IAC-15.7	Mechanisms exist to review all system accounts and disable any account that cannot be associated with a business process and owner.	5		
A.03.01.01.c.01	Account Management	authorized users of the system are specified.	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing screening criteria for individuals filling those positions.	5	Updated in 2026.2	
A.03.01.01.c.01	Account Management	authorized users of the system are specified.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Updated in 2026.2	
A.03.01.01.c.01	Account Management	authorized users of the system are specified.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5		
A.03.01.01.c.01	Account Management	authorized users of the system are specified.	Functional	Intersects With	Restrictions on Shared Groups / Accounts	IAC-15.5	Mechanisms exist to authorize the use of shared/group accounts only under certain organization-defined conditions.	5	Updated in 2026.2	
A.03.01.01.c.02	Account Management	group and role memberships are specified.	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing screening criteria for individuals filling those positions.	5	Updated in 2026.2	
A.03.01.01.c.02	Account Management	group and role memberships are specified.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5		
A.03.01.01.c.02	Account Management	group and role memberships are specified.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5	Updated in 2026.2	
A.03.01.01.c.03	Account Management	access authorizations (i.e., privileges) for each account are specified.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5		
A.03.01.01.c.03	Account Management	access authorizations (i.e., privileges) for each account are specified.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.01.01.c.03	Account Management	access authorizations (i.e., privileges) for each account are specified.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	
A.03.01.01.c.03	Account Management	access authorizations (i.e., privileges) for each account are specified.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Updated in 2026.2	
A.03.01.01.d.01	Account Management	access to the system is authorized based on a valid access authorization.	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	Updated in 2026.2	
A.03.01.01.d.01	Account Management	access to the system is authorized based on a valid access authorization.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	
A.03.01.01.d.01	Account Management	access to the system is authorized based on a valid access authorization.	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing screening criteria for individuals filling those positions.	5	Updated in 2026.2	
A.03.01.01.d.01	Account Management	access to the system is authorized based on a valid access authorization.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5		
A.03.01.01.d.01	Account Management	access to the system is authorized based on a valid access authorization.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5	Updated in 2026.2	
A.03.01.01.d.01	Account Management	access to the system is authorized based on a valid access authorization.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5	Updated in 2026.2	
A.03.01.01.d.01	Account Management	access to the system is authorized based on a valid access authorization.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	Updated in 2026.2	
A.03.01.01.d.01	Account Management	access to the system is authorized based on a valid access authorization.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	
A.03.01.01.d.01	Account Management	access to the system is authorized based on a valid access authorization.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Updated in 2026.2	
A.03.01.01.d.02	Account Management	access to the system is authorized based on intended system usage.	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	Updated in 2026.2	
A.03.01.01.d.02	Account Management	access to the system is authorized based on intended system usage.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5		
A.03.01.01.d.02	Account Management	access to the system is authorized based on intended system usage.	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing screening criteria for individuals filling those positions.	5	Updated in 2026.2	
A.03.01.01.d.02	Account Management	access to the system is authorized based on intended system usage.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5	Updated in 2026.2	
A.03.01.01.d.02	Account Management	access to the system is authorized based on intended system usage.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	Updated in 2026.2	
A.03.01.01.d.02	Account Management	access to the system is authorized based on intended system usage.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	
A.03.01.01.d.02	Account Management	access to the system is authorized based on intended system usage.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Updated in 2026.2	
A.03.01.01.e	Account Management	the use of system accounts is monitored.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5		
A.03.01.01.e	Account Management	the use of system accounts is monitored.	Functional	Intersects With	System Account Reviews	IAC-15.7	Mechanisms exist to review all system accounts and disable any account that cannot be associated with a business process and owner.	5	Updated in 2026.2	
A.03.01.01.e	Account Management	the use of system accounts is monitored.	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	5	Updated in 2026.2	
A.03.01.01.f.01	Account Management	system accounts are disabled when the accounts have expired.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5		
A.03.01.01.f.02	Account Management	system accounts are disabled when the accounts have been inactive for <A.03.01.01.ODP[01]: time period>.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	8		US DoD ODP Value: at most 90 days
A.03.01.01.f.02	Account Management	system accounts are disabled when the accounts have been inactive for <A.03.01.01.ODP[01]: time period>.	Functional	Intersects With	Disable Inactive Accounts	IAC-15.3	Automated mechanisms exist to disable inactive accounts after an organization-defined time period.	8		US DoD ODP Value: at most 90 days
A.03.01.01.f.03	Account Management	system accounts are disabled when the accounts are no longer associated with a user or individual.	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	5	Updated in 2026.2	
A.03.01.01.f.03	Account Management	system accounts are disabled when the accounts are no longer associated with a user or individual.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5		
A.03.01.01.f.04	Account Management	system accounts are disabled when the accounts violate organizational policy.	Functional	Intersects With	Personnel Sanctions	HRS-07	Mechanisms exist to sanction personnel failing to comply with established security policies, standards and procedures.	5	Updated in 2026.2	
A.03.01.01.f.04	Account Management	system accounts are disabled when the accounts violate organizational policy.	Functional	Intersects With	Workplace Investigations	HRS-07.1	Mechanisms exist to conduct employee misconduct investigations when there is reasonable assurance that a policy has been violated.	5	Updated in 2026.2	
A.03.01.01.f.04	Account Management	system accounts are disabled when the accounts violate organizational policy.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5		
A.03.01.01.f.04	Account Management	system accounts are disabled when the accounts violate organizational policy.	Functional	Intersects With	Account Disabling for High Risk Individuals	IAC-15.6	Mechanisms exist to disable accounts immediately upon notification for users posing a significant risk to the organization.	5	Updated in 2026.2	
A.03.01.01.f.05	Account Management	system accounts are disabled when significant risks associated with individuals are discovered.	Functional	Intersects With	Personnel Sanctions	HRS-07	Mechanisms exist to sanction personnel failing to comply with established security policies, standards and procedures.	5	Updated in 2026.2	
A.03.01.01.f.05	Account Management	system accounts are disabled when significant risks associated with individuals are discovered.	Functional	Intersects With	Workplace Investigations	HRS-07.1	Mechanisms exist to conduct employee misconduct investigations when there is reasonable assurance that a policy has been violated.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.01.01.f.05	Account Management	system accounts are disabled when significant risks associated with individuals are discovered.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5		
A.03.01.01.f.05	Account Management	system accounts are disabled when significant risks associated with individuals are discovered.	Functional	Intersects With	Account Disabling for High Risk Individuals	IAC-15.6	Mechanisms exist to disable accounts immediately upon notification for users posing a significant risk to the organization.	5	Updated in 2026.2	
A.03.01.01.g.01	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[02]: time period> when accounts are no longer required.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	8	Updated in 2026.2	US DoD ODP Value: 24 hours
A.03.01.01.g.01	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[02]: time period> when accounts are no longer required.	Functional	Intersects With	Change of Roles & Duties	IAC-07.1	Mechanisms exist to revoke user access rights following changes in personnel roles and duties, if no longer necessary or permitted.	8	Updated in 2026.2	US DoD ODP Value: 24 hours
A.03.01.01.g.01	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[02]: time period> when accounts are no longer required.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	8		US DoD ODP Value: 24 hours
A.03.01.01.g.02	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[03]: time period> when users are terminated or transferred.	Functional	Intersects With	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	8	Updated in 2026.2	US DoD ODP Value: 24 hours
A.03.01.01.g.02	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[03]: time period> when users are terminated or transferred.	Functional	Intersects With	Personnel Transfer	HRS-08	Mechanisms exist to adjust logical and physical access authorizations to Technology Assets, Applications and/or Services (TAAS) and facilities upon personnel reassignment or transfer, in a timely manner.	8	Updated in 2026.2	US DoD ODP Value: 24 hours
A.03.01.01.g.02	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[03]: time period> when users are terminated or transferred.	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	8	Updated in 2026.2	US DoD ODP Value: 24 hours
A.03.01.01.g.02	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[03]: time period> when users are terminated or transferred.	Functional	Intersects With	Automated Employment Status Notifications	HRS-09.4	Automated mechanisms exist to notify Identity and Access Management (IAM) personnel or roles upon termination of an individual employment or contract.	8	Updated in 2026.2	US DoD ODP Value: 24 hours
A.03.01.01.g.02	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[03]: time period> when users are terminated or transferred.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	8	Updated in 2026.2	US DoD ODP Value: 24 hours
A.03.01.01.g.02	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[03]: time period> when users are terminated or transferred.	Functional	Intersects With	Change of Roles & Duties	IAC-07.1	Mechanisms exist to revoke user access rights following changes in personnel roles and duties, if no longer necessary or permitted.	8	Updated in 2026.2	US DoD ODP Value: 24 hours
A.03.01.01.g.02	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[03]: time period> when users are terminated or transferred.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	8		US DoD ODP Value: 24 hours
A.03.01.01.g.03	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[04]: time period> when system usage or the need-to-know changes for an individual.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	8	Updated in 2026.2	US DoD ODP Value: 24 hours
A.03.01.01.g.03	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[04]: time period> when system usage or the need-to-know changes for an individual.	Functional	Intersects With	Change of Roles & Duties	IAC-07.1	Mechanisms exist to revoke user access rights following changes in personnel roles and duties, if no longer necessary or permitted.	8	Updated in 2026.2	US DoD ODP Value: 24 hours
A.03.01.01.g.03	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[04]: time period> when system usage or the need-to-know changes for an individual.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	8		US DoD ODP Value: 24 hours
A.03.01.01.g.03	Account Management	account managers and designated personnel or roles are notified within <A.03.01.01.ODP[04]: time period> when system usage or the need-to-know changes for an individual.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	8	Updated in 2026.2	US DoD ODP Value: 24 hours
A.03.01.01.h	Account Management	users are required to log out of the system after <A.03.01.01.ODP[05]: time period> of expected inactivity or when the following circumstances occur: <A.03.01.01.ODP[06]: circumstances>.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	8	Updated in 2026.2	US DoD ODP Values: [05] - at most 24 hours [06] - the work period ends, for privileged users at a minimum
A.03.01.01.h	Account Management	users are required to log out of the system after <A.03.01.01.ODP[05]: time period> of expected inactivity or when the following circumstances occur: <A.03.01.01.ODP[06]: circumstances>.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	8	Updated in 2026.2	US DoD ODP Values: [05] - at most 24 hours [06] - the work period ends, for privileged users at a minimum
A.03.01.01.h	Account Management	users are required to log out of the system after <A.03.01.01.ODP[05]: time period> of expected inactivity or when the following circumstances occur: <A.03.01.01.ODP[06]: circumstances>.	Functional	Intersects With	Technology Use Restrictions	HRS-05.3	Mechanisms exist to establish usage restrictions and implementation guidance for organizational technologies based on the potential to cause damage to Technology Assets, Applications and/or Services (TAAS), if used maliciously.	8	Updated in 2026.2	US DoD ODP Values: [05] - at most 24 hours [06] - the work period ends, for privileged users at a minimum
A.03.01.01.h	Account Management	users are required to log out of the system after <A.03.01.01.ODP[05]: time period> of expected inactivity or when the following circumstances occur: <A.03.01.01.ODP[06]: circumstances>.	Functional	Intersects With	Session Termination	IAC-25	Automated mechanisms exist to log out users, both locally on the network and for remote sessions, at the end of the session or after an organization-defined period of inactivity.	8		US DoD ODP Values: [05] - at most 24 hours [06] - the work period ends, for privileged users at a minimum
03.01.02	Access Enforcement	Determine IF:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.02[01]	Access Enforcement	approved authorizations for logical access to CUI are enforced in accordance with applicable access control policies.	Functional	Intersects With	Sensitive / Regulated Data Access Enforcement	CFG-08	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to restrict access to sensitive and/or regulated data.	5		
A.03.01.02[01]	Access Enforcement	approved authorizations for logical access to CUI are enforced in accordance with applicable access control policies.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	
A.03.01.02[01]	Access Enforcement	approved authorizations for logical access to CUI are enforced in accordance with applicable access control policies.	Functional	Intersects With	Defining Access Authorizations for Sensitive / Regulated Data	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and /or physical access to sensitive and/or regulated data.	5	Updated in 2026.2	
A.03.01.02[01]	Access Enforcement	approved authorizations for logical access to CUI are enforced in accordance with applicable access control policies.	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing screening criteria for individuals filling those positions.	5	Updated in 2026.2	
A.03.01.02[01]	Access Enforcement	approved authorizations for logical access to CUI are enforced in accordance with applicable access control policies.	Functional	Intersects With	Users With Elevated Privileges	HRS-02.1	Mechanisms exist to ensure that every user accessing Technology Assets, Applications and/or Services (TAAS) that process, store and/or transmit sensitive and/or regulated data is cleared and regularly trained to handle the information in question.	5	Updated in 2026.2	
A.03.01.02[01]	Access Enforcement	approved authorizations for logical access to CUI are enforced in accordance with applicable access control policies.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Updated in 2026.2	
A.03.01.02[01]	Access Enforcement	approved authorizations for logical access to CUI are enforced in accordance with applicable access control policies.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5	Updated in 2026.2	
A.03.01.02[01]	Access Enforcement	approved authorizations for logical access to CUI are enforced in accordance with applicable access control policies.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	Updated in 2026.2	
A.03.01.02[01]	Access Enforcement	approved authorizations for logical access to CUI are enforced in accordance with applicable access control policies.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.01.02[01]	Access Enforcement	approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Updated in 2026.2	
A.03.01.02[02]	Access Enforcement	approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.	Functional	Intersects With	Sensitive / Regulated Data Access Enforcement	CFG-08	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to restrict access to sensitive and/or regulated data.	5	Updated in 2026.2	
A.03.01.02[02]	Access Enforcement	approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	
A.03.01.02[02]	Access Enforcement	approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.	Functional	Intersects With	Defining Access Authorizations for Sensitive / Regulated Data	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and /or physical access to sensitive and/or regulated data.	5	Updated in 2026.2	
A.03.01.02[02]	Access Enforcement	approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing screening criteria for individuals filling those positions.	5	Updated in 2026.2	
A.03.01.02[02]	Access Enforcement	approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.	Functional	Intersects With	Users With Elevated Privileges	HRS-02.1	Mechanisms exist to ensure that every user accessing Technology Assets, Applications and/or Services (TAAS) that process, store and/or transmit sensitive and/or regulated data is cleared and regularly trained to handle the information in question.	5	Updated in 2026.2	
A.03.01.02[02]	Access Enforcement	approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Updated in 2026.2	
A.03.01.02[02]	Access Enforcement	approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5	Updated in 2026.2	
A.03.01.02[02]	Access Enforcement	approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	Updated in 2026.2	
A.03.01.02[02]	Access Enforcement	approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	
A.03.01.02[02]	Access Enforcement	approved authorizations for logical access to system resources are enforced in accordance with applicable access control policies.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Updated in 2026.2	
03.01.03	Information Flow Enforcement	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.03[01]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI within the system.	Functional	Intersects With	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	5	Updated in 2026.2	
A.03.01.03[01]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI within the system.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	Updated in 2026.2	
A.03.01.03[01]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI within the system.	Functional	Intersects With	Defining Access Authorizations for Sensitive / Regulated Data	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and /or physical access to sensitive and/or regulated data.	5	Updated in 2026.2	
A.03.01.03[01]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI within the system.	Functional	Intersects With	Media Access	DCH-03	Mechanisms exist to control and restrict access to digital and non-digital media to authorized individuals.	5	Updated in 2026.2	
A.03.01.03[01]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI within the system.	Functional	Intersects With	Endpoint Device Management (EDM)	END-01	Mechanisms exist to facilitate the implementation of Endpoint Device Management (EDM) controls.	5	Updated in 2026.2	
A.03.01.03[01]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI within the system.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	Updated in 2026.2	
A.03.01.03[01]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI within the system.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Asset-Service Dependencies	AST-01.1	Mechanisms exist to identify and assess the security of Technology Assets, Applications and/or Services (TAAS) that support more than one critical business function.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Network Diagrams & Data Flow Diagrams (DFDs)	AST-04	Mechanisms exist to maintain network architecture diagrams that: (1) Contain sufficient detail to assess the security of the network's architecture; (2) Reflect the current architecture of the network environment; and (3) Document all sensitive and/or regulated data flows.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Compliance-Specific Asset Identification	AST-04.3	Mechanisms exist to create and maintain a current inventory of Technology Assets, Applications, Services and/or Data (TAASD) that are in scope for statutory, regulatory and/or contractual compliance obligations that provides sufficient detail to determine control applicability, based on asset scope categorization.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Asset Categorization	AST-31	Mechanisms exist to categorize Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Defining Access Authorizations for Sensitive / Regulated Data	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and /or physical access to sensitive and/or regulated data.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Media Access	DCH-03	Mechanisms exist to control and restrict access to digital and non-digital media to authorized individuals.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Data Access Mapping	DCH-14.3	Mechanisms exist to leverage data-specific Access Control Lists (ACL) or Interconnection Security Agreements (ISAs) to generate a logical map of the parties with whom sensitive and/or regulated data is shared.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Endpoint Device Management (EDM)	END-01	Mechanisms exist to facilitate the implementation of Endpoint Device Management (EDM) controls.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Data Flow Enforcement - Access Control Lists (ACLs)	NET-04	Mechanisms exist to implement and govern Access Control Lists (ACLs) to provide data flow enforcement that explicitly restrict network traffic to only what is authorized.	5	Updated in 2026.2	
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each interconnection: (1) Interface characteristics; (2) Security, compliance and resilience requirements; and; (3) The nature of the information communicated.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.01.03[02]	Information Flow Enforcement	approved authorizations are enforced for controlling the flow of CUI between connected systems.	Functional	Intersects With	Internal System Connections	NET-05.2	Mechanisms exist to control internal system connections through authorizing internal connections of systems and documenting, for each internal connection, the interface characteristics, security requirements and the nature of the information communicated.	5	Updated in 2026.2	
03.01.04	Separation of Duties	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.04.a	Separation of Duties	duties of individuals requiring separation are identified.	Functional	Intersects With	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	5		
A.03.01.04.a	Separation of Duties	duties of individuals requiring separation are identified.	Functional	Intersects With	Incompatible Roles	HRS-12	Mechanisms exist to avoid incompatible development-specific roles through limiting and reviewing developer privileges to change hardware, software and firmware components within a production/operational environment.	5	Updated in 2026.2	
A.03.01.04.a	Separation of Duties	duties of individuals requiring separation are identified.	Functional	Intersects With	Defining Access Authorizations for Sensitive / Regulated Data	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and/or physical access to sensitive and/or regulated data.	5	Updated in 2026.2	
A.03.01.04.a	Separation of Duties	duties of individuals requiring separation are identified.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	Updated in 2026.2	
A.03.01.04.a	Separation of Duties	duties of individuals requiring separation are identified.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	
A.03.01.04.a	Separation of Duties	duties of individuals requiring separation are identified.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Updated in 2026.2	
03.01.05	Least Privilege	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.05.ODP[01]	Least Privilege	security functions for authorized access are defined.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5		
A.03.01.05.ODP[02]	Least Privilege	security-relevant information for authorized access is defined.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5		
A.03.01.05.ODP[03]	Least Privilege	the frequency at which to review the privileges assigned to roles or classes of users is defined.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5		
A.03.01.05.a	Least Privilege	system access for users (or processes acting on behalf of users) is authorized only when necessary to accomplish assigned organizational tasks.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	Updated in 2026.2	
A.03.01.05.a	Least Privilege	system access for users (or processes acting on behalf of users) is authorized only when necessary to accomplish assigned organizational tasks.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	
A.03.01.05.a	Least Privilege	system access for users (or processes acting on behalf of users) is authorized only when necessary to accomplish assigned organizational tasks.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5		
A.03.01.05.b[01]	Least Privilege	access to <A.03.01.05.ODP[01]: security functions> is authorized.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	8		US DoD ODP Value: at a minimum and if applicable: establishing system accounts and assigning privileges, configuring access authorizations, configuring settings for events to be audited, establishing vulnerability scanning parameters, establishing intrusion detection parameters, and managing audit information
A.03.01.05.b[01]	Least Privilege	access to <A.03.01.05.ODP[01]: security functions> is authorized.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; and (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	8	Updated in 2026.2	US DoD ODP Value: at a minimum and if applicable: establishing system accounts and assigning privileges, configuring access authorizations, configuring settings for events to be audited, establishing vulnerability scanning parameters, establishing intrusion detection parameters, and managing audit information
A.03.01.05.b[01]	Least Privilege	access to <A.03.01.05.ODP[01]: security functions> is authorized.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	8	Updated in 2026.2	US DoD ODP Value: at a minimum and if applicable: establishing system accounts and assigning privileges, configuring access authorizations, configuring settings for events to be audited, establishing vulnerability scanning parameters, establishing intrusion detection parameters, and managing audit information
A.03.01.05.b[01]	Least Privilege	access to <A.03.01.05.ODP[01]: security functions> is authorized.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	8		US DoD ODP Value: at a minimum and if applicable: establishing system accounts and assigning privileges, configuring access authorizations, configuring settings for events to be audited, establishing vulnerability scanning parameters, establishing intrusion detection parameters, and managing audit information
A.03.01.05.b[01]	Least Privilege	access to <A.03.01.05.ODP[01]: security functions> is authorized.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	8	Updated in 2026.2	US DoD ODP Value: at a minimum and if applicable: establishing system accounts and assigning privileges, configuring access authorizations, configuring settings for events to be audited, establishing vulnerability scanning parameters, establishing intrusion detection parameters, and managing audit information

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-hereset-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.01.05.b[02]	Least Privilege	access to <A.03.01.05.ODP[02]: security-relevant information> is authorized.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	8		US DoD ODP Value: at a minimum and if applicable: establishing system accounts and assigning privileges, configuring access authorizations, configuring settings for events to be audited, establishing vulnerability scanning parameters, establishing intrusion detection parameters, and managing audit information
A.03.01.05.b[02]	Least Privilege	access to <A.03.01.05.ODP[02]: security-relevant information> is authorized.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	8	Updated in 2026.2	US DoD ODP Value: at a minimum and if applicable: establishing system accounts and assigning privileges, configuring access authorizations, configuring settings for events to be audited, establishing vulnerability scanning parameters, establishing intrusion detection parameters, and managing audit information
A.03.01.05.b[02]	Least Privilege	access to <A.03.01.05.ODP[02]: security-relevant information> is authorized.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	8	Updated in 2026.2	US DoD ODP Value: at a minimum and if applicable: establishing system accounts and assigning privileges, configuring access authorizations, configuring settings for events to be audited, establishing vulnerability scanning parameters, establishing intrusion detection parameters, and managing audit information
A.03.01.05.b[02]	Least Privilege	access to <A.03.01.05.ODP[02]: security-relevant information> is authorized.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	8		US DoD ODP Value: at a minimum and if applicable: establishing system accounts and assigning privileges, configuring access authorizations, configuring settings for events to be audited, establishing vulnerability scanning parameters, establishing intrusion detection parameters, and managing audit information
A.03.01.05.b[02]	Least Privilege	access to <A.03.01.05.ODP[02]: security-relevant information> is authorized.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	8	Updated in 2026.2	US DoD ODP Value: at a minimum and if applicable: establishing system accounts and assigning privileges, configuring access authorizations, configuring settings for events to be audited, establishing vulnerability scanning parameters, establishing intrusion detection parameters, and managing audit information
A.03.01.05.c	Least Privilege	the privileges assigned to roles or classes of users are reviewed <A.03.01.05.ODP[03]: frequency> to validate the need for such privileges.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months
A.03.01.05.c	Least Privilege	the privileges assigned to roles or classes of users are reviewed <A.03.01.05.ODP[03]: frequency> to validate the need for such privileges.	Functional	Intersects With	System Account Reviews	IAC-15.7	Mechanisms exist to review all system accounts and disable any account that cannot be associated with a business process and owner.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months
A.03.01.05.c	Least Privilege	the privileges assigned to roles or classes of users are reviewed <A.03.01.05.ODP[03]: frequency> to validate the need for such privileges.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	8		US DoD ODP Value: at least every 12 months
A.03.01.05.d	Least Privilege	privileges are reassigned or removed, as necessary.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5	Updated in 2026.2	
A.03.01.05.d	Least Privilege	privileges are reassigned or removed, as necessary.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5		
03.01.06	Least Privilege – Privileged Accounts	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.06.ODP[01]	Least Privilege – Privileged Accounts	personnel or roles to which privileged accounts on the system are to be restricted are defined.	Functional	Intersects With	Management Approval For Privileged Accounts	IAC-21.3	Mechanisms exist to restrict the assignment of privileged accounts to management-approved personnel and/or roles.	5		
A.03.01.06.a	Least Privilege – Privileged Accounts	privileged accounts on the system are restricted to <A.03.01.06.ODP[01]: personnel or roles>.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	8	Updated in 2026.2	US DoD ODP Value: only defined and authorized personnel or administrative roles
A.03.01.06.a	Least Privilege – Privileged Accounts	privileged accounts on the system are restricted to <A.03.01.06.ODP[01]: personnel or roles>.	Functional	Intersects With	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	8	Updated in 2026.2	US DoD ODP Value: only defined and authorized personnel or administrative roles
A.03.01.06.a	Least Privilege – Privileged Accounts	privileged accounts on the system are restricted to <A.03.01.06.ODP[01]: personnel or roles>.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	8	Updated in 2026.2	US DoD ODP Value: only defined and authorized personnel or administrative roles
A.03.01.06.a	Least Privilege – Privileged Accounts	privileged accounts on the system are restricted to <A.03.01.06.ODP[01]: personnel or roles>.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	8	Updated in 2026.2	US DoD ODP Value: only defined and authorized personnel or administrative roles
A.03.01.06.a	Least Privilege – Privileged Accounts	privileged accounts on the system are restricted to <A.03.01.06.ODP[01]: personnel or roles>.	Functional	Intersects With	Management Approval For Privileged Accounts	IAC-21.3	Mechanisms exist to restrict the assignment of privileged accounts to management-approved personnel and/or roles.	8		US DoD ODP Value: only defined and authorized personnel or administrative roles
A.03.01.06.b	Least Privilege – Privileged Accounts	users (or roles) with privileged accounts are required to use non-privileged accounts when accessing non-security functions or non-security information.	Functional	Intersects With	Non-Privileged Access for Non-Security Functions	IAC-21.2	Mechanisms exist to prohibit privileged users from using privileged accounts, while performing non-security functions.	5		
03.01.07	Least Privilege – Privileged Functions	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.01.07.a	Least Privilege – Privileged Functions	non-privileged users are prevented from executing privileged functions.	Functional	Intersects With	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.01.07.a	Least Privilege – Privileged Functions	non-privileged users are prevented from executing privileged functions.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Updated in 2026.2	
A.03.01.07.a	Least Privilege – Privileged Functions	non-privileged users are prevented from executing privileged functions.	Functional	Intersects With	Management Approval For Privileged Accounts	IAC-21.3	Mechanisms exist to restrict the assignment of privileged accounts to management-approved personnel and/or roles.	5	Updated in 2026.2	
A.03.01.07.a	Least Privilege – Privileged Functions	non-privileged users are prevented from executing privileged functions.	Functional	Intersects With	Prohibit Non-Privileged Users from Executing Privileged Functions	IAC-21.5	Mechanisms exist to prevent non-privileged users from executing privileged functions to include disabling, circumventing or altering implemented security safeguards / countermeasures.	5		
A.03.01.07.b	Least Privilege – Privileged Functions	the execution of privileged functions is logged.	Functional	Intersects With	Privileged Account Identifiers	IAC-09.5	Mechanisms exist to uniquely manage privileged accounts to identify the account as a privileged user or service.	5	Updated in 2026.2	
A.03.01.07.b	Least Privilege – Privileged Functions	the execution of privileged functions is logged.	Functional	Intersects With	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.01.07.b	Least Privilege – Privileged Functions	the execution of privileged functions is logged.	Functional	Intersects With	Auditing Use of Privileged Functions	IAC-21.4	Mechanisms exist to audit the execution of privileged functions.	5	Updated in 2026.2	
A.03.01.07.b	Least Privilege – Privileged Functions	the execution of privileged functions is logged.	Functional	Intersects With	Privileged User Oversight	MON-01.15	Mechanisms exist to implement enhanced activity monitoring for privileged users.	5	Updated in 2026.2	
A.03.01.07.b	Least Privilege – Privileged Functions	the execution of privileged functions is logged.	Functional	Intersects With	Privileged Functions Logging	MON-03.3	Mechanisms exist to log and review the actions of users and/or services with elevated privileges.	5		
03.01.08	Unsuccessful Logon Attempts	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.08.ODP[01]	Unsuccessful Logon Attempts	the number of consecutive invalid logon attempts by a user allowed during a time period is defined.	Functional	Intersects With	Account Lockout	IAC-22	Mechanisms exist to enforce a limit for consecutive invalid login attempts by a user during an organization-defined time period and automatically locks the account when the maximum number of unsuccessful attempts is exceeded.	5		
A.03.01.08.ODP[02]	Unsuccessful Logon Attempts	the time period to which the number of consecutive invalid logon attempts by a user is limited is defined.	Functional	Intersects With	Account Lockout	IAC-22	Mechanisms exist to enforce a limit for consecutive invalid login attempts by a user during an organization-defined time period and automatically locks the account when the maximum number of unsuccessful attempts is exceeded.	5		
A.03.01.08.ODP[03]	Unsuccessful Logon Attempts	one or more of the following PARAMETER VALUES are selected: (the account or node is locked automatically for <A.03.01.08.ODP[04]: time period>; the account or node is locked automatically until released by an administrator; the next logon prompt is delayed automatically; the system administrator is notified automatically; other action is taken automatically).	Functional	Intersects With	Account Lockout	IAC-22	Mechanisms exist to enforce a limit for consecutive invalid login attempts by a user during an organization-defined time period and automatically locks the account when the maximum number of unsuccessful attempts is exceeded.	8		US DoD ODP Value: at least 15- minute time period
A.03.01.08.ODP[04]	Unsuccessful Logon Attempts	the time period for an account or node to be locked is defined (if selected).	Functional	Intersects With	Account Lockout	IAC-22	Mechanisms exist to enforce a limit for consecutive invalid login attempts by a user during an organization-defined time period and automatically locks the account when the maximum number of unsuccessful attempts is exceeded.	5		
A.03.01.08.a	Unsuccessful Logon Attempts	a limit of <A.03.01.08.ODP[01]: number> consecutive invalid logon attempts by a user during <A.03.01.08.ODP[02]: time period> is enforced.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	8	Updated in 2026.2	US DoD ODP Values: [01] - at most five (5) [02] - period of five (5) minutes
A.03.01.08.a	Unsuccessful Logon Attempts	a limit of <A.03.01.08.ODP[01]: number> consecutive invalid logon attempts by a user during <A.03.01.08.ODP[02]: time period> is enforced.	Functional	Intersects With	Account Lockout	IAC-22	Mechanisms exist to enforce a limit for consecutive invalid login attempts by a user during an organization-defined time period and automatically locks the account when the maximum number of unsuccessful attempts is exceeded.	8		US DoD ODP Values: [01] - at most five (5) [02] - period of five (5) minutes
A.03.01.08.b	Unsuccessful Logon Attempts	<A.03.01.08.ODP[03]: SELECTED PARAMETER VALUES> when the maximum number of unsuccessful attempts is exceeded.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	8	Updated in 2026.2	US DoD ODP Value: Select one or more: - lock the account or node for an at least 15- minute time period; - lock the account or node until released by an administrator and notify a system administrator
A.03.01.08.b	Unsuccessful Logon Attempts	<A.03.01.08.ODP[03]: SELECTED PARAMETER VALUES> when the maximum number of unsuccessful attempts is exceeded.	Functional	Intersects With	Account Lockout	IAC-22	Mechanisms exist to enforce a limit for consecutive invalid login attempts by a user during an organization-defined time period and automatically locks the account when the maximum number of unsuccessful attempts is exceeded.	8		US DoD ODP Value: Select one or more: - lock the account or node for an at least 15- minute time period; - lock the account or node until released by an administrator and notify a system administrator
03.01.09	System Use Notification	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.09	System Use Notification	a system use notification message with privacy and security notices consistent with applicable CUI rules is displayed before granting access to the system.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	Updated in 2026.2	
A.03.01.09	System Use Notification	a system use notification message with privacy and security notices consistent with applicable CUI rules is displayed before granting access to the system.	Functional	Intersects With	System Use Notification (Logon Banner)	SEA-18	Mechanisms exist to utilize system use notification / logon banners that display an approved system use notification message or banner before granting access to Technology Assets, Applications and/or Services (TAAS).	5		
A.03.01.09	System Use Notification	a system use notification message with privacy and security notices consistent with applicable CUI rules is displayed before granting access to the system.	Functional	Intersects With	Standardized Microsoft Windows Banner	SEA-18.1	Mechanisms exist to configure Microsoft Windows-based systems to display an approved logon banner before granting access to the system.	5		
A.03.01.09	System Use Notification	a system use notification message with privacy and security notices consistent with applicable CUI rules is displayed before granting access to the system.	Functional	Intersects With	Truncated Banner	SEA-18.2	Mechanisms exist to utilize a truncated system use notification / logon banner on systems not capable of displaying a logon banner from a centralized directory services technology (e.g., Active Directory, Entra ID, etc.).	5		
03.01.10	Device Lock	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.10.ODP[01]	Device Lock	one or more of the following PARAMETER VALUES are selected: (a device lock is initiated after <A.03.01.10.ODP[02]: time period> of inactivity; the user is required to initiate a device lock before leaving the system unattended).	Functional	Intersects With	Session Lock	IAC-24	Mechanisms exist to initiate a session lock after an organization-defined time period of inactivity, or upon receiving a request from a user and retain the session lock until the user reestablishes access using established identification and authentication methods.	8		US DoD ODP Value: at most 15- minute time period
A.03.01.10.ODP[02]	Device Lock	the time period of inactivity after which a device lock is initiated is defined (if selected).	Functional	Intersects With	Session Lock	IAC-24	Mechanisms exist to initiate a session lock after an organization-defined time period of inactivity, or upon receiving a request from a user and retain the session lock until the user reestablishes access using established identification and authentication methods.	5		
A.03.01.10.a	Device Lock	access to the system is prevented by <A.03.01.10.ODP[01]: SELECTED PARAMETER VALUES>.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	8	Updated in 2026.2	US DoD ODP Value: Initiating a device lock after "at most 15 minutes" of inactivity and requiring the user to initiate a device lock before leaving the system unattended
A.03.01.10.a	Device Lock	access to the system is prevented by <A.03.01.10.ODP[01]: SELECTED PARAMETER VALUES>.	Functional	Intersects With	Session Lock	IAC-24	Mechanisms exist to initiate a session lock after an organization-defined time period of inactivity, or upon receiving a request from a user and retain the session lock until the user reestablishes access using established identification and authentication methods.	8		US DoD ODP Value: Initiating a device lock after "at most 15 minutes" of inactivity and requiring the user to initiate a device lock before leaving the system unattended
A.03.01.10.b	Device Lock	the device lock is retained until the user reestablishes access using established identification and authentication procedures.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.01.10.b	Device Lock	the device lock is retained until the user reestablishes access using established identification and authentication procedures.	Functional	Intersects With	Session Lock	IAC-24	Mechanisms exist to initiate a session lock after an organization-defined time period of inactivity, or upon receiving a request from a user and retain the session lock until the user reestablishes access using established identification and authentication methods.	5		
A.03.01.10.c	Device Lock	information previously visible on the display is concealed via device lock with a publicly viewable image.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	Updated in 2026.2	
A.03.01.10.c	Device Lock	information previously visible on the display is concealed via device lock with a publicly viewable image.	Functional	Intersects With	Pattern-Hiding Displays	IAC-24.1	Mechanisms exist to implement pattern-hiding displays to conceal information previously visible on the display during the session lock.	5		
03.01.11	Session Termination	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.11.ODP[01]	Session Termination	conditions or trigger events that require session disconnect are defined.	Functional	Intersects With	Session Termination	IAC-25	Automated mechanisms exist to log out users, both locally on the network and for remote sessions, at the end of the session or after an organization-defined period of inactivity.	5		
A.03.01.11	Session Termination	a user session is terminated automatically after <A.03.01.11.ODP[01]: conditions or trigger events>.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	8	Updated in 2026.2	US DoD ODP Value: a specified duration (maximum of 24 hours) of inactivity, misbehavior (end the session due to an attempted policy violation), and maintenance (terminate sessions to prevent issues with an upgrade or service outage)
A.03.01.11	Session Termination	a user session is terminated automatically after <A.03.01.11.ODP[01]: conditions or trigger events>.	Functional	Intersects With	Session Termination	IAC-25	Automated mechanisms exist to log out users, both locally on the network and for remote sessions, at the end of the session or after an organization-defined period of inactivity.	8		US DoD ODP Value: a specified duration (maximum of 24 hours) of inactivity, misbehavior (end the session due to an attempted policy violation), and maintenance (terminate sessions to prevent issues with an upgrade or service outage)
03.01.12	Remote Access	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.12.a[01]	Remote Access	types of allowable remote system access are defined.	Functional	Intersects With	Jump Server	AST-27	Mechanisms exist to conduct remote system administrative functions via a "jump box" or "jump server" that is located in a separate network zone to user workstations.	5	Updated in 2026.2	
A.03.01.12.a[01]	Remote Access	types of allowable remote system access are defined.	Functional	Intersects With	Remote Access	NET-14	Mechanisms exist to define, control and review organization-approved, secure remote access methods.	5		
A.03.01.12.a[01]	Remote Access	types of allowable remote system access are defined.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Updated in 2026.2	
A.03.01.12.a[02]	Remote Access	usage restrictions are established for each type of allowable remote system access.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Updated in 2026.2	
A.03.01.12.a[02]	Remote Access	usage restrictions are established for each type of allowable remote system access.	Functional	Intersects With	Remote Access	NET-14	Mechanisms exist to define, control and review organization-approved, secure remote access methods.	5		
A.03.01.12.a[03]	Remote Access	configuration requirements are established for each type of allowable remote system access.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	Updated in 2026.2	
A.03.01.12.a[04]	Remote Access	connection requirements are established for each type of allowable remote system access.	Functional	Intersects With	Remote Access	NET-14	Mechanisms exist to define, control and review organization-approved, secure remote access methods.	5		
A.03.01.12.a[04]	Remote Access	connection requirements are established for each type of allowable remote system access.	Functional	Intersects With	Protection of Confidentiality / Integrity Using Encryption	NET-14.2	Cryptographic mechanisms exist to protect the confidentiality and integrity of remote access sessions (e.g., VPN).	5	Updated in 2026.2	
A.03.01.12.a[04]	Remote Access	connection requirements are established for each type of allowable remote system access.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.01.12.b	Remote Access	each type of remote system access is authorized prior to establishing such connections.	Functional	Intersects With	Remote Access	NET-14	Mechanisms exist to define, control and review organization-approved, secure remote access methods.	5		
A.03.01.12.b	Remote Access	each type of remote system access is authorized prior to establishing such connections.	Functional	Intersects With	Automated Monitoring & Control	NET-14.1	Automated mechanisms exist to monitor and control remote access sessions.	5	Updated in 2026.2	
A.03.01.12.c[01]	Remote Access	remote access to the system is routed through authorized access control points.	Functional	Intersects With	Jump Server	AST-27	Mechanisms exist to conduct remote system administrative functions via a "jump box" or "jump server" that is located in a separate network zone to user workstations.	5	Updated in 2026.2	
A.03.01.12.c[01]	Remote Access	remote access to the system is routed through authorized access control points.	Functional	Intersects With	Remote Access	NET-14	Mechanisms exist to define, control and review organization-approved, secure remote access methods.	5		
A.03.01.12.c[01]	Remote Access	remote access to the system is routed through authorized access control points.	Functional	Intersects With	Managed Access Control Points	NET-14.3	Mechanisms exist to route all remote accesses through managed network access control points (e.g., VPN concentrator).	5	Updated in 2026.2	
A.03.01.12.c[02]	Remote Access	remote access to the system is routed through managed access control points.	Functional	Intersects With	Jump Server	AST-27	Mechanisms exist to conduct remote system administrative functions via a "jump box" or "jump server" that is located in a separate network zone to user workstations.	5	Updated in 2026.2	
A.03.01.12.c[02]	Remote Access	remote access to the system is routed through managed access control points.	Functional	Intersects With	Remote Access	NET-14	Mechanisms exist to define, control and review organization-approved, secure remote access methods.	5		
A.03.01.12.c[02]	Remote Access	remote access to the system is routed through managed access control points.	Functional	Intersects With	Managed Access Control Points	NET-14.3	Mechanisms exist to route all remote accesses through managed network access control points (e.g., VPN concentrator).	5	Updated in 2026.2	
A.03.01.12.d[1]	Remote Access	remote execution of privileged commands is authorized.	Functional	Intersects With	Remote Maintenance	MNT-05	Mechanisms exist to authorize, monitor and control remote, non-local maintenance and diagnostic activities.	5	Updated in 2026.2	
A.03.01.12.d[1]	Remote Access	remote execution of privileged commands is authorized.	Functional	Intersects With	Remote Privileged Commands & Sensitive Data Access	NET-14.4	Mechanisms exist to restrict the execution of privileged commands and access to security-relevant information via remote access only for compelling operational needs.	5		
A.03.01.12.d[2]	Remote Access	remote access to security-relevant information is authorized.	Functional	Intersects With	Remote Privileged Commands & Sensitive Data Access	NET-14.4	Mechanisms exist to restrict the execution of privileged commands and access to security-relevant information via remote access only for compelling operational needs.	5		
03.01.13	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.01.14	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.01.15	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.01.16	Wireless Access	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.16.a[01]	Wireless Access	each type of wireless access to the system is defined.	Functional	Intersects With	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	5	Updated in 2026.2	
A.03.01.16.a[01]	Wireless Access	each type of wireless access to the system is defined.	Functional	Intersects With	Guest Networks	NET-02.2	Mechanisms exist to implement and manage a secure guest network.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD OWP Values
A.03.01.16.a[01]	Wireless Access	each type of wireless access to the system is defined.	Functional	Intersects With	Wireless Networking	NET-15	Mechanisms exist to control authorized wireless usage and monitor for unauthorized wireless access.	5		
A.03.01.16.a[02]	Wireless Access	usage restrictions are established for each type of wireless access to the system.	Functional	Intersects With	Wireless Access Authentication & Encryption	CRY-07	Mechanisms exist to protect the confidentiality and integrity of wireless networking technologies by implementing authentication and strong encryption.	5	Updated in 2026.2	
A.03.01.16.a[02]	Wireless Access	usage restrictions are established for each type of wireless access to the system.	Functional	Intersects With	Guest Networks	NET-02.2	Mechanisms exist to implement and manage a secure guest network.	5		
A.03.01.16.a[02]	Wireless Access	usage restrictions are established for each type of wireless access to the system.	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	5	Updated in 2026.2	
A.03.01.16.a[02]	Wireless Access	usage restrictions are established for each type of wireless access to the system.	Functional	Intersects With	Wireless Networking	NET-15	Mechanisms exist to control authorized wireless usage and monitor for unauthorized wireless access.	5		
A.03.01.16.a[02]	Wireless Access	usage restrictions are established for each type of wireless access to the system.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.01.16.a[02]	Wireless Access	usage restrictions are established for each type of wireless access to the system.	Functional	Intersects With	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations, assets, individuals and other organizations.	5	Updated in 2026.2	
A.03.01.16.a[03]	Wireless Access	configuration requirements are established for each type of wireless access to the system.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5		
A.03.01.16.a[03]	Wireless Access	configuration requirements are established for each type of wireless access to the system.	Functional	Intersects With	Restrict Configuration By Users	NET-15.3	Mechanisms exist to identify and explicitly authorize users who are allowed to independently configure wireless networking capabilities.	5	Updated in 2026.2	
A.03.01.16.a[04]	Wireless Access	connection requirements are established for each type of wireless access to the system.	Functional	Intersects With	Guest Networks	NET-02.2	Mechanisms exist to implement and manage a secure guest network.	5		
A.03.01.16.a[04]	Wireless Access	connection requirements are established for each type of wireless access to the system.	Functional	Intersects With	Wireless Networking	NET-15	Mechanisms exist to control authorized wireless usage and monitor for unauthorized wireless access.	5		
A.03.01.16.a[04]	Wireless Access	connection requirements are established for each type of wireless access to the system.	Functional	Intersects With	Authentication & Encryption	NET-15.1	Mechanisms exist to secure Wi-Fi (e.g., IEEE 802.11) and prevent unauthorized access by: (1) Authenticating devices trying to connect; and (2) Encrypting transmitted data.	5	Updated in 2026.2	
A.03.01.16.b	Wireless Access	each type of wireless access to the system is authorized prior to establishing such connections.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5		
A.03.01.16.b	Wireless Access	each type of wireless access to the system is authorized prior to establishing such connections.	Functional	Intersects With	Guest Networks	NET-02.2	Mechanisms exist to implement and manage a secure guest network.	5		
A.03.01.16.b	Wireless Access	each type of wireless access to the system is authorized prior to establishing such connections.	Functional	Intersects With	Wireless Networking	NET-15	Mechanisms exist to control authorized wireless usage and monitor for unauthorized wireless access.	5	Updated in 2026.2	
A.03.01.16.b	Wireless Access	each type of wireless access to the system is authorized prior to establishing such connections.	Functional	Intersects With	Authentication & Encryption	NET-15.1	Mechanisms exist to secure Wi-Fi (e.g., IEEE 802.11) and prevent unauthorized access by: (1) Authenticating devices trying to connect; and (2) Encrypting transmitted data.	5	Updated in 2026.2	
A.03.01.16.c	Wireless Access	wireless networking capabilities not intended for use are disabled prior to issuance and deployment.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5		
A.03.01.16.c	Wireless Access	wireless networking capabilities not intended for use are disabled prior to issuance and deployment.	Functional	Intersects With	Disable Wireless Networking	NET-15.2	Mechanisms exist to disable unnecessary wireless networking capabilities that are internally embedded within system components prior to issuance to and users.	5	Updated in 2026.2	
A.03.01.16.c	Wireless Access	wireless networking capabilities not intended for use are disabled prior to issuance and deployment.	Functional	Intersects With	Restrict Configuration By Users	NET-15.3	Mechanisms exist to identify and explicitly authorize users who are allowed to independently configure wireless networking capabilities.	5	Updated in 2026.2	
A.03.01.16.c	Wireless Access	wireless networking capabilities not intended for use are disabled prior to issuance and deployment.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.01.16.d[01]	Wireless Access	wireless access to the system is protected using authentication.	Functional	Intersects With	Authentication & Encryption	NET-15.1	Mechanisms exist to secure Wi-Fi (e.g., IEEE 802.11) and prevent unauthorized access by: (1) Authenticating devices trying to connect; and (2) Encrypting transmitted data.	5		
A.03.01.16.d[02]	Wireless Access	wireless access to the system is protected using encryption.	Functional	Intersects With	Authentication & Encryption	NET-15.1	Mechanisms exist to secure Wi-Fi (e.g., IEEE 802.11) and prevent unauthorized access by: (1) Authenticating devices trying to connect; and (2) Encrypting transmitted data.	5		
03.01.17	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.01.18	Access Control for Mobile Devices	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	10	Updated in 2026.2	
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Use of Personal Devices	AST-12	Mechanisms exist to restrict the possession and/or use of personally-owned Technology Assets, Applications and/or Services (TAAS) within organization-controlled facilities.	10	Updated in 2026.2	
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Use of Third-Party Devices	AST-13	Mechanisms exist to reduce the risk associated with third-party assets that are attached to the network from harming organizational assets or exfiltrating organizational data.	10	Updated in 2026.2	
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Usage Parameters	AST-14	Mechanisms exist to monitor and enforce usage parameters that limit the potential damage caused from the unauthorized or unintentional alteration of system parameters.	10	Updated in 2026.2	
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Bring Your Own Device (BYOD) Usage	AST-16	Mechanisms exist to implement and govern a Bring Your Own Device (BYOD) program to reduce risk associated with personally-owned devices in the workplace.	10	Updated in 2026.2	
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	10	Updated in 2026.2	
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Technology Use Restrictions	HRS-05.3	Mechanisms exist to establish usage restrictions and implementation guidance for organizational technologies based on the potential to cause damage to Technology Assets, Applications and/or Services (TAAS), if used maliciously.	10	Updated in 2026.2	
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Use of Mobile Devices	HRS-05.5	Mechanisms exist to manage business risks associated with permitting mobile device access to organizational resources.	10	Updated in 2026.2	
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Access Agreements	HRS-06	Mechanisms exist to require internal and third-party users to sign appropriate access agreements prior to being granted access.	10	Updated in 2026.2	
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Centralized Management Of Mobile Devices	MDM-01	Mechanisms exist to implement and govern Mobile Device Management (MDM) controls.	10		
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Personally-Owned Mobile Devices	MDM-06	Mechanisms exist to restrict the connection of personally-owned, mobile devices to organizational Technology Assets, Applications and/or Services (TAAS).	10	Updated in 2026.2	
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Organization-Owned Mobile Devices	MDM-07	Mechanisms exist to prohibit the installation of non-approved applications or approved applications not obtained through the organization-approved application store.	10	Updated in 2026.2	
A.03.01.18.a[01]	Access Control for Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.01.18.a[01]	Access Control For Mobile Devices	usage restrictions are established for mobile devices.	Functional	Subset Of	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations, assets, individuals and other organizations.	10	Updated in 2026.2	
A.03.01.18.a[02]	Access Control For Mobile Devices	configuration requirements are established for mobile devices.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5		
A.03.01.18.a[02]	Access Control For Mobile Devices	configuration requirements are established for mobile devices.	Functional	Intersects With	Access Control For Mobile Devices	MDM-02	Mechanisms exist to enforce access control requirements for the connection of mobile devices to organizational Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.01.18.a[03]	Access Control For Mobile Devices	connection requirements are established for mobile devices.	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	5	Updated in 2026.2	
A.03.01.18.a[03]	Access Control For Mobile Devices	connection requirements are established for mobile devices.	Functional	Intersects With	Boundary Protection	NET-03	Mechanisms exist to monitor and control communications at the external network boundary and at key internal boundaries within the network.	5		
A.03.01.18.b	Access Control For Mobile Devices	the connection of mobile devices to the system is authorized.	Functional	Intersects With	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	5	Updated in 2026.2	
A.03.01.18.b	Access Control For Mobile Devices	the connection of mobile devices to the system is authorized.	Functional	Intersects With	Identification & Authentication for Devices	IAC-04	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) devices before establishing a connection using bidirectional authentication that is cryptographically- based and replay resistant.	5	Updated in 2026.2	
A.03.01.18.b	Access Control For Mobile Devices	the connection of mobile devices to the system is authorized.	Functional	Intersects With	Access Control For Mobile Devices	MDM-02	Mechanisms exist to enforce access control requirements for the connection of mobile devices to organizational Technology Assets, Applications and/or Services (TAAS).	5		
A.03.01.18.b	Access Control For Mobile Devices	the connection of mobile devices to the system is authorized.	Functional	Intersects With	Personally-Owned Mobile Devices	MDM-06	Mechanisms exist to restrict the connection of personally-owned, mobile devices to organizational Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.01.18.b	Access Control For Mobile Devices	the connection of mobile devices to the system is authorized.	Functional	Intersects With	Organization-Owned Mobile Devices	MDM-07	Mechanisms exist to prohibit the installation of non-approved applications or approved applications not obtained through the organization-approved application store.	5	Updated in 2026.2	
A.03.01.18.b	Access Control For Mobile Devices	the connection of mobile devices to the system is authorized.	Functional	Intersects With	Restricting Access To Authorized Technology Assets, Applications and/or Services (TAAS)	MDM-11	Mechanisms exist to restrict the connectivity of unauthorized mobile devices from communicating with organizational Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.01.18.c	Access Control For Mobile Devices	full-device or container-based encryption is implemented to protect the confidentiality of CUI on mobile devices.	Functional	Intersects With	Full Device & Container-Based Encryption	MDM-03	Cryptographic mechanisms exist to protect the confidentiality and integrity of information on mobile devices through full-device or container encryption.	5		
03.01.19	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.01.20	Use of External Systems	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.20.ODP[01]	Use of External Systems	security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are defined.	Functional	Intersects With	Use of External Technology Assets, Applications and/or Services (TAAS)	DCH-13	Mechanisms exist to govern how external parties, including Technology Assets, Applications and/or Services (TAAS), are used to securely store, process and transmit data.	5		
A.03.01.20.a	Use of External Systems	the use of external systems is prohibited unless the systems are specifically authorized.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	
A.03.01.20.a	Use of External Systems	the use of external systems is prohibited unless the systems are specifically authorized.	Functional	Intersects With	Use of External Technology Assets, Applications and/or Services (TAAS)	DCH-13	Mechanisms exist to govern how external parties, including Technology Assets, Applications and/or Services (TAAS), are used to securely store, process and transmit data.	5		
A.03.01.20.a	Use of External Systems	the use of external systems is prohibited unless the systems are specifically authorized.	Functional	Intersects With	Limits of Authorized Use	DCH-13.1	Mechanisms exist to prohibit external parties, including Technology Assets, Applications and/or Services (TAAS), from storing, processing and transmitting data unless authorized individuals first: (1) Verifying the implementation of required security, compliance and/or resilience controls; or (2) Retaining a processing agreement with the entity hosting the external TAAS.	5	Updated in 2026.2	
A.03.01.20.a	Use of External Systems	the use of external systems is prohibited unless the systems are specifically authorized.	Functional	Intersects With	Portable Storage Devices	DCH-13.2	Mechanisms exist to restrict or prohibit the use of portable storage devices by users on external systems.	5	Updated in 2026.2	
A.03.01.20.a	Use of External Systems	the use of external systems is prohibited unless the systems are specifically authorized.	Functional	Intersects With	Non-Organizationally Owned Technology Assets, Applications and/or Services (TAAS)	DCH-13.4	Mechanisms exist to restrict the use of non-organizationally owned Technology Assets, Applications and/or Services (TAAS) to process, store or transmit organizational information.	5	Updated in 2026.2	
A.03.01.20.a	Use of External Systems	the use of external systems is prohibited unless the systems are specifically authorized.	Functional	Intersects With	Ad-Hoc Transfers	DCH-17	Mechanisms exist to secure ad-hoc exchanges of large digital files with internal or external parties.	5	Updated in 2026.2	
A.03.01.20.a	Use of External Systems	the use of external systems is prohibited unless the systems are specifically authorized.	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	5	Updated in 2026.2	
A.03.01.20.a	Use of External Systems	the use of external systems is prohibited unless the systems are specifically authorized.	Functional	Intersects With	Third-Party Attestation (3PA)	TPM-05.8	Mechanisms exist to obtain an attestation from an independent Third-Party Assessment Organization (3PAO) that provides assurance of conformity with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down requirements to contractors and subcontractors.	5	Updated in 2026.2	
A.03.01.20.b	Use of External Systems	the following security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are established: <A.03.01.20.ODP[01]: security requirements>.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Organizations establish specific terms and conditions for the use of external systems in accordance with organizational security policies and procedures. At a minimum, terms and conditions address the specific types of applications that can be accessed on organizational systems from external systems and the highest security category of information that can be processed, stored, or transmitted on external systems. If the terms and conditions with the owners of the external systems cannot be established, organizations may impose restrictions on organizational personnel using those external systems. If applicable, use NIST SP 800-47 as a guide for establishing information exchanges between organizations.

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.01.20.b	Use of External Systems	the following security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are established: <A.03.01.20.ODP[01]: security requirements>.	Functional	Intersects With	Use of External Technology Assets, Applications and/or Services (TAAS)	DCH-13	Mechanisms exist to govern how external parties, including Technology Assets, Applications and/or Services (TAAS), are used to securely store, process and transmit data.	5		US DoD ODP Value: Guidance: Organizations establish specific terms and conditions for the use of external systems in accordance with organizational security policies and procedures. At a minimum, terms and conditions address the specific types of applications that can be accessed on organizational systems from external systems and the highest security category of information that can be processed, stored, or transmitted on external systems. If the terms and conditions with the owners of the external systems cannot be established, organizations may impose restrictions on organizational personnel using those external systems. If applicable, use NIST SP 800-47 as a guide for establishing information exchanges between organizations.
A.03.01.20.b	Use of External Systems	the following security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are established: <A.03.01.20.ODP[01]: security requirements>.	Functional	Intersects With	Limits of Authorized Use	DCH-13.1	Mechanisms exist to prohibit external parties, including Technology Assets, Applications and/or Services (TAAS), from storing, processing and transmitting data unless authorized individuals first: (1) Verifying the implementation of required security, compliance and/or resilience controls; or (2) Retaining a processing agreement with the entity hosting the external TAAS.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Organizations establish specific terms and conditions for the use of external systems in accordance with organizational security policies and procedures. At a minimum, terms and conditions address the specific types of applications that can be accessed on organizational systems from external systems and the highest security category of information that can be processed, stored, or transmitted on external systems. If the terms and conditions with the owners of the external systems cannot be established, organizations may impose restrictions on organizational personnel using those external systems. If applicable, use NIST SP 800-47 as a guide for establishing information exchanges between organizations.
A.03.01.20.b	Use of External Systems	the following security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are established: <A.03.01.20.ODP[01]: security requirements>.	Functional	Intersects With	Protecting Sensitive / Regulated Data on External Technology Assets, Applications and/or Services (TAAS)	DCH-13.3	Mechanisms exist to ensure that the requirements for the protection of sensitive and/or regulated data processed, stored or transmitted on external Technology Assets, Applications and/or Services (TAAS), are implemented in accordance with applicable statutory, regulatory and contractual obligations.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Organizations establish specific terms and conditions for the use of external systems in accordance with organizational security policies and procedures. At a minimum, terms and conditions address the specific types of applications that can be accessed on organizational systems from external systems and the highest security category of information that can be processed, stored, or transmitted on external systems. If the terms and conditions with the owners of the external systems cannot be established, organizations may impose restrictions on organizational personnel using those external systems. If applicable, use NIST SP 800-47 as a guide for establishing information exchanges between organizations.
A.03.01.20.b	Use of External Systems	the following security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are established: <A.03.01.20.ODP[01]: security requirements>.	Functional	Intersects With	Information Sharing	DCH-14	Mechanisms exist to utilize a process to assist users in making information sharing decisions to ensure data is appropriately protected.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Organizations establish specific terms and conditions for the use of external systems in accordance with organizational security policies and procedures. At a minimum, terms and conditions address the specific types of applications that can be accessed on organizational systems from external systems and the highest security category of information that can be processed, stored, or transmitted on external systems. If the terms and conditions with the owners of the external systems cannot be established, organizations may impose restrictions on organizational personnel using those external systems. If applicable, use NIST SP 800-47 as a guide for establishing information exchanges between organizations.

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.01.20.b	Use of External Systems	the following security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are established: <A.03.01.20.ODP[01]: security requirements>.	Functional	Intersects With	Transfer Authorizations	DCH-14.2	Mechanisms exist to verify that individuals or Technology Assets, Applications and/or Services (TAAS) transferring data between interconnecting TAAS have the requisite authorizations (e.g., write permissions or privileges) prior to transferring said data.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Organizations establish specific terms and conditions for the use of external systems in accordance with organizational security policies and procedures. At a minimum, terms and conditions address the specific types of applications that can be accessed on organizational systems from external systems and the highest security category of information that can be processed, stored, or transmitted on external systems. If the terms and conditions with the owners of the external systems cannot be established, organizations may impose restrictions on organizational personnel using those external systems. If applicable, use NIST SP 800-47 as a guide for establishing information exchanges between organizations.
A.03.01.20.b	Use of External Systems	the following security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are established: <A.03.01.20.ODP[01]: security requirements>.	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Organizations establish specific terms and conditions for the use of external systems in accordance with organizational security policies and procedures. At a minimum, terms and conditions address the specific types of applications that can be accessed on organizational systems from external systems and the highest security category of information that can be processed, stored, or transmitted on external systems. If the terms and conditions with the owners of the external systems cannot be established, organizations may impose restrictions on organizational personnel using those external systems. If applicable, use NIST SP 800-47 as a guide for establishing information exchanges between organizations.
A.03.01.20.b	Use of External Systems	the following security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are established: <A.03.01.20.ODP[01]: security requirements>.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology/ Assets, Applications, Services and/or Data (TAASD).	5	Updated in 2026.2	US DoD ODP Value: Guidance: Organizations establish specific terms and conditions for the use of external systems in accordance with organizational security policies and procedures. At a minimum, terms and conditions address the specific types of applications that can be accessed on organizational systems from external systems and the highest security category of information that can be processed, stored, or transmitted on external systems. If the terms and conditions with the owners of the external systems cannot be established, organizations may impose restrictions on organizational personnel using those external systems. If applicable, use NIST SP 800-47 as a guide for establishing information exchanges between organizations.
A.03.01.20.b	Use of External Systems	the following security requirements to be satisfied on external systems prior to allowing the use of or access to those systems by authorized individuals are established: <A.03.01.20.ODP[01]: security requirements>.	Functional	Intersects With	Third-Party Attestation (3PA)	TPM-05.8	Mechanisms exist to obtain an attestation from an independent Third-Party Assessment Organization (3PAO) that provides assurance of conformity with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down requirements to contractors and subcontractors.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Organizations establish specific terms and conditions for the use of external systems in accordance with organizational security policies and procedures. At a minimum, terms and conditions address the specific types of applications that can be accessed on organizational systems from external systems and the highest security category of information that can be processed, stored, or transmitted on external systems. If the terms and conditions with the owners of the external systems cannot be established, organizations may impose restrictions on organizational personnel using those external systems. If applicable, use NIST SP 800-47 as a guide for establishing information exchanges between organizations.

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.01.20.c.01	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after verifying that the security requirements on the external systems as specified in the organization's system security plans have been satisfied.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	
A.03.01.20.c.01	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after verifying that the security requirements on the external systems as specified in the organization's system security plans have been satisfied.	Functional	Intersects With	Use of External Technology Assets, Applications and/or Services (TAAS)	DCH-13	Mechanisms exist to govern how external parties, including Technology Assets, Applications and/or Services (TAAS), are used to securely store, process and transmit data.	5		
A.03.01.20.c.01	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after verifying that the security requirements on the external systems as specified in the organization's system security plans have been satisfied.	Functional	Intersects With	Limits of Authorized Use	DCH-13.1	Mechanisms exist to prohibit external parties, including Technology Assets, Applications and/or Services (TAAS), from storing, processing and transmitting data unless authorized individuals first: (1) Verifying the implementation of required security, compliance and/or resilience controls; or (2) Retaining a processing agreement with the entity hosting the external TAAS.	5	Updated in 2026.2	
A.03.01.20.c.01	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after verifying that the security requirements on the external systems as specified in the organization's system security plans have been satisfied.	Functional	Intersects With	Protecting Sensitive / Regulated Data on External Technology Assets, Applications and/or Services (TAAS)	DCH-13.3	Mechanisms exist to ensure that the requirements for the protection of sensitive and/or regulated data processed, stored or transmitted on external Technology Assets, Applications and/or Services (TAAS), are implemented in accordance with applicable statutory, regulatory and contractual obligations.	5	Updated in 2026.2	
A.03.01.20.c.01	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after verifying that the security requirements on the external systems as specified in the organization's system security plans have been satisfied.	Functional	Intersects With	Non-Organizationally Owned Technology Assets, Applications and/or Services (TAAS)	DCH-13.4	Mechanisms exist to restrict the use of non-organizationally owned Technology Assets, Applications and/or Services (TAAS) to process, store or transmit organizational information.	5	Updated in 2026.2	
A.03.01.20.c.01	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after verifying that the security requirements on the external systems as specified in the organization's system security plans have been satisfied.	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	5	Updated in 2026.2	
A.03.01.20.c.01	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after verifying that the security requirements on the external systems as specified in the organization's system security plans have been satisfied.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Updated in 2026.2	
A.03.01.20.c.01	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after verifying that the security requirements on the external systems as specified in the organization's system security plans have been satisfied.	Functional	Intersects With	First-Party Declaration (1PD)	TPM-05.6	Mechanisms exist to obtain a First-Party Declaration(1PD) from applicable External Service Providers (ESPs) that provides assurance of compliance with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down requirements to subcontractors.	5	Updated in 2026.2	
A.03.01.20.c.01	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after verifying that the security requirements on the external systems as specified in the organization's system security plans have been satisfied.	Functional	Intersects With	Third-Party Attestation (3PA)	TPM-05.8	Mechanisms exist to obtain an attestation from an independent Third-Party Assessment Organization (3PAO) that provides assurance of conformity with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down requirements to contractors and subcontractors.	5	Updated in 2026.2	
A.03.01.20.c.02	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after retaining approved system connection or processing agreements with the organizational entity hosting the external systems.	Functional	Intersects With	Use of External Technology Assets, Applications and/or Services (TAAS)	DCH-13	Mechanisms exist to govern how external parties, including Technology Assets, Applications and/or Services (TAAS), are used to securely store, process and transmit data.	5		
A.03.01.20.c.02	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after retaining approved system connection or processing agreements with the organizational entity hosting the external systems.	Functional	Intersects With	Limits of Authorized Use	DCH-13.1	Mechanisms exist to prohibit external parties, including Technology Assets, Applications and/or Services (TAAS), from storing, processing and transmitting data unless authorized individuals first: (1) Verifying the implementation of required security, compliance and/or resilience controls; or (2) Retaining a processing agreement with the entity hosting the external TAAS.	5	Updated in 2026.2	
A.03.01.20.c.02	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after retaining approved system connection or processing agreements with the organizational entity hosting the external systems.	Functional	Intersects With	Transfer Authorizations	DCH-14.2	Mechanisms exist to verify that individuals or Technology Assets, Applications and/or Services (TAAS) transferring data between interconnecting TAAS have the requisite authorizations (e.g., write permissions or privileges) prior to transferring said data.	5	Updated in 2026.2	
A.03.01.20.c.02	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after retaining approved system connection or processing agreements with the organizational entity hosting the external systems.	Functional	Intersects With	Data Access Mapping	DCH-14.3	Mechanisms exist to leverage data-specific Access Control Lists (ACL) or Interconnection Security Agreements (ISAs) to generate a logical map of the parties with whom sensitive and/or regulated data is shared.	5	Updated in 2026.2	
A.03.01.20.c.02	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after retaining approved system connection or processing agreements with the organizational entity hosting the external systems.	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	5	Updated in 2026.2	
A.03.01.20.c.02	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after retaining approved system connection or processing agreements with the organizational entity hosting the external systems.	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each interconnection: (1) Interface characteristics; (2) Security, compliance and resilience requirements; and; (3) The nature of the information communicated.	5	Updated in 2026.2	
A.03.01.20.c.02	Use of External Systems	authorized individuals are permitted to use external systems to access the organizational system or to process, store, or transmit CUI only after retaining approved system connection or processing agreements with the organizational entity hosting the external systems.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Updated in 2026.2	
A.03.01.20.d	Use of External Systems	the use of organization-controlled portable storage devices by authorized individuals on external systems is restricted.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	
A.03.01.20.d	Use of External Systems	the use of organization-controlled portable storage devices by authorized individuals on external systems is restricted.	Functional	Intersects With	Use of External Technology Assets, Applications and/or Services (TAAS)	DCH-13	Mechanisms exist to govern how external parties, including Technology Assets, Applications and/or Services (TAAS), are used to securely store, process and transmit data.	5	Updated in 2026.2	
A.03.01.20.d	Use of External Systems	the use of organization-controlled portable storage devices by authorized individuals on external systems is restricted.	Functional	Intersects With	Limits of Authorized Use	DCH-13.1	Mechanisms exist to prohibit external parties, including Technology Assets, Applications and/or Services (TAAS), from storing, processing and transmitting data unless authorized individuals first: (1) Verifying the implementation of required security, compliance and/or resilience controls; or (2) Retaining a processing agreement with the entity hosting the external TAAS.	5	Updated in 2026.2	
A.03.01.20.d	Use of External Systems	the use of organization-controlled portable storage devices by authorized individuals on external systems is restricted.	Functional	Intersects With	Portable Storage Devices	DCH-13.2	Mechanisms exist to restrict or prohibit the use of portable storage devices by users on external systems.	5		
A.03.01.20.d	Use of External Systems	the use of organization-controlled portable storage devices by authorized individuals on external systems is restricted.	Functional	Intersects With	Non-Organizationally Owned Technology Assets, Applications and/or Services (TAAS)	DCH-13.4	Mechanisms exist to restrict the use of non-organizationally owned Technology Assets, Applications and/or Services (TAAS) to process, store or transmit organizational information.	5	Updated in 2026.2	
A.03.01.20.d	Use of External Systems	the use of organization-controlled portable storage devices by authorized individuals on external systems is restricted.	Functional	Intersects With	Centralized Management Of Mobile Devices	MDM-01	Mechanisms exist to implement and govern Mobile Device Management (MDM) controls.	5	Updated in 2026.2	
A.03.01.20.d	Use of External Systems	the use of organization-controlled portable storage devices by authorized individuals on external systems is restricted.	Functional	Intersects With	Organization-Owned Mobile Devices	MDM-07	Mechanisms exist to prohibit the installation of non-approved applications or approved applications not obtained through the organization-approved application store.	5	Updated in 2026.2	
03.01.21	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
03.01.22	Publicly Accessible Content	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	Disclosure of Information	DCH-03.1	Mechanisms exist to restrict the disclosure of sensitive and/or regulated data to authorized parties with a need to know.	5	Updated in 2026.2	
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	Publicly Accessible Content	DCH-15	Mechanisms exist to control publicly-accessible content.	5		
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Updated in 2026.2	
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	User Awareness	HRS-03.1	Mechanisms exist to communicate with users about their roles and responsibilities to maintain a safe and secure working environment.	5	Updated in 2026.2	
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	Roles With Special Protection Measures	HRS-04.1	Mechanisms exist to ensure that individuals accessing a system that stores, transmits or processes information requiring special protection satisfy organization-defined personnel screening criteria.	5	Updated in 2026.2	
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	Formal Indoctrination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	5	Updated in 2026.2	
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Updated in 2026.2	
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	5	Updated in 2026.2	
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Updated in 2026.2	
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5	Updated in 2026.2	
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	Sensitive / Regulated Data Storage, Handling & Processing	SAT-03.3	Mechanisms exist to ensure that every user accessing a system processing, storing or transmitting sensitive and/or regulated data is formally trained in data handling requirements.	5	Updated in 2026.2	
A.03.01.22.a	Publicly Accessible Content	authorized individuals are trained to ensure that publicly accessible information does not contain CUI.	Functional	Intersects With	Web Security	WEB-01	Mechanisms exist to facilitate the implementation of an enterprise-wide web management policy, as well as associated standards, controls and procedures.	5	Updated in 2026.2	
A.03.01.22.b[01]	Publicly Accessible Content	the content on publicly accessible systems is reviewed for CUI.	Functional	Intersects With	Publicly Accessible Content	DCH-15	Mechanisms exist to control publicly-accessible content.	5		
A.03.01.22.b[01]	Publicly Accessible Content	the content on publicly accessible systems is reviewed for CUI.	Functional	Intersects With	Monitoring For Information Disclosure	MON-11	Mechanisms exist to monitor for evidence of unauthorized exfiltration or disclosure of non-public information.	5		
A.03.01.22.b[02]	Publicly Accessible Content	CUI is removed from publicly accessible systems, if discovered.	Functional	Intersects With	Sensitive / Regulated Data Spill Response	IRO-12	Mechanisms exist to respond to sensitive and/or regulated data spills.	5		
A.03.01.22.b[02]	Publicly Accessible Content	CUI is removed from publicly accessible systems, if discovered.	Functional	Intersects With	Publicly Accessible Content Reviews	WEB-14	Mechanisms exist to routinely review the content on publicly accessible systems for sensitive and/or regulated data and remove such information, if discovered.	5	Updated in 2026.2	
03.02.01	Literacy Training and Awareness	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.02.01.ODP[01]	Literacy Training and Awareness	the frequency at which to provide security literacy training to system users after initial training is defined.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10		
A.03.02.01.ODP[02]	Literacy Training and Awareness	events that require security literacy training for system users are defined.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10		
A.03.02.01.ODP[03]	Literacy Training and Awareness	the frequency at which to update security literacy training content is defined.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5		
A.03.02.01.ODP[04]	Literacy Training and Awareness	events that require security literacy training content updates are defined.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5		
A.03.02.01.a.01[01]	Literacy Training and Awareness	security literacy training is provided to system users as part of initial training for new users.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10		
A.03.02.01.a.01[01]	Literacy Training and Awareness	security literacy training is provided to system users as part of initial training for new users.	Functional	Subset Of	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	10	Updated in 2026.2	
A.03.02.01.a.01[01]	Literacy Training and Awareness	security literacy training is provided to system users as part of initial training for new users.	Functional	Subset Of	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	10	Updated in 2026.2	
A.03.02.01.a.01[01]	Literacy Training and Awareness	security literacy training is provided to system users as part of initial training for new users.	Functional	Subset Of	Sensitive / Regulated Data Storage, Handling & Processing	SAT-03.3	Mechanisms exist to ensure that every user accessing a system processing, storing or transmitting sensitive and/or regulated data is formally trained in data handling requirements.	10	Updated in 2026.2	
A.03.02.01.a.01[01]	Literacy Training and Awareness	security literacy training is provided to system users as part of initial training for new users.	Functional	Subset Of	Privileged Users	SAT-03.5	Mechanisms exist to provide specific training for privileged users to ensure privileged users understand their unique roles and responsibilities.	10	Updated in 2026.2	
A.03.02.01.a.01[01]	Literacy Training and Awareness	security literacy training is provided to system users as part of initial training for new users.	Functional	Subset Of	Cyber Threat Environment	SAT-03.6	Mechanisms exist to provide role-based security, compliance and resilience awareness training that is current and relevant to the cyber threats that users might encounter in day-to-day business operations.	10	Updated in 2026.2	
A.03.02.01.a.01[02]	Literacy Training and Awareness	security literacy training is provided to system users <A.03.02.01.ODP[01]: frequency> after initial training.	Functional	Subset Of	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	10	Updated in 2026.2	US DoD ODP Value: at least every 12 months
A.03.02.01.a.02	Literacy Training and Awareness	security literacy training is provided to system users when required by system changes or following <A.03.02.01.ODP[02]: events>.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	8	Updated in 2026.2	US DoD ODP Value: significant, novel incidents, or significant changes to risks
A.03.02.01.a.02	Literacy Training and Awareness	security literacy training is provided to system users when required by system changes or following <A.03.02.01.ODP[02]: events>.	Functional	Intersects With	Cyber Threat Environment	SAT-03.6	Mechanisms exist to provide role-based security, compliance and resilience awareness training that is current and relevant to the cyber threats that users might encounter in day-to-day business operations.	8		US DoD ODP Value: significant, novel incidents, or significant changes to risks
A.03.02.01.a.02	Literacy Training and Awareness	security literacy training is provided to system users when required by system changes or following <A.03.02.01.ODP[02]: events>.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and	8	Updated in 2026.2	US DoD ODP Value: significant, novel incidents, or significant changes to risks
A.03.02.01.a.03[01]	Literacy Training and Awareness	security literacy training is provided to system users on recognizing indicators of insider threat.	Functional	Intersects With	Insider Threat Awareness	THR-05	Mechanisms exist to utilize security awareness training on recognizing and reporting potential indicators of insider threat.	5		
A.03.02.01.a.03[02]	Literacy Training and Awareness	security literacy training is provided to system users on reporting indicators of insider threat.	Functional	Intersects With	Insider Threat Awareness	THR-05	Mechanisms exist to utilize security awareness training on recognizing and reporting potential indicators of insider threat.	5		
A.03.02.01.a.03[03]	Literacy Training and Awareness	security literacy training is provided to system users on recognizing indicators of social engineering.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.02.01.a.03[03]	Literacy Training and Awareness	security literacy training is provided to system users on recognizing indicators of social engineering.	Functional	Intersects With	Social Engineering & Mining	SAT-02.2	Mechanisms exist to include awareness training on recognizing and reporting potential and actual instances of social engineering and social mining.	5	Updated in 2026.2	
A.03.02.01.a.03[04]	Literacy Training and Awareness	security literacy training is provided to system users on reporting indicators of social engineering.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5		
A.03.02.01.a.03[05]	Literacy Training and Awareness	security literacy training is provided to system users on recognizing indicators of social mining.	Functional	Intersects With	Social Engineering & Mining	SAT-02.2	Mechanisms exist to include awareness training on recognizing and reporting potential and actual instances of social engineering and social mining.	5	Updated in 2026.2	
A.03.02.01.a.03[06]	Literacy Training and Awareness	security literacy training is provided to system users on reporting indicators of social mining.	Functional	Intersects With	Social Engineering & Mining	SAT-02.2	Mechanisms exist to include awareness training on recognizing and reporting potential and actual instances of social engineering and social mining.	5	Updated in 2026.2	
A.03.02.01.b[01]	Literacy Training and Awareness	security literacy training content is updated <A.03.02.01.ODP[03]: frequency>.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to:	8		US DoD ODP Value: at least every 12 months Updated in 2026.2
A.03.02.01.b[02]	Literacy Training and Awareness	security literacy training content is updated following <A.03.02.01.ODP[04]: events>.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and (4) Technological developments.	8	Updated in 2026.2	US DoD ODP Value: significant, novel incidents, or significant changes to risks
A.03.02.01.b[02]	Literacy Training and Awareness	security literacy training content is updated following <A.03.02.01.ODP[04]: events>.	Functional	Intersects With	Cyber Threat Environment	SAT-03.6	Mechanisms exist to provide role-based security, compliance and resilience awareness training that is current and relevant to the cyber threats that users might encounter in day-to-day business operations.	8	Updated in 2026.2	US DoD ODP Value: significant, novel incidents, or significant changes to risks
A.03.02.01.b[02]	Literacy Training and Awareness	security literacy training content is updated following <A.03.02.01.ODP[04]: events>.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and	8	Updated in 2026.2	US DoD ODP Value: significant, novel incidents, or significant changes to risks
03.02.02	Role-Based Training	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.02.02.ODP[01]	Role-Based Training	the frequency at which to provide role-based security training to assigned personnel after initial training is defined.	Functional	Intersects With	Role-Based Security, Compliance &	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training:	5		
A.03.02.02.ODP[02]	Role-Based Training	events that require role-based security training are defined.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5		
A.03.02.02.ODP[03]	Role-Based Training	the frequency at which to update role-based security training content is defined.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5		
A.03.02.02.ODP[04]	Role-Based Training	events that require role-based security training content updates are defined.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5		
A.03.02.02.a.01[01]	Role-Based Training	role-based security training is provided to organizational personnel before authorizing access to the system or CUI.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Updated in 2026.2	
A.03.02.02.a.01[01]	Role-Based Training	role-based security training is provided to organizational personnel before authorizing access to the system or CUI.	Functional	Intersects With	Roles With Special Protection Measures	HRS-04.1	Mechanisms exist to ensure that individuals accessing a system that stores, transmits or processes information	5	Updated in 2026.2	
A.03.02.02.a.01[01]	Role-Based Training	role-based security training is provided to organizational personnel before authorizing access to the system or CUI.	Functional	Intersects With	Formal Indoctrination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	5	Updated in 2026.2	
A.03.02.02.a.01[01]	Role-Based Training	role-based security training is provided to organizational personnel before authorizing access to the system or CUI.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties;	5	Updated in 2026.2	
A.03.02.02.a.01[01]	Role-Based Training	role-based security training is provided to organizational personnel before authorizing access to the system or CUI.	Functional	Intersects With	Sensitive / Regulated Data Storage, Handling & Processing	SAT-03.3	Mechanisms exist to ensure that every user accessing a system processing, storing or transmitting sensitive and/or regulated data is formally trained in data handling requirements.	5	Updated in 2026.2	
A.03.02.02.a.01[01]	Role-Based Training	role-based security training is provided to organizational personnel before authorizing access to the system or CUI.	Functional	Intersects With	Privileged Users	SAT-03.5	Mechanisms exist to provide specific training for privileged users to ensure privileged users understand their unique roles and responsibilities	5	Updated in 2026.2	
A.03.02.02.a.01[01]	Role-Based Training	role-based security training is provided to organizational personnel before authorizing access to the system or CUI.	Functional	Intersects With	Cyber Threat Environment	SAT-03.6	Mechanisms exist to provide role-based security, compliance and resilience awareness training that is current and relevant to the cyber threats that users might encounter in day-to-day	5	Updated in 2026.2	
A.03.02.02.a.01[02]	Role-Based Training	role-based security training is provided to organizational personnel before performing assigned duties.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties;	5		
A.03.02.02.a.01[03]	Role-Based Training	role-based security training is provided to organizational personnel <A.03.02.02.ODP[01]: frequency> after initial training.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	8		US DoD ODP Value: at least every 12 months
A.03.02.02.a.02	Role-Based Training	role-based security training is provided to organizational personnel when required by system changes or following <A.03.02.02.ODP[02]: events>.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	8		US DoD ODP Value: significant, novel incidents, or significant changes to risks
A.03.02.02.a.02	Role-Based Training	role-based security training is provided to organizational personnel when required by system changes or following <A.03.02.02.ODP[02]: events>.	Functional	Intersects With	Cyber Threat Environment	SAT-03.6	Mechanisms exist to provide role-based security, compliance and resilience awareness training that is current and relevant to the cyber threats that users might encounter in day-to-day business operations.	8		US DoD ODP Value: significant, novel incidents, or significant changes to risks
A.03.02.02.b[01]	Role-Based Training	role-based security training content is updated <A.03.02.02.ODP[03]: frequency>.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures;	8		US DoD ODP Value: at least every 12 months
A.03.02.02.b[02]	Role-Based Training	role-based security training content is updated following <A.03.02.02.ODP[04]: events>.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and (4) Technological developments.	8		US DoD ODP Value: significant, novel incidents, or significant changes to risks

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
03.02.03	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.03.01	Event Logging	Determine if:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.03.01.ODP[01]	Event Logging	event types selected for logging within the system are defined.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that	5		
A.03.03.01.ODP[02]	Event Logging	the frequency of event types selected for logging are reviewed and updated.	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5		
A.03.03.01.a	Event Logging	the following event types are specified for logging within the system: <A.03.03.01.ODP[01]: event types>.	Functional	Intersects With	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	8	Updated in 2026.2	US DoD ODP Values: at a minimum and where applicable:
A.03.03.01.a	Event Logging	the following event types are specified for logging within the system: <A.03.03.01.ODP[01]: event types>.	Functional	Intersects With	System Generated Alerts	MON-01.4	Mechanisms exist to generate, monitor, correlate and respond to alerts from physical, cybersecurity, data protection and supply chain activities to achieve integrated situational awareness.	8	Updated in 2026.2	US DoD ODP Values: at a minimum and where applicable: (1) Authentication events: (a) Logons (Success/Failure) (b) Logoffs (Success) (2) Security Relevant File and Objects events: (a) Create (Success/Failure) (b) Access (Success/Failure) (c) Delete (Success/Failure) (d) Modify (Success/Failure) (e) Permission Modification (Success/Failure) (f) Ownership Modification (Success/Failure) (3) Export/Writes/downloads to devices/digital media (e.g., CD/DVD, USB, SD) (Success/Failure) (4) Import/Uploads from devices/digital media (e.g., CD/DVD, USB, SD) (Success/Failure) (5) User and Group Management events: (a) User add, delete, modify, disable, lock (Success/Failure) (b) Group/Role add, delete, modify, disable, lock (Success/Failure)
A.03.03.01.a	Event Logging	the following event types are specified for logging within the system: <A.03.03.01.ODP[01]: event types>.	Functional	Intersects With	System-Wide / Time-Correlated Audit Trail	MON-02.7	Automated mechanisms exist to compile audit records into an organization-wide audit trail that is time-correlated.	8	Updated in 2026.2	US DoD ODP Values: at a minimum and where applicable: (1) Authentication events: (a) Logons (Success/Failure) (b) Logoffs (Success) (2) Security Relevant File and Objects events: (a) Create (Success/Failure) (b) Access (Success/Failure) (c) Delete (Success/Failure) (d) Modify (Success/Failure) (e) Permission Modification (Success/Failure) (f) Ownership Modification (Success/Failure) (3) Export/Writes/downloads to devices/digital media (e.g., CD/DVD, USB, SD) (Success/Failure) (4) Import/Uploads from devices/digital media (e.g., CD/DVD, USB, SD) (Success/Failure) (5) User and Group Management events: (a) User add, delete, modify, disable, lock (Success/Failure) (b) Group/Role add, delete, modify, disable, lock (Success/Failure)
A.03.03.01.a	Event Logging	the following event types are specified for logging within the system: <A.03.03.01.ODP[01]: event types>.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	8		US DoD ODP Values: at a minimum and where applicable: (1) Authentication events: (a) Logons (Success/Failure) (b) Logoffs (Success) (2) Security Relevant File and Objects events: (a) Create (Success/Failure) (b) Access (Success/Failure) (c) Delete (Success/Failure) (d) Modify (Success/Failure) (e) Permission Modification (Success/Failure) (f) Ownership Modification (Success/Failure) (3) Export/Writes/downloads to devices/digital media (e.g., CD/DVD, USB, SD) (Success/Failure) (4) Import/Uploads from devices/digital media (e.g., CD/DVD, USB, SD) (Success/Failure) (5) User and Group Management events: (a) User add, delete, modify, disable, lock (Success/Failure) (b) Group/Role add, delete, modify, disable, lock (Success/Failure)

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.03.01.a	Event Logging	the following event types are specified for logging within the system: <A.03.03.01.ODP[01]: event types>.	Functional	Intersects With	Audit Trails	MON-03.2	Mechanisms exist to link system access to individual users or service accounts.	8	Updated in 2026.2	US DoD ODP Values: at a minimum and where applicable: (1) Authentication events: (a) Logons (Success/Failure) (b) Logoffs (Success) (2) Security Relevant File and Objects events: (a) Create (Success/Failure) (b) Access (Success/Failure) (c) Delete (Success/Failure) (d) Modify (Success/Failure) (e) Permission Modification (Success/Failure) (f) Ownership Modification (Success/Failure) (3) Export/Writes/downloads to devices/digital media (e.g., CD/DVD, USB, SD) (Success/Failure) (4) Import/Uploads from devices/digital media (e.g., CD/DVD, USB, SD) (Success/Failure) (5) User and Group Management events: (a) User add, delete, modify, disable, lock (Success/Failure) (b) Group/Role add, delete, modify (Success/Failure)
A.03.03.01.b[01]	Event Logging	the event types selected for logging are reviewed <A.03.03.01.ODP[02]: frequency>.	Functional	Intersects With	Audit Level Adjustments	MON-02.6	Mechanisms exist to adjust the level of audit review, analysis and reporting based on evolving threat information from law enforcement, industry associations or other credible sources of threat intelligence.	8		US DoD ODP Value: at least every 12 months and after any significant incidents or significant changes to risks Updated in 2026.2
A.03.03.01.b[01]	Event Logging	the event types selected for logging are reviewed <A.03.03.01.ODP[02]: frequency>.	Functional	Intersects With	Centralized Management of Event Log Content	MON-03.6	Mechanisms exist to centrally manage and update the criteria to be captured in event logs generated by organization-defined system components.	8		US DoD ODP Value: at least every 12 months and after any significant incidents or significant changes to risks
A.03.03.01.b[02]	Event Logging	the event types selected for logging are updated <A.03.03.01.ODP[02]: frequency>.	Functional	Intersects With	Centralized Management of Event Log Content	MON-03.6	Mechanisms exist to centrally manage and update the criteria to be captured in event logs generated by organization-defined system components.	8		US DoD ODP Value: at least every 12 months and after any significant incidents or significant changes to risks
03.03.02	Audit Record Content	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.03.02.a.01	Audit Record Content	audit records contain information that establishes what type of event occurred.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that	5	Updated in 2026.2	
A.03.03.02.a.02	Audit Record Content	audit records contain information that establishes when the event occurred.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5		
A.03.03.02.a.02	Audit Record Content	audit records contain information that establishes when the event occurred.	Functional	Intersects With	Time Stamps	MON-07	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to use an authoritative time source to generate time stamps for event logs.	5	Updated in 2026.2	
A.03.03.02.a.03	Audit Record Content	audit records contain information that establishes where the event occurred.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum:	5		
A.03.03.02.a.04	Audit Record Content	audit records contain information that establishes the source of the event.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5		
A.03.03.02.a.05	Audit Record Content	audit records contain information that establishes the outcome of the event.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.03.02.a.06	Audit Record Content	audit records contain information that establishes the identity of the individuals, subjects, objects, or entities associated with the event.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5		
A.03.03.02.b	Audit Record Content	additional information for audit records is provided, as needed.	Functional	Intersects With	Baseline Tailoring	CFG-02.9	Mechanisms exist to allow baseline controls to be specialized or customized by applying a defined set of tailoring actions that are specific to: (1) Mission / business functions; (2) Operational environment; (3) Specific threats or vulnerabilities; or (4) Other conditions or situations that could affect mission / business success.	5		
A.03.03.02.b	Audit Record Content	additional information for audit records is provided, as needed.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5		
03.03.03	Audit Record Generation	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.03.03.a	Audit Record Generation	audit records for the selected event types and audit record content specified in 03.03.01 and 03.03.02 are generated.	Functional	Intersects With	System Generated Alerts	MON-01.4	Mechanisms exist to generate, monitor, correlate and respond to alerts from physical, cybersecurity, data protection and	5		
A.03.03.03.b	Audit Record Generation	audit records are retained for a time period consistent with the records retention policy.	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5		
A.03.03.03.b	Audit Record Generation	audit records are retained for a time period consistent with the records retention policy.	Functional	Intersects With	Event Log Retention	MON-10	Mechanisms exist to retain event logs for a time period consistent with records retention requirements to provide	5		
03.03.04	Response to Audit Logging Process Failures	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.03.04.ODP[01]	Response to Audit Logging Process Failures	the time period for organizational personnel or roles receiving audit logging process failure alerts is defined.	Functional	Intersects With	Response To Event Log Processing Failures	MON-05	Mechanisms exist to alert appropriate personnel in the event of a log processing failure and take actions to remedy the disruption.	5		
A.03.03.04.ODP[02]	Response to Audit Logging Process Failures	additional actions to be taken in the event of an audit logging process failure are defined.	Functional	Intersects With	Response To Event Log Processing Failures	MON-05	Mechanisms exist to alert appropriate personnel in the event of a log processing failure and take actions to remedy the disruption.	5		
A.03.03.04.a	Response to Audit Logging Process Failures	organizational personnel or roles are alerted in the event of an audit logging process failure within <A.03.03.04.ODP[01]: time period>.	Functional	Intersects With	Response To Event Log Processing Failures	MON-05	Mechanisms exist to alert appropriate personnel in the event of a log processing failure and take actions to remedy the disruption.	8		US DoD ODP Value: near real time or as soon as practicable upon discovery
A.03.03.04.b	Response to Audit Logging Process Failures	the following additional actions are taken: <A.03.03.04.ODP[02]: additional actions>.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report	8	Updated in 2026.2	US DoD ODP Value: document the failure and resolution, troubleshoot,
A.03.03.04.b	Response to Audit Logging Process Failures	the following additional actions are taken: <A.03.03.04.ODP[02]: additional actions>.	Functional	Intersects With	Response To Event Log Processing Failures	MON-05	Mechanisms exist to alert appropriate personnel in the event of a log processing failure and take actions to remedy the disruption.	8		US DoD ODP Value: document the failure and resolution, troubleshoot, repair/restart the audit logging process, and report as incident if applicable
03.03.05	Audit Record Review, Analysis, and Reporting	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.03.05.ODP[01]	Audit Record Review, Analysis, and Reporting	the frequency at which system audit records are reviewed and analyzed is defined.	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established	5		
A.03.03.05.ODP[01]	Audit Record Review, Analysis, and Reporting	the frequency at which system audit records are reviewed and analyzed is defined.	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	5		
A.03.03.05.a	Audit Record Review, Analysis, and Reporting	system audit records are reviewed and analyzed <A.03.03.05.ODP[01]: frequency> for indications and the potential impact of inappropriate or unusual activity.	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	8		US DoD ODP Value: at least weekly
A.03.03.05.a	Audit Record Review, Analysis, and Reporting	system audit records are reviewed and analyzed <A.03.03.05.ODP[01]: frequency> for indications and the potential impact of inappropriate or unusual activity.	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	8		US DoD ODP Value: at least weekly
A.03.03.05.a	Audit Record Review, Analysis, and Reporting	system audit records are reviewed and analyzed <A.03.03.05.ODP[01]: frequency> for indications and the potential impact of inappropriate or unusual activity.	Functional	Intersects With	Correlate Monitoring Information	MON-02.1	Automated mechanisms exist to correlate both technical and non-technical information from across the enterprise by a Security Incident Event Manager (SIEM) or similar automated	8	Updated in 2026.2	US DoD ODP Value: at least weekly
A.03.03.05.a	Audit Record Review, Analysis, and Reporting	system audit records are reviewed and analyzed <A.03.03.05.ODP[01]: frequency> for indications and the potential impact of inappropriate or unusual activity.	Functional	Intersects With	Central Review & Analysis	MON-02.2	Automated mechanisms exist to centrally collect, review and analyze audit records from multiple sources.	8	Updated in 2026.2	US DoD ODP Value: at least weekly
A.03.03.05.a	Audit Record Review, Analysis, and Reporting	system audit records are reviewed and analyzed <A.03.03.05.ODP[01]: frequency> for indications and the potential impact of inappropriate or unusual activity.	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate	8	Updated in 2026.2	US DoD ODP Value: at least weekly
A.03.03.05.b	Audit Record Review, Analysis, and Reporting	findings are reported to organizational personnel or roles.	Functional	Intersects With	Automated Alerts	MON-01.12	Mechanisms exist to automatically alert incident response personnel to inappropriate or anomalous activities that have potential security incident implications.	5		
A.03.03.05.b	Audit Record Review, Analysis, and Reporting	findings are reported to organizational personnel or roles.	Functional	Intersects With	Monitoring Reporting	MON-06	Mechanisms exist to provide an event log report generation capability to aid in detecting and assessing anomalous activities.	5		
A.03.03.05.c[01]	Audit Record Review, Analysis, and Reporting	audit records across different repositories are analyzed to gain organization-wide situational awareness.	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	5		
A.03.03.05.c[01]	Audit Record Review, Analysis, and Reporting	audit records across different repositories are analyzed to gain organization-wide situational awareness.	Functional	Intersects With	Central Review & Analysis	MON-02.2	Automated mechanisms exist to centrally collect, review and analyze audit records from multiple sources.	5	Updated in 2026.2	
A.03.03.05.c[02]	Audit Record Review, Analysis, and Reporting	audit records across different repositories are correlated to gain organization-wide situational awareness.	Functional	Intersects With	Correlate Monitoring Information	MON-02.1	Automated mechanisms exist to correlate both technical and non-technical information from across the enterprise by a	5		
A.03.03.05.c[02]	Audit Record Review, Analysis, and Reporting	audit records across different repositories are correlated to gain organization-wide situational awareness.	Functional	Intersects With	Integration of Scanning & Other Monitoring Information	MON-02.3	Automated mechanisms exist to integrate the analysis of audit records with analysis of vulnerability scanners, network performance, system monitoring and other sources to further enhance the ability to identify inappropriate or unusual activity.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/

Focal Document: NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information

Focal Document URL: https://csrc.nist.gov/pubs/sp/800/171/a/r3/final

Published STRM URL: https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
03.03.06	Audit Record Reduction and Report Generation	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.03.06.a[01]	Audit Record Reduction and Report Generation	an audit record reduction and report generation capability that supports audit record review is implemented.	Functional	Intersects With	Monitoring Reporting	MON-06	Mechanisms exist to provide an event log report generation capability to aid in detecting and assessing anomalous activities.	5		
A.03.03.06.a[02]	Audit Record Reduction and Report Generation	an audit record reduction and report generation capability that supports audit record analysis is implemented.	Functional	Intersects With	Monitoring Reporting	MON-06	Mechanisms exist to provide an event log report generation capability to aid in detecting and assessing anomalous activities.	5		
A.03.03.06.a[03]	Audit Record Reduction and Report Generation	an audit record reduction and report generation capability that supports audit record reporting requirements is implemented.	Functional	Intersects With	Monitoring Reporting	MON-06	Mechanisms exist to provide an event log report generation capability to aid in detecting and assessing anomalous activities.	5		
A.03.03.06.a[04]	Audit Record Reduction and Report Generation	an audit record reduction and report generation capability that supports after-the-fact investigations of incidents is implemented.	Functional	Intersects With	Monitoring Reporting	MON-06	Mechanisms exist to provide an event log report generation capability to aid in detecting and assessing anomalous activities.	5		
A.03.03.06.b[01]	Audit Record Reduction and Report Generation	the original content of audit records is preserved.	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5		
A.03.03.06.b[02]	Audit Record Reduction and Report Generation	the original time ordering of audit records is preserved.	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5		
03.03.07	Time Stamps	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.03.07.ODP[01]	Time Stamps	granularity of time measurement for audit record time stamps is defined.	Functional	Intersects With	Time Stamps	MON-07	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to use an authoritative time source to generate time stamps for event logs.	5		
A.03.03.07.a	Time Stamps	internal system clocks are used to generate time stamps for audit records.	Functional	Intersects With	Time Stamps	MON-07	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to use an authoritative time source to generate time stamps for event logs.	5		
A.03.03.07.b[01]	Time Stamps	time stamps are recorded for audit records that meet <A.03.03.07.ODP[01]: granularity of time measurement>.	Functional	Intersects With	Time Stamps	MON-07	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to use an authoritative time source to generate time stamps for event logs.	8		US DoD ODP Value: a granularity of one (1) second or smaller
A.03.03.07.b[02]	Time Stamps	time stamps are recorded for audit records that use Coordinated Universal Time (UTC), have a fixed local time offset from UTC, or include the local time offset as part of the	Functional	Intersects With	Synchronization With Authoritative Time Source	MON-07.1	Mechanisms exist to synchronize internal system clocks with an authoritative time source.	5		
03.03.08	Protection of Audit Information	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.03.08.a[01]	Protection of Audit Information	audit information is protected from unauthorized access, modification, and deletion.	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5		
A.03.03.08.a[01]	Protection of Audit Information	audit information is protected from unauthorized access, modification, and deletion.	Functional	Intersects With	Event Log Backup on Separate Physical	MON-08.1	Mechanisms exist to back up event logs onto a physically different system or system component than the Security	5	Updated in 2026.2	
A.03.03.08.a[01]	Protection of Audit Information	audit information is protected from unauthorized access, modification, and deletion.	Functional	Intersects With	Access by Subset of Privileged Users	MON-08.2	Mechanisms exist to restrict access to the management of event logs to privileged users with a specific business need.	5	Updated in 2026.2	
A.03.03.08.a[01]	Protection of Audit Information	audit information is protected from unauthorized access, modification, and deletion.	Functional	Intersects With	Cryptographic Protection of Event Log	MON-08.3	Cryptographic mechanisms exist to protect the integrity of event logs and audit tools.	5	Updated in 2026.2	
A.03.03.08.a[02]	Protection of Audit Information	audit logging tools are protected from unauthorized access, modification, and deletion.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry.	5		
A.03.03.08.a[02]	Protection of Audit Information	audit logging tools are protected from unauthorized access, modification, and deletion.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Updated in 2026.2	
A.03.03.08.b	Protection of Audit Information	access to management of audit logging functionality is authorized to only a subset of privileged users or roles.	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5		
A.03.03.08.b	Protection of Audit Information	access to management of audit logging functionality is authorized to only a subset of privileged users or roles.	Functional	Intersects With	Access by Subset of Privileged Users	MON-08.2	Mechanisms exist to restrict access to the management of event logs to privileged users with a specific business need.	5		
A.03.03.08.b	Protection of Audit Information	access to management of audit logging functionality is authorized to only a subset of privileged users or roles.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or	5	Updated in 2026.2	
A.03.03.08.b	Protection of Audit Information	access to management of audit logging functionality is authorized to only a subset of privileged users or roles.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Updated in 2026.2	
03.03.09	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.04.01	Baseline Configuration	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.04.01.ODP[01]	Baseline Configuration	the frequency of baseline configuration review and update is defined.	Functional	Intersects With	Reviews & Updates	CFG-02.1	Mechanisms exist to review and update baseline configurations.	5		
A.03.04.01.a[01]	Baseline Configuration	a current baseline configuration of the system is developed.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5		
A.03.04.01.a[01]	Baseline Configuration	a current baseline configuration of the system is developed.	Functional	Intersects With	Configure Technology Assets, Applications and/or Services (TAAS) for High-Risk Areas	CFG-02.5	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) utilized in high-risk areas with more restrictive baseline configurations.	5	Updated in 2026.2	
A.03.04.01.a[01]	Baseline Configuration	a current baseline configuration of the system is developed.	Functional	Intersects With	Approved Configuration Deviations	CFG-02.7	Mechanisms exist to document, assess risk and approve or deny deviations to standardized configurations.	5	Updated in 2026.2	
A.03.04.01.a[01]	Baseline Configuration	a current baseline configuration of the system is developed.	Functional	Intersects With	Baseline Tailoring	CFG-02.9	Mechanisms exist to allow baseline controls to be specialized or customized by applying a defined set of tailoring actions that are specific to;	5	Updated in 2026.2	
A.03.04.01.a[02]	Baseline Configuration	a current baseline configuration of the system is maintained under configuration control.	Functional	Intersects With	Configuration Management Program	CFG-01	Mechanisms exist to facilitate the implementation of configuration management controls.	5	Updated in 2026.2	
A.03.04.01.a[02]	Baseline Configuration	a current baseline configuration of the system is maintained under configuration control.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications	5		
A.03.04.01.b[01]	Baseline Configuration	the baseline configuration of the system is reviewed <A.03.04.01.ODP[01]: frequency>.	Functional	Intersects With	Reviews & Updates	CFG-02.1	Mechanisms exist to review and update baseline configurations: (1) At least annually; (2) When required due to so; or	8		US DoD ODP Value: at least every 12 months and after any significant incidents or significant changes occur
A.03.04.01.b[02]	Baseline Configuration	the baseline configuration of the system is updated <A.03.04.01.ODP[01]: frequency>.	Functional	Intersects With	Reviews & Updates	CFG-02.1	Mechanisms exist to review and update baseline configurations: (1) At least annually; (2) When required due to so; or (3) As part of system component installations and upgrades.	8		US DoD ODP Value: at least every 12 months and after any significant incidents or significant changes occur
A.03.04.01.b[03]	Baseline Configuration	the baseline configuration of the system is reviewed when system components are installed or modified.	Functional	Intersects With	Reviews & Updates	CFG-02.1	Mechanisms exist to review and update baseline configurations: (1) At least annually; (2) When required due to so; or (3) As part of system component installations and upgrades.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.04.01.b[04]	Baseline Configuration	the baseline configuration of the system is updated when system components are installed or modified.	Functional	Intersects With	Reviews & Updates	CFG-02.1	Mechanisms exist to review and update baseline configurations: (1) At least annually; (2) When required due to sc; or (3) As part of system component installations and upgrades.	5		
03.04.02	Configuration Settings	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.04.02.ODP[01]	Configuration Settings	configuration settings for the system that reflect the most restrictive mode consistent with operational requirements are the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements are established and documented:	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting	5		
A.03.04.02.a[01]	Configuration Settings	the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements are established and documented:	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry:	8		US DoD ODP Value: Apply the appropriate use of common security configurations
A.03.04.02.a[01]	Configuration Settings	the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements are established and documented: <A.03.04.02.ODP[01]: configuration settings>.	Functional	Intersects With	Configure Technology Assets, Applications and/or Services (TAAS) for High-Risk Areas	CFG-02.5	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) utilized in high-risk areas with more restrictive baseline configurations.	8	Updated in 2026.2	US DoD ODP Value: Apply the appropriate use of common security configurations available from the National Institute of Standards and Technology's National Checklist Program (NCP) website (https://ncp.nist.gov/repository/) and prevent remote devices from simultaneously establishing nonremote connections with organizational systems and communicating via some other unauthorized connection to resources in external networks. Document any deviations from the published standard or source document.
A.03.04.02.a[01]	Configuration Settings	the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements are established and documented: <A.03.04.02.ODP[01]: configuration settings>.	Functional	Intersects With	Baseline Tailoring	CFG-02.9	Mechanisms exist to allow baseline controls to be specialized or customized by applying a defined set of tailoring actions that are specific to: (1) Mission / business functions; (2) Operational environment; (3) Specific threats or vulnerabilities; or (4) Other conditions or situations that could affect mission / business success.	8	Updated in 2026.2	US DoD ODP Value: Apply the appropriate use of common security configurations available from the National Institute of Standards and Technology's National Checklist Program (NCP) website (https://ncp.nist.gov/repository/) and prevent remote devices from simultaneously establishing nonremote connections with organizational systems and communicating via some other unauthorized connection to resources in external networks. Document any deviations from the published standard or source document.
A.03.04.02.a[01]	Configuration Settings	the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements are established and documented: <A.03.04.02.ODP[01]: configuration settings>.	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	8	Updated in 2026.2	US DoD ODP Value: Apply the appropriate use of common security configurations available from the National Institute of Standards and Technology's National Checklist Program (NCP) website (https://ncp.nist.gov/repository/) and prevent remote devices from simultaneously establishing nonremote connections with organizational systems and communicating via some other unauthorized connection to resources in external networks. Document any deviations from the published standard or source document.
A.03.04.02.a[01]	Configuration Settings	the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements are established and documented: <A.03.04.02.ODP[01]: configuration settings>.	Functional	Intersects With	Configuration Enforcement	CFG-06	Automated mechanisms exist to monitor, enforce and report on configurations for endpoint devices.	8	Updated in 2026.2	US DoD ODP Value: Apply the appropriate use of common security configurations available from the National Institute of Standards and Technology's National Checklist Program (NCP) website (https://ncp.nist.gov/repository/) and prevent remote devices from simultaneously establishing nonremote connections with organizational systems and communicating via some other unauthorized connection to resources in external networks. Document any deviations from the published standard or source document.

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.04.02.a[02]	Configuration Settings	the following configuration settings for the system are implemented: <A.03.04.02.ODP[01]: configuration settings>.	Functional	Intersects With	Approved Baseline Deviations	AST-02.4	Mechanisms exist to document and govern instances of approved deviations from established baseline configurations.	8	Updated in 2026.2	US DoD ODP Value: Apply the appropriate use of common security configurations available from the National Institute of Standards and Technology's National Checklist Program (NCP) website (https://ncp.nist.gov/repository/) and prevent remote devices from simultaneously establishing nonremote connections with organizational systems and communicating via some other unauthorized connection to resources in external networks. Document any deviations from the published standard or source document.
A.03.04.02.a[02]	Configuration Settings	the following configuration settings for the system are implemented: <A.03.04.02.ODP[01]: configuration settings>.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	8		US DoD ODP Value: Apply the appropriate use of common security configurations available from the National Institute of Standards and Technology's National Checklist Program (NCP) website (https://ncp.nist.gov/repository/) and prevent remote devices from simultaneously establishing nonremote connections with organizational systems and communicating via some other unauthorized connection to resources in external networks. Document any deviations from the published standard or source document.
A.03.04.02.b[01]	Configuration Settings	any deviations from established configuration settings are identified and documented.	Functional	Intersects With	Automated Central Management & Verification	CFG-02.2	Automated mechanisms exist to govern and report on baseline configurations of Technology Assets, Applications and/or Services (TAAS) through Continuous Diagnostics and Mitigation (CDM), or similar technologies.	5	Updated in 2026.2	
A.03.04.02.b[01]	Configuration Settings	any deviations from established configuration settings are identified and documented.	Functional	Intersects With	Baseline Tailoring	CFG-02.9	Mechanisms exist to allow baseline controls to be specialized or customized by applying a defined set of tailoring actions that are specific to: (1) Mission / business functions;	5	Updated in 2026.2	
A.03.04.02.b[01]	Configuration Settings	any deviations from established configuration settings are identified and documented.	Functional	Intersects With	Configuration Enforcement	CFG-06	Automated mechanisms exist to monitor, enforce and report on configurations for endpoint devices.	5	Updated in 2026.2	
A.03.04.02.b[01]	Configuration Settings	any deviations from established configuration settings are identified and documented.	Functional	Intersects With	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	5	Updated in 2026.2	
A.03.04.02.b[01]	Configuration Settings	any deviations from established configuration settings are identified and documented.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Updated in 2026.2	
A.03.04.02.b[01]	Configuration Settings	any deviations from established configuration settings are identified and documented.	Functional	Intersects With	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	5	Updated in 2026.2	
A.03.04.02.b[01]	Configuration Settings	any deviations from established configuration settings are identified and documented.	Functional	Intersects With	Access Restriction For Change	CHG-04	Mechanisms exist to enforce configuration restrictions in an effort to restrict the ability of users to conduct unauthorized	5	Updated in 2026.2	
A.03.04.02.b[01]	Configuration Settings	any deviations from established configuration settings are identified and documented.	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies	5	Updated in 2026.2	
A.03.04.02.b[02]	Configuration Settings	any deviations from established configuration settings are approved.	Functional	Intersects With	Approved Configuration Deviations	CFG-02.7	Mechanisms exist to document, assess risk and approve or deny deviations to standardized configurations.	5		
03.04.03	Configuration Change Control	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.04.03.a	Configuration Change Control	the types of changes to the system that are configuration-controlled are defined.	Functional	Subset Of	Configuration Management Program	CFG-01	Mechanisms exist to facilitate the implementation of configuration management controls.	10		
A.03.04.03.a	Configuration Change Control	the types of changes to the system that are configuration-controlled are defined.	Functional	Intersects With	Configuration Enforcement	CFG-06	Automated mechanisms exist to monitor, enforce and report on configurations for endpoint devices.	5	Updated in 2026.2	
A.03.04.03.a	Configuration Change Control	the types of changes to the system that are configuration-controlled are defined.	Functional	Intersects With	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	5	Updated in 2026.2	
A.03.04.03.a	Configuration Change Control	the types of changes to the system that are configuration-controlled are defined.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5		
A.03.04.03.a	Configuration Change Control	the types of changes to the system that are configuration-controlled are defined.	Functional	Intersects With	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	5	Updated in 2026.2	
A.03.04.03.b[01]	Configuration Change Control	proposed configuration-controlled changes to the system are reviewed with explicit consideration for security impacts.	Functional	Intersects With	Security Impact Analysis for Changes	CHG-03	Mechanisms exist to analyze proposed changes for potential security impacts, prior to the implementation of the change.	5		
A.03.04.03.b[02]	Configuration Change Control	proposed configuration-controlled changes to the system are approved or disapproved with explicit consideration for security impacts.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Updated in 2026.2	
A.03.04.03.b[02]	Configuration Change Control	proposed configuration-controlled changes to the system are approved or disapproved with explicit consideration for security impacts.	Functional	Intersects With	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	5		
A.03.04.03.b[02]	Configuration Change Control	proposed configuration-controlled changes to the system are approved or disapproved with explicit consideration for security impacts.	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.04.03.c[01]	Configuration Change Control	approved configuration-controlled changes to the system are implemented.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5		
A.03.04.03.c[01]	Configuration Change Control	approved configuration-controlled changes to the system are implemented.	Functional	Intersects With	Maintenance Operations	MNT-01	Mechanisms exist to develop, disseminate, review & update procedures to facilitate the implementation of maintenance	5	Updated in 2026.2	
A.03.04.03.c[01]	Configuration Change Control	approved configuration-controlled changes to the system are implemented.	Functional	Intersects With	Controlled Maintenance	MNT-02	Mechanisms exist to conduct controlled maintenance activities throughout the lifecycle of the Technology Asset, Application and/or Service (TAAS).	5		
A.03.04.03.c[02]	Configuration Change Control	approved configuration-controlled changes to the system are documented.	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	5		
A.03.04.03.d[01]	Configuration Change Control	activities associated with configuration-controlled changes to the system are monitored.	Functional	Intersects With	Automated Central Management & Verification	CFG-02.2	Automated mechanisms exist to govern and report on baseline configurations of Technology Assets, Applications and/or Services (TAAS) through Continuous Diagnostics and	5		
A.03.04.03.d[01]	Configuration Change Control	activities associated with configuration-controlled changes to the system are monitored.	Functional	Subset Of	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	10		
A.03.04.03.d[02]	Configuration Change Control	activities associated with configuration-controlled changes to the system are reviewed.	Functional	Intersects With	Automated Central Management &	CFG-02.2	Automated mechanisms exist to govern and report on baseline configurations of Technology Assets, Applications	5		
A.03.04.03.d[02]	Configuration Change Control	activities associated with configuration-controlled changes to the system are reviewed.	Functional	Subset Of	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	10		
03.04.04	Impact Analyses	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.04.04.a	Impact Analyses	changes to the system are analyzed to determine potential security impacts prior to change implementation.	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before	5	Updated in 2026.2	
A.03.04.04.a	Impact Analyses	changes to the system are analyzed to determine potential security impacts prior to change implementation.	Functional	Intersects With	Security, Compliance & Resilience Representative for Asset	CHG-02.3	Mechanisms exist to include a cybersecurity and/or data protection representative in the configuration change control review process.	5	Updated in 2026.2	
A.03.04.04.a	Impact Analyses	changes to the system are analyzed to determine potential security impacts prior to change implementation.	Functional	Intersects With	Security Impact Analysis for Changes	CHG-03	Mechanisms exist to analyze proposed changes for potential security impacts, prior to the implementation of the change.	5		
A.03.04.04.b	Impact Analyses	the security requirements for the system continue to be satisfied after the system changes have been implemented.	Functional	Intersects With	Control Functionality Verification	CHG-06	Mechanisms exist to verify the functionality of security, compliance and resilience controls following implemented changes to ensure applicable controls operate as designed.	5		
03.04.05	Access Restrictions for Change	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.04.05[01]	Access Restrictions for Change	physical access restrictions associated with changes to the system are defined and documented.	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of	5		
A.03.04.05[02]	Access Restrictions for Change	physical access restrictions associated with changes to the system are approved.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the	5		
A.03.04.05[03]	Access Restrictions for Change	physical access restrictions associated with changes to the system are enforced.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly	5		
A.03.04.05[04]	Access Restrictions for Change	logical access restrictions associated with changes to the system are defined and documented.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5		
A.03.04.05[04]	Access Restrictions for Change	logical access restrictions associated with changes to the system are defined and documented.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Updated in 2026.2	
A.03.04.05[05]	Access Restrictions for Change	logical access restrictions associated with changes to the system are approved.	Functional	Intersects With	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	5		
A.03.04.05[06]	Access Restrictions for Change	logical access restrictions associated with changes to the system are enforced.	Functional	Intersects With	Access Restriction For Change	CHG-04	Mechanisms exist to enforce configuration restrictions in an effort to restrict the ability of users to conduct unauthorized	5	Updated in 2026.2	
A.03.04.05[06]	Access Restrictions for Change	logical access restrictions associated with changes to the system are enforced.	Functional	Intersects With	Permissions To Implement Changes	CHG-04.4	Mechanisms exist to limit operational privileges for implementing changes.	5		
03.04.06	Least Functionality	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.04.06.ODP[01]	Least Functionality	functions to be prohibited or restricted are defined.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications	5		
A.03.04.06.ODP[02]	Least Functionality	ports to be prohibited or restricted are defined.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5		
A.03.04.06.ODP[03]	Least Functionality	protocols to be prohibited or restricted are defined.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5		
A.03.04.06.ODP[04]	Least Functionality	connections to be prohibited or restricted are defined.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5		
A.03.04.06.ODP[05]	Least Functionality	services to be prohibited or restricted are defined.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5		
A.03.04.06.ODP[06]	Least Functionality	the frequency at which to review the system to identify unnecessary or nonsecure functions, ports, protocols, connections, or services is defined.	Functional	Intersects With	Periodic Review	CFG-03.1	Mechanisms exist to periodically review system configurations to identify and disable unnecessary and/or non-secure functions, ports, protocols and services.	5		
A.03.04.06.a	Least Functionality	the system is configured to provide only mission-essential capabilities.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-	5	Updated in 2026.2	
A.03.04.06.a	Least Functionality	the system is configured to provide only mission-essential capabilities.	Functional	Intersects With	Approved Baseline Deviations	AST-02.4	Mechanisms exist to document and govern instances of approved deviations from established baseline configurations.	5	Updated in 2026.2	
A.03.04.06.a	Least Functionality	the system is configured to provide only mission-essential capabilities.	Functional	Intersects With	Configure Technology Assets, Applications and/or Services (TAAS)	CFG-02.5	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) utilized in high-risk areas with more restrictive baseline configurations.	5	Updated in 2026.2	
A.03.04.06.a	Least Functionality	the system is configured to provide only mission-essential capabilities.	Functional	Intersects With	Baseline Tailoring	CFG-02.9	Mechanisms exist to allow baseline controls to be specialized or customized by applying a defined set of tailoring actions that are specific to: (1) Mission / business functions;	5	Updated in 2026.2	
A.03.04.06.a	Least Functionality	the system is configured to provide only mission-essential capabilities.	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	5	Updated in 2026.2	
A.03.04.06.b[01]	Least Functionality	the use of the following functions is prohibited or restricted: <A.03.04.06.ODP[01]: functions>.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-	5		US DoD ODP Value: Guidance: Where feasible, organizations should limit

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.04.06.b[01]	Least Functionality	the use of the following functions is prohibited or restricted: <A.03.04.06.ODP[01]: functions>.	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of
A.03.04.06.b[02]	Least Functionality	the use of the following ports is prohibited or restricted: <A.03.04.06.ODP[02]: ports>.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of
A.03.04.06.b[02]	Least Functionality	the use of the following ports is prohibited or restricted: <A.03.04.06.ODP[02]: ports>.	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of
A.03.04.06.b[03]	Least Functionality	the use of the following protocols is prohibited or restricted: <A.03.04.06.ODP[03]: protocols>.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.04.06.b[03]	Least Functionality	the use of the following protocols is prohibited or restricted: <A.03.04.06.ODP[03]: protocols>.	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of
A.03.04.06.b[04]	Least Functionality	the use of the following connections is prohibited or restricted: <A.03.04.06.ODP[04]: connections>.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of
A.03.04.06.b[04]	Least Functionality	the use of the following connections is prohibited or restricted: <A.03.04.06.ODP[04]: connections>.	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of
A.03.04.06.b[05]	Least Functionality	the use of the following services is prohibited or restricted: <A.03.04.06.ODP[05]: services>.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.04.06.b[05]	Least Functionality	the use of the following services is prohibited or restricted: <A.03.04.06.ODP[05]: services>.	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	5	Updated in 2026.2	US DoD ODP Value: Guidance: Where feasible, organizations should limit component functionality to a single function per component. Organizations should consider removing unused or unnecessary software and disabling unused or unnecessary physical and logical ports and protocols to prevent unauthorized connection of components, transfer of information, and tunneling. Organizations should employ network scanning tools, intrusion detection and prevention systems, and endpoint protection technologies, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, protocols, ports, and services. Least functionality should also be achieved as part of the fundamental design and development of
A.03.04.06.c	Least Functionality	the system is reviewed <A.03.04.06.ODP[06]: frequency> to identify unnecessary or nonsecure functions, ports, protocols, connections, and services.	Functional	Intersects With	Reviews & Updates	CFG-02.1	Mechanisms exist to review and update baseline configurations: (1) At least annually; (2) When required due to so; or (3) As part of system component installations and upgrades.	8		US DoD ODP Value: at least every 12 months, when any system functions, ports, protocols, or services changes are made, and after any significant incidents or significant changes to risks
A.03.04.06.c	Least Functionality	the system is reviewed <A.03.04.06.ODP[06]: frequency> to identify unnecessary or nonsecure functions, ports, protocols, connections, and services.	Functional	Intersects With	Periodic Review	CFG-03.1	Mechanisms exist to periodically review system configurations to identify and disable unnecessary and/or non-secure functions, ports, protocols and services.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, when any system functions, ports, protocols, or services changes are made, and after any significant incidents or significant changes to risks
A.03.04.06.d	Least Functionality	unnecessary or nonsecure functions, ports, protocols, connections, and services are disabled or removed.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	Updated in 2026.2	
A.03.04.06.d	Least Functionality	unnecessary or nonsecure functions, ports, protocols, connections, and services are disabled or removed.	Functional	Intersects With	Configure Technology Assets, Applications and/or Services (TAAS) for High-Risk Areas	CFG-02.5	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) utilized in high-risk areas with more restrictive baseline configurations.	5	Updated in 2026.2	
A.03.04.06.d	Least Functionality	unnecessary or nonsecure functions, ports, protocols, connections, and services are disabled or removed.	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	5		
03.04.07	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.04.08	Authorized Software – Allow by Exception	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.04.08.ODP[01]	Authorized Software – Allow by Exception	the frequency at which to review and update the list of authorized software programs is defined.	Functional	Intersects With	Explicitly Allow / Deny Applications	CFG-03.3	Mechanisms exist to explicitly allow (allowlist / whitelist) and/or block (denylist / blacklist) applications that are	5		
A.03.04.08.a	Authorized Software – Allow by Exception	software programs authorized to execute on the system are identified.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use;	5	Updated in 2026.2	
A.03.04.08.a	Authorized Software – Allow by Exception	software programs authorized to execute on the system are identified.	Functional	Intersects With	Configuration Management Database (CMDB)	AST-02.9	Mechanisms exist to implement and manage a Configuration Management Database (CMDB), or similar technology, to monitor and govern technology asset-specific information.	5	Updated in 2026.2	
A.03.04.08.a	Authorized Software – Allow by Exception	software programs authorized to execute on the system are identified.	Functional	Intersects With	Baseline Tailoring	CFG-02.9	Mechanisms exist to allow baseline controls to be specialized or customized by applying a defined set of tailoring actions that are specific to: (1) Mission / business functions;	5	Updated in 2026.2	
A.03.04.08.a	Authorized Software – Allow by Exception	software programs authorized to execute on the system are identified.	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	5	Updated in 2026.2	
A.03.04.08.a	Authorized Software – Allow by Exception	software programs authorized to execute on the system are identified.	Functional	Intersects With	Explicitly Allow / Deny Applications	CFG-03.3	Mechanisms exist to explicitly allow (allowlist / whitelist) and/or block (denylist / blacklist) applications that are authorized to execute on systems.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.04.08.b	Authorized Software – Allow by Exception	a deny-all, allow-by-exception policy for the execution of authorized software programs on the system is implemented.	Functional	Intersects With	Prevent Unauthorized Software Execution	CFG-03.2	Mechanisms exist to configure systems to prevent the execution of unauthorized software programs.	5	Updated in 2026.2	
A.03.04.08.b	Authorized Software – Allow by Exception	a deny-all, allow-by-exception policy for the execution of authorized software programs on the system is implemented.	Functional	Intersects With	Explicitly Allow / Deny Applications	CFG-03.3	Mechanisms exist to explicitly allow (allowlist / whitelist) and/or block (denylist / blacklist) applications that are authorized to execute on systems.	5		
A.03.04.08.c	Authorized Software – Allow by Exception	the list of authorized software programs is reviewed and updated <A.03.04.08.ODP[01]: frequency>.	Functional	Intersects With	Approved Technologies	AST-01.4	Mechanisms exist to maintain a current list of approved technologies (hardware and software).	8		US DoD ODP Value: at least quarterly
A.03.04.08.c	Authorized Software – Allow by Exception	the list of authorized software programs is reviewed and updated <A.03.04.08.ODP[01]: frequency>.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that:	8	Updated in 2026.2	US DoD ODP Value: at least quarterly
A.03.04.08.c	Authorized Software – Allow by Exception	the list of authorized software programs is reviewed and updated <A.03.04.08.ODP[01]: frequency>.	Functional	Intersects With	Periodic Review	CFG-03.1	Mechanisms exist to periodically review system configurations to identify and disable unnecessary and/or non-secure functions, ports, protocols and services.	8	Updated in 2026.2	US DoD ODP Value: at least quarterly
A.03.04.08.c	Authorized Software – Allow by Exception	the list of authorized software programs is reviewed and updated <A.03.04.08.ODP[01]: frequency>.	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies	8	Updated in 2026.2	US DoD ODP Value: at least quarterly
03.04.09	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.04.10	System Component Inventory	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.04.10.ODP[01]	System Component Inventory	the frequency at which to review and update the system component inventory is defined.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that:	5		
A.03.04.10.a	System Component Inventory	an inventory of system components is developed and documented.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	5		
A.03.04.10.a	System Component Inventory	an inventory of system components is developed and documented.	Functional	Intersects With	Updates During Installations / Removals	AST-02.1	Mechanisms exist to update asset inventories as part of component installations, removals and asset upgrades.	5	Updated in 2026.2	
A.03.04.10.a	System Component Inventory	an inventory of system components is developed and documented.	Functional	Intersects With	Configuration Management Database (CMDB)	AST-02.9	Mechanisms exist to implement and manage a Configuration Management Database (CMDB), or similar technology, to monitor and govern technology asset-specific information.	5	Updated in 2026.2	
A.03.04.10.b[01]	System Component Inventory	the system component inventory is reviewed <A.03.04.10.ODP[01]: frequency>.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	8		US DoD ODP Value: at least quarterly
A.03.04.10.b[02]	System Component Inventory	the system component inventory is updated <A.03.04.10.ODP[01]: frequency>.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	8		US DoD ODP Value: at least quarterly
A.03.04.10.b[02]	System Component Inventory	the system component inventory is updated <A.03.04.10.ODP[01]: frequency>.	Functional	Intersects With	Updates During Installations / Removals	AST-02.1	Mechanisms exist to update asset inventories as part of component installations, removals and asset upgrades.	8	Updated in 2026.2	US DoD ODP Value: at least quarterly
A.03.04.10.b[02]	System Component Inventory	the system component inventory is updated <A.03.04.10.ODP[01]: frequency>.	Functional	Intersects With	Configuration Management Database (CMDB)	AST-02.9	Mechanisms exist to implement and manage a Configuration Management Database (CMDB), or similar technology, to monitor and govern technology asset-specific information.	8	Updated in 2026.2	US DoD ODP Value: at least quarterly
A.03.04.10.c[01]	System Component Inventory	the system component inventory is updated as part of component installations.	Functional	Intersects With	Updates During Installations / Removals	AST-02.1	Mechanisms exist to update asset inventories as part of component installations, removals and asset upgrades.	5		
A.03.04.10.c[02]	System Component Inventory	the system component inventory is updated as part of component removals.	Functional	Intersects With	Updates During Installations / Removals	AST-02.1	Mechanisms exist to update asset inventories as part of component installations, removals and asset upgrades.	5		
A.03.04.10.c[03]	System Component Inventory	the system component inventory is updated as part of system updates.	Functional	Intersects With	Updates During Installations / Removals	AST-02.1	Mechanisms exist to update asset inventories as part of component installations, removals and asset upgrades.	5		
03.04.11	Information Location	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.04.11.a[01]	Information Location	the location of CUI is identified and documented.	Functional	Intersects With	Data Action Mapping	AST-02.8	Mechanisms exist to create and maintain a map of Technology Assets, Applications and/or Services (TAAS) where sensitive	5		
A.03.04.11.a[01]	Information Location	the location of CUI is identified and documented.	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	Updated in 2026.2	
A.03.04.11.a[01]	Information Location	the location of CUI is identified and documented.	Functional	Intersects With	Compliance Scope	CPL-01.2	Mechanisms exist to document and validate the scope of security, compliance and resilience controls that are determined to meet statutory, regulatory and/or contractual	5	Updated in 2026.2	
A.03.04.11.a[01]	Information Location	the location of CUI is identified and documented.	Functional	Intersects With	Geographic Location of Data	DCH-19	Mechanisms exist to inventory, document and maintain data flows for data that is resident (permanently or temporarily) within a service's geographically distributed applications (physical and virtual), infrastructure, systems components	5	Updated in 2026.2	
A.03.04.11.a[01]	Information Location	the location of CUI is identified and documented.	Functional	Intersects With	Information Location	DCH-24	Mechanisms exist to identify and document the location of information and the specific system components on which the information resides.	5		
A.03.04.11.a[02]	Information Location	the system components on which CUI is processed are identified and documented.	Functional	Intersects With	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD OWP Values
A.03.04.11.a[02]	Information Location	the system components on which CUI is processed are identified and documented.	Functional	Intersects With	Data Action Mapping	AST-02.8	Mechanisms exist to create and maintain a map of Technology Assets, Applications and/or Services (TAAS) where sensitive and/or regulated data is stored, transmitted or processed.	5		
A.03.04.11.a[02]	Information Location	the system components on which CUI is processed are identified and documented.	Functional	Subset Of	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business	10	Updated in 2026.2	
A.03.04.11.a[02]	Information Location	the system components on which CUI is processed are identified and documented.	Functional	Subset Of	Network Diagrams & Data Flow Diagrams (DFDs)	AST-04	Mechanisms exist to maintain network architecture diagrams that: (1) Contain sufficient detail to assess the security of the network's architecture; (2) Reflect the current architecture of the network environment; and (3) Document all sensitive and/or regulated data flows.	10	Updated in 2026.2	
A.03.04.11.a[02]	Information Location	the system components on which CUI is processed are identified and documented.	Functional	Subset Of	Asset Scope Classification	AST-04.1	Mechanisms exist to determine security, compliance and resilience control applicability by identifying, assigning and documenting the appropriate asset scope categorization for all Technology Assets, Applications and/or Services (TAAS) and personnel (internal and third-parties).	10	Updated in 2026.2	
A.03.04.11.a[02]	Information Location	the system components on which CUI is processed are identified and documented.	Functional	Subset Of	Control Applicability Boundary Graphical Representation	AST-04.2	Mechanisms exist to ensure control applicability is appropriately-determined for Technology Assets, Applications and/or Services (TAAS) and third parties by graphically representing applicable boundaries.	10	Updated in 2026.2	
A.03.04.11.a[02]	Information Location	the system components on which CUI is processed are identified and documented.	Functional	Subset Of	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	10	Updated in 2026.2	
A.03.04.11.a[02]	Information Location	the system components on which CUI is processed are identified and documented.	Functional	Subset Of	Sensitive Data Inventories	DCH-06.2	Mechanisms exist to maintain inventory logs of all sensitive media and conduct sensitive media inventories at least annually.	10	Updated in 2026.2	
A.03.04.11.a[02]	Information Location	the system components on which CUI is processed are identified and documented.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation	10		
A.03.04.11.a[03]	Information Location	the system components on which CUI is stored are identified and documented.	Functional	Intersects With	Data Action Mapping	AST-02.8	Mechanisms exist to create and maintain a map of Technology Assets, Applications and/or Services (TAAS) where sensitive and/or regulated data is stored, transmitted or processed.	5		
A.03.04.11.a[03]	Information Location	the system components on which CUI is stored are identified and documented.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications	10		
A.03.04.11.b[01]	Information Location	changes to the system or system component location where CUI is processed are documented.	Functional	Intersects With	Data Action Mapping	AST-02.8	Mechanisms exist to create and maintain a map of Technology Assets, Applications and/or Services (TAAS) where sensitive and/or regulated data is stored, transmitted or processed.	5		
A.03.04.11.b[01]	Information Location	changes to the system or system component location where CUI is processed are documented.	Functional	Intersects With	Network Diagrams & Data Flow Diagrams (DFDs)	AST-04	Mechanisms exist to maintain network architecture diagrams that: (1) Contain sufficient detail to assess the security of the network's architecture;	5	Updated in 2026.2	
A.03.04.11.b[01]	Information Location	changes to the system or system component location where CUI is processed are documented.	Functional	Intersects With	Asset Scope Classification	AST-04.1	Mechanisms exist to determine security, compliance and resilience control applicability by identifying, assigning and documenting the appropriate asset scope categorization for all Technology Assets, Applications and/or Services (TAAS) and personnel (internal and third-parties).	5	Updated in 2026.2	
A.03.04.11.b[01]	Information Location	changes to the system or system component location where CUI is processed are documented.	Functional	Intersects With	Control Applicability Boundary Graphical Representation	AST-04.2	Mechanisms exist to ensure control applicability is appropriately-determined for Technology Assets, Applications and/or Services (TAAS) and third parties by graphically representing applicable boundaries.	5	Updated in 2026.2	
A.03.04.11.b[01]	Information Location	changes to the system or system component location where CUI is processed are documented.	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	5	Updated in 2026.2	
A.03.04.11.b[01]	Information Location	changes to the system or system component location where CUI is processed are documented.	Functional	Intersects With	Security Impact Analysis for Changes	CHG-03	Mechanisms exist to analyze proposed changes for potential security impacts, prior to the implementation of the change.	5	Updated in 2026.2	
A.03.04.11.b[01]	Information Location	changes to the system or system component location where CUI is processed are documented.	Functional	Intersects With	Stakeholder Notification of Changes	CHG-05	Mechanisms exist to ensure stakeholders are made aware of and understand the impact of proposed changes.	5		
A.03.04.11.b[01]	Information Location	changes to the system or system component location where CUI is processed are documented.	Functional	Intersects With	Sensitive Data Inventories	DCH-06.2	Mechanisms exist to maintain inventory logs of all sensitive media and conduct sensitive media inventories at least annually.	5	Updated in 2026.2	
A.03.04.11.b[01]	Information Location	changes to the system or system component location where CUI is processed are documented.	Functional	Intersects With	Geographic Location of Data	DCH-19	Mechanisms exist to inventory, document and maintain data flows for data that is resident (permanently or temporarily) within a service's geographically distributed applications	5	Updated in 2026.2	
A.03.04.11.b[01]	Information Location	changes to the system or system component location where CUI is processed are documented.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS);	10		
A.03.04.11.b[01]	Information Location	changes to the system or system component location where CUI is processed are documented.	Functional	Subset Of	Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum: (1) Deficiency tracking number; (2) Applicable security, compliance and/or resilience control; (3) Description of the deficiency(ies); (4) Risk associated with the deficiency(ies); (5) Source deficiency identification/detection; (6) Temporary compensating controls, if applicable; (7) Point of Contact (POC) (e.g., asset/process owner); (8) Resources required to conduct remediation actions;	10	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.04.11.b[02]	Information Location	changes to the system or system component location where CUI is stored are documented.	Functional	Intersects With	Data Action Mapping	AST-02.8	Mechanisms exist to create and maintain a map of Technology Assets, Applications and/or Services (TAAS) where sensitive and/or regulated data is stored, transmitted or processed.	5		
A.03.04.11.b[02]	Information Location	changes to the system or system component location where CUI is stored are documented.	Functional	Intersects With	Network Diagrams & Data Flow Diagrams (DFDs)	AST-04	Mechanisms exist to maintain network architecture diagrams that: (1) Contain sufficient detail to assess the security of the network's architecture;	5	Updated in 2026.2	
A.03.04.11.b[02]	Information Location	changes to the system or system component location where CUI is stored are documented.	Functional	Subset Of	Asset Scope Classification	AST-04.1	Mechanisms exist to determine security, compliance and resilience control applicability by identifying, assigning and documenting the appropriate asset scope categorization for all Technology Assets, Applications and/or Services (TAAS) and personnel (internal and third-parties).	10	Updated in 2026.2	
A.03.04.11.b[02]	Information Location	changes to the system or system component location where CUI is stored are documented.			Control Applicability Boundary Graphical Representation	AST-04.2	Mechanisms exist to ensure control applicability is appropriately-determined for Technology Assets, Applications and/or Services (TAAS) and third parties by graphically representing applicable boundaries.	5	Updated in 2026.2	
A.03.04.11.b[02]	Information Location	changes to the system or system component location where CUI is stored are documented.			Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	5	Updated in 2026.2	
A.03.04.11.b[02]	Information Location	changes to the system or system component location where CUI is stored are documented.			Security Impact Analysis for Changes	CHG-03	Mechanisms exist to analyze proposed changes for potential security impacts, prior to the implementation of the change.	5	Updated in 2026.2	
A.03.04.11.b[02]	Information Location	changes to the system or system component location where CUI is stored are documented.			Stakeholder Notification of Changes	CHG-05	Mechanisms exist to ensure stakeholders are made aware of and understand the impact of proposed changes.	5		
A.03.04.11.b[02]	Information Location	changes to the system or system component location where CUI is stored are documented.			Sensitive Data Inventories	DCH-06.2	Mechanisms exist to maintain inventory logs of all sensitive media and conduct sensitive media inventories at least annually.	5	Updated in 2026.2	
A.03.04.11.b[02]	Information Location	changes to the system or system component location where CUI is stored are documented.			Geographic Location of Data	DCH-19	Mechanisms exist to inventory, document and maintain data flows for data that is resident (permanently or temporarily) within a service's geographically distributed applications	5	Updated in 2026.2	
A.03.04.11.b[02]	Information Location	changes to the system or system component location where CUI is stored are documented.			Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS);	10		
A.03.04.11.b[02]	Information Location	changes to the system or system component location where CUI is stored are documented.			Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POAM)) or similar methodology that formally documents, at a minimum: (1) Deficiency tracking number; (2) Applicable security, compliance and/or resilience control; (3) Description of the deficiency(ies); (4) Risk associated with the deficiency(ies); (5) Source deficiency identification/detection; (6) Temporary compensating controls, if applicable; (7) Point of Contact (POC) (e.g., asset/process owner); (8) Resources required to conduct remediation actions;	10	Updated in 2026.2	
03.04.12	System and Component Configuration for High-Risk Areas	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.04.12.ODP[01]	System and Component Configuration for High-Risk Areas	configurations for systems or system components to be issued to individuals traveling to high-risk locations are defined.	Functional	Intersects With	Configure Technology Assets, Applications and/or Services (TAAS) for High-Risk Areas	CFG-02.5	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) utilized in high-risk areas with more restrictive baseline configurations.	5		
A.03.04.12.ODP[02]	System and Component Configuration for High-Risk Areas	security requirements to be applied to the system or system components when individuals return from travel are defined.	Functional	Intersects With	Configure Technology Assets, Applications and/or Services (TAAS) for High-Risk Areas	CFG-02.5	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) utilized in high-risk areas with more restrictive baseline configurations.	5		
A.03.04.12.a	System and Component Configuration for High-Risk Areas	systems or system components with the following configurations are issued to individuals traveling to high-risk locations: <A.03.04.12.ODP[01]: configurations>.	Functional	Intersects With	Travel-Only Devices	AST-24	Mechanisms exist to issue personnel travelling overseas with temporary, loaner or "travel-only" end user technology (e.g., laptops and mobile devices) when travelling to authoritarian countries with a higher-than average risk for Intellectual	8		US DoD ODP Value: a configuration that has no CUI or FCI stored on the system and prevents the processing.
A.03.04.12.a	System and Component Configuration for High-Risk Areas	systems or system components with the following configurations are issued to individuals traveling to high-risk locations: <A.03.04.12.ODP[01]: configurations>.	Functional	Intersects With	Configure Technology Assets, Applications and/or Services (TAAS) for High-Risk Areas	CFG-02.5	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) utilized in high-risk areas with more restrictive baseline configurations.	8	Updated in 2026.2	US DoD ODP Value: a configuration that has no CUI or FCI stored on the system and prevents the processing, storing, and transmission of CUI and FCI, unless a specific exception is granted in writing by the Contracting Officer
A.03.04.12.a	System and Component Configuration for High-Risk Areas	systems or system components with the following configurations are issued to individuals traveling to high-risk locations: <A.03.04.12.ODP[01]: configurations>.	Functional	Intersects With	Baseline Tailoring	CFG-02.9	Mechanisms exist to allow baseline controls to be specialized or customized by applying a defined set of tailoring actions that are specific to: (1) Mission / business functions; (2) Operational environment; (3) Specific threats or vulnerabilities; or (4) Other conditions or situations that could affect mission / business success.	8	Updated in 2026.2	US DoD ODP Value: a configuration that has no CUI or FCI stored on the system and prevents the processing, storing, and transmission of CUI and FCI, unless a specific exception is granted in writing by the Contracting Officer
A.03.04.12.b	System and Component Configuration for High-Risk Areas	the following security requirements are applied to the system or system components when the individuals return from travel: <A.03.04.12.ODP[02]: security requirements>.	Functional	Intersects With	Travel-Only Devices	AST-24	Mechanisms exist to issue personnel travelling overseas with temporary, loaner or "travel-only" end user technology (e.g., laptops and mobile devices) when travelling to authoritarian countries with a higher-than average risk for Intellectual Property (IP) theft or espionage against individuals and private companies.	8	Updated in 2026.2	US DoD ODP Value: examine the system for signs of physical tampering and take the appropriate actions, and then either purge and reimage all storage media or destroy the system

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.04.12.b	System and Component Configuration for High-Risk Areas	the following security requirements are applied to the system or system components when the individuals return from travel: <A.03.04.12.ODP[02]: security requirements>.	Functional	Intersects With	Re-Imaging Devices After Travel	AST-25	Mechanisms exist to re-image end user technology (e.g., laptops and mobile devices) when returning from overseas travel to an authoritarian country with a higher-than average risk for Intellectual Property (IP) theft or espionage against individuals and private companies.	8		US DoD ODP Value: examine the system for signs of physical tampering and take the appropriate actions, and then either purge and reimage all storage media or destroy the system
A.03.04.12.b	System and Component Configuration for High-Risk Areas	the following security requirements are applied to the system or system components when the individuals return from travel: <A.03.04.12.ODP[02]: security requirements>.	Functional	Intersects With	Mobile Device Tampering	MDM-04	Mechanisms exist to protect mobile devices from tampering through inspecting devices returning from locations that the organization deems to be of significant risk, prior to the device being connected to the organization's network.	8	Updated in 2026.2	US DoD ODP Value: examine the system for signs of physical tampering and take the appropriate actions, and then either purge and reimage all storage media or destroy the system
03.05.01	User Identification and Authentication	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.05.01.ODP[01]	User Identification and Authentication	circumstances or situations that require re-authentication are defined.	Functional	Intersects With	Re-Authentication	IAC-14	Mechanisms exist to force users and devices to re-authenticate according to organization-defined circumstances	5		
A.03.05.01.a[01]	User Identification and Authentication	system users are uniquely identified.	Functional	Intersects With	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	5	Updated in 2026.2	
A.03.05.01.a[01]	User Identification and Authentication	system users are uniquely identified.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and	5		
A.03.05.01.a[02]	User Identification and Authentication	system users are authenticated.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5		
A.03.05.01.a[03]	User Identification and Authentication	processes acting on behalf of users are associated with uniquely identified and authenticated system users.	Functional	Intersects With	Identification & Authentication for Organizational Users	IAC-02	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) organizational users and processes acting on behalf of organizational users.	5		
A.03.05.01.a[03]	User Identification and Authentication	processes acting on behalf of users are associated with uniquely identified and authenticated system users.	Functional	Intersects With	Identification & Authentication for Non-Organizational Users	IAC-03	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) third-party users and processes that provide services to the organization.	5	Updated in 2026.2	
A.03.05.01.a[03]	User Identification and Authentication	processes acting on behalf of users are associated with uniquely identified and authenticated system users.	Functional	Intersects With	Identification & Authentication for Third-Party Technology	IAC-05	Mechanisms exist to identify and authenticate third-party Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.05.01.b	User Identification and Authentication	users are reauthenticated when <A.03.05.01.ODP[01]: circumstances or situations>.	Functional	Intersects With	Re-Authentication	IAC-14	Mechanisms exist to force users and devices to re-authenticate according to organization-defined circumstances that necessitate re-authentication.	8		US DoD ODP Value: roles, authenticators, or credentials change (including modification of user privilege); when security
03.05.02	Device Identification and Authentication	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.05.02.ODP[01]	Device Identification and Authentication	devices or types of devices to be uniquely identified and authenticated before establishing a connection are defined.	Functional	Intersects With	Identification & Authentication for	IAC-04	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) devices before	5		
A.03.05.02[01]	Device Identification and Authentication	<A.03.05.02.ODP[01]: devices or types of devices> are uniquely identified before establishing a system connection.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	8	Updated in 2026.2	US DoD ODP Value: all devices for identification, where feasible for authentication, and document when not feasible
A.03.05.02[01]	Device Identification and Authentication	<A.03.05.02.ODP[01]: devices or types of devices> are uniquely identified before establishing a system connection.	Functional	Intersects With	Identification & Authentication for Devices	IAC-04	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) devices before establishing a connection using bidirectional authentication that is cryptographically- based and replay resistant.	8		US DoD ODP Value: all devices for identification, where feasible for authentication, and document when not feasible
A.03.05.02[01]	Device Identification and Authentication	<A.03.05.02.ODP[01]: devices or types of devices> are uniquely identified before establishing a system connection.	Functional	Intersects With	Identification & Authentication for Third-Party Technology Assets, Applications and/or Services (TAAS)	IAC-05	Mechanisms exist to identify and authenticate third-party Technology Assets, Applications and/or Services (TAAS).	8	Updated in 2026.2	US DoD ODP Value: all devices for identification, where feasible for authentication, and document when not feasible
A.03.05.02[02]	Device Identification and Authentication	<A.03.05.02.ODP[01]: devices or types of devices> are authenticated before establishing a system connection.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	8	Updated in 2026.2	US DoD ODP Value: all devices for identification, where feasible for authentication, and document when not feasible
A.03.05.02[02]	Device Identification and Authentication	<A.03.05.02.ODP[01]: devices or types of devices> are authenticated before establishing a system connection.	Functional	Intersects With	Identification & Authentication for Devices	IAC-04	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) devices before establishing a connection using bidirectional authentication that is cryptographically- based and replay resistant.	8		US DoD ODP Value: all devices for identification, where feasible for authentication, and document when not feasible
A.03.05.02[02]	Device Identification and Authentication	<A.03.05.02.ODP[01]: devices or types of devices> are authenticated before establishing a system connection.	Functional	Intersects With	Identification & Authentication for Third-Party Technology Assets, Applications and/or Services (TAAS)	IAC-05	Mechanisms exist to identify and authenticate third-party Technology Assets, Applications and/or Services (TAAS).	8	Updated in 2026.2	US DoD ODP Value: all devices for identification, where feasible for authentication, and document when not feasible
03.05.03	Multi-Factor Authentication	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.05.03[01]	Multi-Factor Authentication	multi-factor authentication for access to privileged accounts is implemented.	Functional	Intersects With	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for:	5		
A.03.05.03[01]	Multi-Factor Authentication	multi-factor authentication for access to privileged accounts is implemented.	Functional	Intersects With	Network Access to Privileged Accounts	IAC-06.1	Mechanisms exist to utilize Multi-Factor Authentication (MFA) to authenticate network access for privileged accounts.	5	Updated in 2026.2	
A.03.05.03[01]	Multi-Factor Authentication	multi-factor authentication for access to privileged accounts is implemented.	Functional	Intersects With	Local Access to Privileged Accounts	IAC-06.3	Mechanisms exist to utilize Multi-Factor Authentication (MFA) to authenticate local access for privileged accounts.	5	Updated in 2026.2	
A.03.05.03[01]	Multi-Factor Authentication	multi-factor authentication for access to privileged accounts is implemented.	Functional	Intersects With	Out-of-Band Multi-Factor Authentication	IAC-06.4	Mechanisms exist to implement Multi-Factor Authentication (MFA) for access to privileged and non-privileged accounts	5		
A.03.05.03[02]	Multi-Factor Authentication	multi-factor authentication for access to non-privileged accounts is implemented.	Functional	Intersects With	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for: (1) Remote network access; (2) Third-party Technology Assets, Applications and/or Services (TAAS); and/ or	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.05.03[02]	Multi-Factor Authentication	multi-factor authentication for access to non-privileged accounts is implemented.	Functional	Intersects With	Network Access to Non-Privileged Accounts	IAC-06.2	Mechaniams exist to utilize Multi-Factor Authentication (MFA) to authenticate network access for non-privileged accounts.	5	Updated in 2026.2	
A.03.05.03[02]	Multi-Factor Authentication	multi-factor authentication for access to non-privileged accounts is implemented.	Functional	Intersects With	Out-of-Band Multi-Factor Authentication	IAC-06.4	Mechanisms exist to implement Multi-Factor Authentication (MFA) for access to privileged and non-privileged accounts such that one of the factors is independently provided by a	5		
03.05.04	Replay-Resistant Authentication	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.05.04[01]	Replay-Resistant Authentication	replay-resistant authentication mechanisms for access to privileged accounts are implemented.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications	5		
A.03.05.04[01]	Replay-Resistant Authentication	replay-resistant authentication mechanisms for access to privileged accounts are implemented.	Functional	Intersects With	Replay-Resistant Authentication	IAC-02.2	Automated mechanisms exist to employ replay-resistant authentication.	5		
A.03.05.04[02]	Replay-Resistant Authentication	replay-resistant authentication mechanisms for access to non-privileged accounts are implemented.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications	5		
A.03.05.04[02]	Replay-Resistant Authentication	replay-resistant authentication mechanisms for access to non-privileged accounts are implemented.	Functional	Intersects With	Replay-Resistant Authentication	IAC-02.2	Automated mechanisms exist to employ replay-resistant authentication.	5		
03.05.05	Identifier Management	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.05.05.ODP[01]	Identifier Management	the time period for preventing the reuse of identifiers is defined.	Functional	Intersects With	Identifier Management (User Names)	IAC-09	Mechanisms exist to govern naming standards for usernames and Technology Assets, Applications and/or Services (TAAS).	5		
A.03.05.05.ODP[02]	Identifier Management	characteristic used to identify individual status are defined.	Functional	Intersects With	Identity User Status	IAC-09.2	Mechanisms exist to identify contractors and other third-party users through unique username characteristics.	5		
A.03.05.05.a	Identifier Management	authorization is received from organizational personnel or roles to assign an individual, group, role, service, or device identifier.	Functional	Intersects With	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	5	Updated in 2026.2	
A.03.05.05.a	Identifier Management	authorization is received from organizational personnel or roles to assign an individual, group, role, service, or device identifier.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5		
A.03.05.05.a	Identifier Management	authorization is received from organizational personnel or roles to assign an individual, group, role, service, or device identifier.	Functional	Intersects With	Change of Roles & Duties	IAC-07.1	Mechanisms exist to revoke user access rights following changes in personnel roles and duties, if no longer necessary or permitted.	5	Updated in 2026.2	
A.03.05.05.a	Identifier Management	authorization is received from organizational personnel or roles to assign an individual, group, role, service, or device identifier.	Functional	Intersects With	Management Approval For New or Changed Accounts	IAC-28.1	Mechanisms exist to ensure management approvals are required for new accounts or changes in permissions to existing accounts.	5	Updated in 2026.2	
A.03.05.05.b[01]	Identifier Management	an identifier that identifies an individual, group, role, service, or device is selected.	Functional	Intersects With	Identifier Management (User Names)	IAC-09	Mechanisms exist to govern naming standards for usernames and Technology Assets, Applications and/or Services (TAAS).	5		
A.03.05.05.b[01]	Identifier Management	an identifier that identifies an individual, group, role, service, or device is selected.	Functional	Intersects With	User Identity (ID) Management	IAC-09.1	Mechanisms exist to ensure proper user identification management for non-consumer users and administrators.	5	Updated in 2026.2	
A.03.05.05.b[01]	Identifier Management	an identifier that identifies an individual, group, role, service, or device is selected.	Functional	Intersects With	Automated System Account Management	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5	Updated in 2026.2	
A.03.05.05.b[02]	Identifier Management	an identifier that identifies an individual, group, role, service, or device is assigned.	Functional	Intersects With	Identifier Management (User Names)	IAC-09	Mechanisms exist to govern naming standards for usernames and Technology Assets, Applications and/or Services (TAAS).	5		
A.03.05.05.b[02]	Identifier Management	an identifier that identifies an individual, group, role, service, or device is assigned.	Functional	Intersects With	User Identity (ID) Management	IAC-09.1	Mechanisms exist to ensure proper user identification management for non-consumer users and administrators.	5	Updated in 2026.2	
A.03.05.05.b[02]	Identifier Management	an identifier that identifies an individual, group, role, service, or device is assigned.	Functional	Intersects With	Automated System Account Management	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5	Updated in 2026.2	
A.03.05.05.c	Identifier Management	the reuse of identifiers for <A.03.05.05.ODP[01]: time period> is prevented.	Functional	Intersects With	Identifier Management (User Names)	IAC-09	Mechanisms exist to govern naming standards for usernames and Technology Assets, Applications and/or Services (TAAS).	8		US DoD ODP Value: at least ten (10) years
A.03.05.05.c	Identifier Management	the reuse of identifiers for <A.03.05.05.ODP[01]: time period> is prevented.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	8		US DoD ODP Value: at least ten (10) years
A.03.05.05.d	Identifier Management	individual identifiers are managed by uniquely identifying each individual as <A.03.05.05.ODP[02]: characteristic>.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	8	Updated in 2026.2	US DoD ODP Value: privileged or non-privileged users; contractors, foreign nationals, and/or non-organizational users
A.03.05.05.d	Identifier Management	individual identifiers are managed by uniquely identifying each individual as <A.03.05.05.ODP[02]: characteristic>.	Functional	Intersects With	Identification & Authentication for Organizational Users	IAC-02	Mechanisms exist to uniquely identify and centrally Authenticate, Authorize and Audit (AAA) organizational users and processes acting on behalf of organizational users.	8		US DoD ODP Value: privileged or non-privileged users; contractors, foreign nationals, and/or non-organizational users
A.03.05.05.d	Identifier Management	individual identifiers are managed by uniquely identifying each individual as <A.03.05.05.ODP[02]: characteristic>.	Functional	Intersects With	Identifier Management (User Names)	IAC-09	Mechanisms exist to govern naming standards for usernames and Technology Assets, Applications and/or Services (TAAS).	8	Updated in 2026.2	US DoD ODP Value: privileged or non-privileged users; contractors, foreign nationals, and/or non-organizational users
A.03.05.05.d	Identifier Management	individual identifiers are managed by uniquely identifying each individual as <A.03.05.05.ODP[02]: characteristic>.	Functional	Intersects With	Identity User Status	IAC-09.2	Mechanisms exist to identify contractors and other third-party users through unique username characteristics.	8		US DoD ODP Value: privileged or non-privileged users; contractors, foreign nationals, and/or non-organizational users
A.03.05.05.d	Identifier Management	individual identifiers are managed by uniquely identifying each individual as <A.03.05.05.ODP[02]: characteristic>.	Functional	Intersects With	Privileged Account Identifiers	IAC-09.5	Mechanisms exist to uniquely manage privileged accounts to identify the account as a privileged user or service.	8	Updated in 2026.2	US DoD ODP Value: privileged or non-privileged users; contractors, foreign nationals, and/or non-organizational users
A.03.05.05.d	Identifier Management	individual identifiers are managed by uniquely identifying each individual as <A.03.05.05.ODP[02]: characteristic>.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	8	Updated in 2026.2	US DoD ODP Value: privileged or non-privileged users; contractors, foreign nationals, and/or non-organizational users
03.05.06	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.05.07	Password Management	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.05.07.ODP[01]	Password Management	the frequency at which to update the list of commonly used, expected, or compromised passwords is defined.	Functional	Intersects With	Automated Support For Password Strength	IAC-10.4	Automated mechanisms exist to determine if password authenticators are sufficiently strong enough to satisfy	5		
A.03.05.07.ODP[01]	Password Management	the frequency at which to update the list of commonly used, expected, or compromised passwords is defined.	Functional	Intersects With	Password Managers	IAC-10.11	Mechanisms exist to protect and store passwords via a password manager tool.	5		
A.03.05.07.ODP[02]	Password Management	password composition and complexity rules are defined.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based	5		
A.03.05.07.a[01]	Password Management	a list of commonly used, expected, or compromised passwords is maintained.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Updated in 2026.2	
A.03.05.07.a[01]	Password Management	a list of commonly used, expected, or compromised passwords is maintained.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.05.07.a[01]	Password Management	a list of commonly used, expected, or compromised passwords is maintained.	Functional	Intersects With	Automated Support For Password Strength	IAC-10.4	Automated mechanisms exist to determine if password authenticators are sufficiently strong enough to satisfy organization-defined password length and complexity requirements.	5		
A.03.05.07.a[01]	Password Management	a list of commonly used, expected, or compromised passwords is maintained.	Functional	Intersects With	Password Managers	IAC-10.11	Mechanisms exist to protect and store passwords via a password manager tool.	5		
A.03.05.07.a[02]	Password Management	a list of commonly used, expected, or compromised passwords is updated -<A.03.05.07.ODP[01]: frequency>.	Functional	Intersects With	Automated Support For Password Strength	IAC-10.4	Automated mechanisms exist to determine if password authenticators are sufficiently strong enough to satisfy	8		US DoD ODP Value: at least quarterly
A.03.05.07.a[02]	Password Management	a list of commonly used, expected, or compromised passwords is updated -<A.03.05.07.ODP[01]: frequency>.	Functional	Intersects With	Password Managers	IAC-10.11	Mechanisms exist to protect and store passwords via a password manager tool.	8		US DoD ODP Value: at least quarterly
A.03.05.07.a[03]	Password Management	a list of commonly used, expected, or compromised passwords is updated when organizational passwords are suspected to have been compromised.	Functional	Intersects With	Automated Support For Password Strength	IAC-10.4	Automated mechanisms exist to determine if password authenticators are sufficiently strong enough to satisfy	5		
A.03.05.07.a[03]	Password Management	a list of commonly used, expected, or compromised passwords is updated when organizational passwords are suspected to have been compromised.	Functional	Intersects With	Password Managers	IAC-10.11	Mechanisms exist to protect and store passwords via a password manager tool.	5		
A.03.05.07.b	Password Management	passwords are verified not to be found on the list of commonly used, expected, or compromised passwords when they are created or updated by users.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Updated in 2026.2	
A.03.05.07.b	Password Management	passwords are verified not to be found on the list of commonly used, expected, or compromised passwords when they are created or updated by users.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	Updated in 2026.2	
A.03.05.07.b	Password Management	passwords are verified not to be found on the list of commonly used, expected, or compromised passwords when they are created or updated by users.	Functional	Intersects With	Automated Support For Password Strength	IAC-10.4	Automated mechanisms exist to determine if password authenticators are sufficiently strong enough to satisfy organization-defined password length and complexity requirements.	5		
A.03.05.07.b	Password Management	passwords are verified not to be found on the list of commonly used, expected, or compromised passwords when they are created or updated by users.	Functional	Intersects With	Password Managers	IAC-10.11	Mechanisms exist to protect and store passwords via a password manager tool.	5		
A.03.05.07.c	Password Management	passwords are only transmitted over cryptographically protected channels.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry.	5		
A.03.05.07.c	Password Management	passwords are only transmitted over cryptographically protected channels.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Updated in 2026.2	
A.03.05.07.c	Password Management	passwords are only transmitted over cryptographically protected channels.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	Updated in 2026.2	
A.03.05.07.c	Password Management	passwords are only transmitted over cryptographically protected channels.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5		
A.03.05.07.c	Password Management	passwords are only transmitted over cryptographically protected channels.	Functional	Intersects With	Password Managers	IAC-10.11	Mechanisms exist to protect and store passwords via a password manager tool.	5	Updated in 2026.2	
A.03.05.07.c	Password Management	passwords are only transmitted over cryptographically protected channels.	Functional	Intersects With	Automated System Account Management	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5	Updated in 2026.2	
A.03.05.07.d	Password Management	passwords are stored in a cryptographically protected form.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry.	5		
A.03.05.07.d	Password Management	passwords are stored in a cryptographically protected form.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Updated in 2026.2	
A.03.05.07.d	Password Management	passwords are stored in a cryptographically protected form.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	Updated in 2026.2	
A.03.05.07.d	Password Management	passwords are stored in a cryptographically protected form.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5		
A.03.05.07.d	Password Management	passwords are stored in a cryptographically protected form.	Functional	Intersects With	Password Managers	IAC-10.11	Mechanisms exist to protect and store passwords via a password manager tool.	5	Updated in 2026.2	
A.03.05.07.d	Password Management	passwords are stored in a cryptographically protected form.	Functional	Intersects With	No Embedded Unencrypted Static	IAC-10.6	Mechanisms exist to ensure that unencrypted, static authenticators are not embedded in applications, scripts or	5	Updated in 2026.2	
A.03.05.07.d	Password Management	passwords are stored in a cryptographically protected form.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5	Updated in 2026.2	
A.03.05.07.e	Password Management	a new password is selected upon first use after account recovery.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry.	5		
A.03.05.07.e	Password Management	a new password is selected upon first use after account recovery.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Updated in 2026.2	
A.03.05.07.e	Password Management	a new password is selected upon first use after account recovery.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	Updated in 2026.2	
A.03.05.07.e	Password Management	a new password is selected upon first use after account recovery.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Updated in 2026.2	
A.03.05.07.e	Password Management	a new password is selected upon first use after account recovery.	Functional	Intersects With	Default Authenticators	IAC-10.8	Mechanisms exist to ensure default authenticators are changed as part of account creation or system installation.	5	Updated in 2026.2	
A.03.05.07.e	Password Management	a new password is selected upon first use after account recovery.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types;	5		
A.03.05.07.e	Password Management	a new password is selected upon first use after account recovery.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5	Updated in 2026.2	
A.03.05.07.f	Password Management	the following composition and complexity rules for passwords are enforced: -<A.03.05.07.ODP[02]: rules>.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry.	8		US DoD ODP Values: (1) Must have a minimum length of 16 characters.
A.03.05.07.f	Password Management	the following composition and complexity rules for passwords are enforced: -<A.03.05.07.ODP[02]: rules>.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	8	Updated in 2026.2	US DoD ODP Values: (1) Must have a minimum length of 16 characters. (2) Contains a string of characters that does not include the user's account name or full name.

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.05.07.f	Password Management	the following composition and complexity rules for passwords are enforced: <A.03.05.07.ODP[02]: rules>.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	8		US DoD ODP Values: (1) Must have a minimum length of 16 characters. (2) Contains a string of characters that does not include the user's account name or full name.
A.03.05.07.f	Password Management	the following composition and complexity rules for passwords are enforced: <A.03.05.07.ODP[02]: rules>.	Functional	Intersects With	Password Managers	IAC-10.11	Mechanisms exist to protect and store passwords via a password manager tool.	8	Updated in 2026.2	US DoD ODP Values: (1) Must have a minimum length of 16 characters. (2) Contains a string of characters that does not include the user's account name or full name.
A.03.05.07.f	Password Management	the following composition and complexity rules for passwords are enforced: <A.03.05.07.ODP[02]: rules>.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	8	Updated in 2026.2	US DoD ODP Values: (1) Must have a minimum length of 16 characters. (2) Contains a string of characters that does not include the user's account name or full name.
03.05.08	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.05.09	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.05.10	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.05.11	Authentication Feedback	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.05.11	Authentication Feedback	feedback of authentication information during the authentication process is obscured.	Functional	Intersects With	Authenticator Feedback	IAC-11	Mechanisms exist to obscure the feedback of authentication information during the authentication process to protect the	5		
03.05.12	Authenticator Management	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.05.12.ODP[01]	Authenticator Management	the frequency for changing or refreshing authenticators is defined.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and	5		
A.03.05.12.ODP[02]	Authenticator Management	events that trigger the change or refreshment of authenticators are defined.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5		
A.03.05.12.a	Authenticator Management	the identity of the individual, group, role, service, or device receiving the authenticator as part of the initial authenticator distribution is verified.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5		
A.03.05.12.a	Authenticator Management	the identity of the individual, group, role, service, or device receiving the authenticator as part of the initial authenticator distribution is verified.	Functional	Intersects With	In-Person or Trusted Third-Party Registration	IAC-10.3	Mechanisms exist to conduct in-person or trusted third-party identify verification before user accounts for third-parties are created.	5	Updated in 2026.2	
A.03.05.12.a	Authenticator Management	the identity of the individual, group, role, service, or device receiving the authenticator as part of the initial authenticator distribution is verified.	Functional	Intersects With	Identity Proofing (Identity Verification)	IAC-28	Mechanisms exist to verify the identity of a user before issuing authenticators or modifying access permissions.	5	Updated in 2026.2	
A.03.05.12.b	Authenticator Management	initial authenticator content for any authenticators issued by the organization is established.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the	5		
A.03.05.12.b	Authenticator Management	initial authenticator content for any authenticators issued by the organization is established.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Updated in 2026.2	
A.03.05.12.c[01]	Authenticator Management	administrative procedures for initial authenticator distribution are established.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the	5		
A.03.05.12.c[02]	Authenticator Management	administrative procedures for lost, compromised, or damaged authenticators are established.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5		
A.03.05.12.c[03]	Authenticator Management	administrative procedures for revoking authenticators are established.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5		
A.03.05.12.c[04]	Authenticator Management	administrative procedures for initial authenticator distribution are implemented.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5		
A.03.05.12.c[05]	Authenticator Management	administrative procedures for lost, compromised, or damaged authenticators are implemented.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5		
A.03.05.12.c[06]	Authenticator Management	administrative procedures for revoking authenticators are implemented.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5		
A.03.05.12.d	Authenticator Management	default authenticators are changed at first use.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	Updated in 2026.2	
A.03.05.12.d	Authenticator Management	default authenticators are changed at first use.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Updated in 2026.2	
A.03.05.12.d	Authenticator Management	default authenticators are changed at first use.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5		
A.03.05.12.d	Authenticator Management	default authenticators are changed at first use.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Updated in 2026.2	
A.03.05.12.d	Authenticator Management	default authenticators are changed at first use.	Functional	Intersects With	Default Authenticators	IAC-10.8	Mechanisms exist to ensure default authenticators are changed as part of account creation or system installation.	5	Updated in 2026.2	
A.03.05.12.d	Authenticator Management	default authenticators are changed at first use.	Functional	Intersects With	Automated System Account Management	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.05.12.e	Authenticator Management	authenticators are changed or refreshed <A.03.05.12.ODP[01]: frequency> or when the following events occur: <A.03.05.12.ODP[02]: events>.	Functional	Intersects With	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	8		US DoD ODP Values: (1) never for passwords where MFA is employed, at least
A.03.05.12.e	Authenticator Management	authenticators are changed or refreshed <A.03.05.12.ODP[01]: frequency> or when the following events occur: <A.03.05.12.ODP[02]: events>.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	8		US DoD ODP Values: (1) never for passwords where MFA is employed, at least every five (5) years for hard tokens and identification badges, and at least every three (3) years for all other authenticators. (2) after a relevant security incident or any evidence of compromise or loss.
A.03.05.12.e	Authenticator Management	authenticators are changed or refreshed <A.03.05.12.ODP[01]: frequency> or when the following events occur: <A.03.05.12.ODP[02]: events>.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	8		US DoD ODP Values: (1) never for passwords where MFA is employed, at least every five (5) years for hard tokens and identification badges, and at least every three (3) years for all other authenticators. (2) after a relevant security incident or any evidence of compromise or loss.
A.03.05.12.e	Authenticator Management	authenticators are changed or refreshed <A.03.05.12.ODP[01]: frequency> or when the following events occur: <A.03.05.12.ODP[02]: events>.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	8		US DoD ODP Values: (1) never for passwords where MFA is employed, at least every five (5) years for hard tokens and identification badges, and at least every three (3) years for all other authenticators. (2) after a relevant security incident or any evidence of compromise or loss.
A.03.05.12.f[01]	Authenticator Management	authenticator content is protected from unauthorized disclosure.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5		
A.03.05.12.f[01]	Authenticator Management	authenticator content is protected from unauthorized disclosure.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5		
A.03.05.12.f[01]	Authenticator Management	authenticator content is protected from unauthorized disclosure.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5	Updated in 2026.2	
A.03.05.12.f[02]	Authenticator Management	authenticator content is protected from unauthorized modification.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the	5		
A.03.05.12.f[02]	Authenticator Management	authenticator content is protected from unauthorized modification.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5		
A.03.05.12.f[02]	Authenticator Management	authenticator content is protected from unauthorized modification.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5	Updated in 2026.2	
03.06.01	Incident Handling	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.06.01[01]	Incident Handling	an incident-handling capability that is consistent with the incident response plan is implemented.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response	10		
A.03.06.01[01]	Incident Handling	an incident-handling capability that is consistent with the incident response plan is implemented.	Functional	Subset Of	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	10	Updated in 2026.2	
A.03.06.01[01]	Incident Handling	an incident-handling capability that is consistent with the incident response plan is implemented.	Functional	Subset Of	Sensitive / Regulated Data Spill Response	IRO-12	Mechanisms exist to respond to sensitive and/or regulated data spills.	10	Updated in 2026.2	
A.03.06.01[02]	Incident Handling	the incident handling capability includes preparation.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation;	5		
A.03.06.01[03]	Incident Handling	the incident handling capability includes detection and analysis.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	5		
A.03.06.01[04]	Incident Handling	the incident handling capability includes containment.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	5		
A.03.06.01[05]	Incident Handling	the incident handling capability includes eradication.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	5		
A.03.06.01[06]	Incident Handling	the incident handling capability includes recovery.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
03.06.02	Incident Monitoring, Reporting, and Response Assistance	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.06.02.ODP[01]	Incident Monitoring, Reporting, and Response Assistance	the time period to report suspected incidents to the organizational incident response capability is defined.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5		
A.03.06.02.ODP[01]	Incident Monitoring, Reporting, and Response Assistance	the time period to report suspected incidents to the organizational incident response capability is defined.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and	5		
A.03.06.02.ODP[02]	Incident Monitoring, Reporting, and Response Assistance	authorities to whom incident information is to be reported are defined.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5		
A.03.06.02.ODP[02]	Incident Monitoring, Reporting, and Response Assistance	authorities to whom incident information is to be reported are defined.	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	5		
A.03.06.02.ODP[02]	Incident Monitoring, Reporting, and Response Assistance	authorities to whom incident information is to be reported are defined.	Functional	Intersects With	Regulatory & Law Enforcement Contacts	IRO-14	Mechanisms exist to maintain incident response contacts with applicable regulatory and law enforcement agencies.	5		
A.03.06.02.a[01]	Incident Monitoring, Reporting, and Response Assistance	system security incidents are tracked.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report	5	Updated in 2026.2	
A.03.06.02.a[01]	Incident Monitoring, Reporting, and Response Assistance	system security incidents are tracked.	Functional	Intersects With	Situational Awareness For Incidents	IRO-09	Mechanisms exist to document, monitor and report the status of cybersecurity and data protection incidents to internal stakeholders all the way through the resolution of the incident.	5		
A.03.06.02.a[02]	Incident Monitoring, Reporting, and Response Assistance	system security incidents are documented.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake;	5	Updated in 2026.2	
A.03.06.02.a[02]	Incident Monitoring, Reporting, and Response Assistance	system security incidents are documented.	Functional	Intersects With	Situational Awareness For Incidents	IRO-09	Mechanisms exist to document, monitor and report the status of cybersecurity and data protection incidents to internal stakeholders all the way through the resolution of the incident.	5		
A.03.06.02.b	Incident Monitoring, Reporting, and Response Assistance	suspected incidents are reported to the organizational incident response capability within <A.03.06.02.ODP[01]: time period>.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake;	8		US DoD ODP Value: near real time or as soon as practicable upon discovery
A.03.06.02.b	Incident Monitoring, Reporting, and Response Assistance	suspected incidents are reported to the organizational incident response capability within <A.03.06.02.ODP[01]: time period>.	Functional	Intersects With	Integrated Security Incident Response Team (ISIRT)	IRO-07	Mechanisms exist to establish an integrated team of cybersecurity, IT and business function representatives that are capable of addressing cybersecurity and data protection incident response operations.	8		US DoD ODP Value: near real time or as soon as practicable upon discovery
A.03.06.02.b	Incident Monitoring, Reporting, and Response Assistance	suspected incidents are reported to the organizational incident response capability within <A.03.06.02.ODP[01]: time period>.	Functional	Intersects With	Situational Awareness For Incidents	IRO-09	Mechanisms exist to document, monitor and report the status of cybersecurity and data protection incidents to internal stakeholders all the way through the resolution of the incident.	8	Updated in 2026.2	US DoD ODP Value: near real time or as soon as practicable upon discovery
A.03.06.02.b	Incident Monitoring, Reporting, and Response Assistance	suspected incidents are reported to the organizational incident response capability within <A.03.06.02.ODP[01]: time period>.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8		US DoD ODP Value: near real time or as soon as practicable upon discovery
A.03.06.02.b	Incident Monitoring, Reporting, and Response Assistance	suspected incidents are reported to the organizational incident response capability within <A.03.06.02.ODP[01]: time period>.	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	8	Updated in 2026.2	US DoD ODP Value: near real time or as soon as practicable upon discovery
A.03.06.02.c	Incident Monitoring, Reporting, and Response Assistance	incident information is reported to <A.03.06.02.ODP[02]: authorities>.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report	8	Updated in 2026.2	US DoD ODP Value: all applicable personnel and entities as specified by the
A.03.06.02.c	Incident Monitoring, Reporting, and Response Assistance	incident information is reported to <A.03.06.02.ODP[02]: authorities>.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8		US DoD ODP Value: all applicable personnel and entities as specified by the contract, and in accordance with any incident response plan notification procedures
A.03.06.02.d	Incident Monitoring, Reporting, and Response Assistance	an incident response support resource that offers advice and assistance to system users on handling and reporting incidents is provided.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment;	5	Updated in 2026.2	
A.03.06.02.d	Incident Monitoring, Reporting, and Response Assistance	an incident response support resource that offers advice and assistance to system users on handling and reporting incidents is provided.	Functional	Intersects With	Integrated Security Incident Response Team (ISIRT)	IRO-07	Mechanisms exist to establish an integrated team of cybersecurity, IT and business function representatives that are capable of addressing cybersecurity and data protection incident response operations.	5		
A.03.06.02.d	Incident Monitoring, Reporting, and Response Assistance	an incident response support resource that offers advice and assistance to system users on handling and reporting incidents is provided.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5		
A.03.06.02.d	Incident Monitoring, Reporting, and Response Assistance	an incident response support resource that offers advice and assistance to system users on handling and reporting incidents is provided.	Functional	Intersects With	Incident Reporting Assistance	IRO-11	Mechanisms exist to provide incident response advice and assistance to users of Technology Assets, Applications and/or Services (TAAS) for the handling and reporting of actual and potential cybersecurity and data protection incidents.	5		
03.06.03	Incident Response Testing	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.06.03.ODP[01]	Incident Response Testing	the frequency at which to test the effectiveness of the incident response capability for the system is defined.	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the	5		
A.03.06.03	Incident Response Testing	the effectiveness of the incident response capability is tested <A.03.06.03.ODP[01]: frequency>.	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	8		US DoD ODP Value: at least every 12 months
03.06.04	Incident Response Training	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.06.04.ODP[01]	Incident Response Training	the time period within which incident response training is to be provided to system users is defined.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Updated in 2026.2	
A.03.06.04.ODP[01]	Incident Response Training	the time period within which incident response training is to be provided to system users is defined.	Functional	Intersects With	Formal Indoctrination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.06.04.ODP[01]	Incident Response Training	the time period within which incident response training is to be provided to system users is defined.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties;	5	Updated in 2026.2	
A.03.06.04.ODP[02]	Incident Response Training	the frequency at which to provide incident response training to users after initial training is defined.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5	Updated in 2026.2	
A.03.06.04.ODP[03]	Incident Response Training	the frequency at which to review and update incident response training content is defined.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and	5	Updated in 2026.2	
A.03.06.04.ODP[04]	Incident Response Training	events that initiate a review of the incident response training content are defined.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and (4) Technological developments.	5	Updated in 2026.2	
A.03.06.04.a.01	Incident Response Training	incident response training for system users consistent with assigned roles and responsibilities is provided within <A.03.06.04.ODP[01]: time period> of assuming an incident response role or responsibility or acquiring system access.	Functional	Intersects With	Formal Indoctrination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	8	Updated in 2026.2	US DoD ODP Value: ten (10) days for privileged users, thirty (30) days for all other roles
A.03.06.04.a.01	Incident Response Training	incident response training for system users consistent with assigned roles and responsibilities is provided within <A.03.06.04.ODP[01]: time period> of assuming an incident response role or responsibility or acquiring system access.	Functional	Intersects With	Incident Response Training	IRO-05	Mechanisms exist to train personnel in their incident response roles and responsibilities.	8		US DoD ODP Value: ten (10) days for privileged users, thirty (30) days for all other roles
A.03.06.04.a.01	Incident Response Training	incident response training for system users consistent with assigned roles and responsibilities is provided within <A.03.06.04.ODP[01]: time period> of assuming an incident response role or responsibility or acquiring system access.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and	8		US DoD ODP Value: ten (10) days for privileged users, thirty (30) days for all other roles
A.03.06.04.a.02	Incident Response Training	incident response training for system users consistent with assigned roles and responsibilities is provided when required by system changes.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and	5		
A.03.06.04.a.02	Incident Response Training	incident response training for system users consistent with assigned roles and responsibilities is provided when required by system changes.	Functional	Intersects With	Cyber Threat Environment	SAT-03.6	Mechanisms exist to provide role-based security, compliance and resilience awareness training that is current and relevant to the cyber threats that users might encounter in day-to-day business operations.	5	Updated in 2026.2	
A.03.06.04.a.03	Incident Response Training	incident response training for system users consistent with assigned roles and responsibilities is provided <A.03.06.04.ODP[02]: frequency> thereafter.	Functional	Intersects With	Incident Response Training	IRO-05	Mechanisms exist to train personnel in their incident response roles and responsibilities.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months
A.03.06.04.a.03	Incident Response Training	incident response training for system users consistent with assigned roles and responsibilities is provided <A.03.06.04.ODP[02]: frequency> thereafter.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months
A.03.06.04.a.03	Incident Response Training	incident response training for system users consistent with assigned roles and responsibilities is provided <A.03.06.04.ODP[02]: frequency> thereafter.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties;	8		US DoD ODP Value: at least every 12 months
A.03.06.04.b[01]	Incident Response Training	incident response training content is reviewed <A.03.06.04.ODP[03]: frequency>.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months
A.03.06.04.b[02]	Incident Response Training	incident response training content is updated <A.03.06.04.ODP[03]: frequency>.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months
A.03.06.04.b[03]	Incident Response Training	incident response training content is reviewed following <A.03.06.04.ODP[04]: events>.	Functional	Intersects With	Continuous Incident Response Improvements	IRO-04.3	Mechanisms exist to use qualitative and quantitative data from incident response testing to: (1) Determine the effectiveness of incident response processes; (2) Continuously improve incident response processes; and (3) Provide incident response measures and metrics that are accurate, consistent and in a reproducible format.	8	Updated in 2026.2	US DoD ODP Values: (1) at least every 12 months (2) significant, novel incidents, or significant changes to risks
A.03.06.04.b[03]	Incident Response Training	incident response training content is reviewed following <A.03.06.04.ODP[04]: events>.	Functional	Intersects With	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	8		US DoD ODP Values: (1) at least every 12 months (2) significant, novel incidents, or significant changes to risks
A.03.06.04.b[03]	Incident Response Training	incident response training content is reviewed following <A.03.06.04.ODP[04]: events>.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and (4) Technological developments.	8	Updated in 2026.2	US DoD ODP Values: (1) at least every 12 months (2) significant, novel incidents, or significant changes to risks
A.03.06.04.b[04]	Incident Response Training	incident response training content is updated following <A.03.06.04.ODP[04]: events>.	Functional	Intersects With	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	8		US DoD ODP Values: (1) at least every 12 months (2) significant, novel incidents, or significant changes to risks
A.03.06.04.b[04]	Incident Response Training	incident response training content is updated following <A.03.06.04.ODP[04]: events>.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and (4) Technological developments.	8	Updated in 2026.2	US DoD ODP Values: (1) at least every 12 months (2) significant, novel incidents, or significant changes to risks
03.06.05	Incident Response Plan	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.06.05.a.01	Incident Response Plan	an incident response plan is developed that provides the organization with a roadmap for implementing its incident response capability.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5		
A.03.06.05.a.02	Incident Response Plan	an incident response plan is developed that describes the structure and organization of the incident response capability.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.06.05.a.03	Incident Response Plan	an incident response plan is developed that provides a high-level approach for how the incident response capability fits into the overall organization.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5		
A.03.06.05.a.04	Incident Response Plan	an incident response plan is developed that defines reportable incidents.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5		
A.03.06.05.a.05	Incident Response Plan	an incident response plan is developed that addresses the sharing of incident information.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5		
A.03.06.05.a.06	Incident Response Plan	an incident response plan is developed that designates responsibilities to organizational entities, personnel, or roles.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5		
A.03.06.05.b[01]	Incident Response Plan	copies of the incident response plan are distributed to designated incident response personnel (identified by name or by role).	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report	5	Updated in 2026.2	
A.03.06.05.b[01]	Incident Response Plan	copies of the incident response plan are distributed to designated incident response personnel (identified by name or by role).	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5		
A.03.06.05.b[02]	Incident Response Plan	copies of the incident response plan are distributed to organizational elements.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5		
A.03.06.05.c	Incident Response Plan	the incident response plan is updated to address system and organizational changes or problems encountered during plan implementation, execution, or testing.	Functional	Intersects With	IRP Update	IRO-04.2	Mechanisms exist to regularly review and modify incident response practices to incorporate lessons learned, business process changes and industry developments, as necessary.	5		
A.03.06.05.d	Incident Response Plan	the incident response plan is protected from unauthorized disclosure.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5		
A.03.06.05.d	Incident Response Plan	the incident response plan is protected from unauthorized disclosure.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5		
A.03.06.05.d	Incident Response Plan	the incident response plan is protected from unauthorized disclosure.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or	5		
A.03.06.05.d	Incident Response Plan	the incident response plan is protected from unauthorized disclosure.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5		
A.03.06.05.d	Incident Response Plan	the incident response plan is protected from unauthorized disclosure.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	8		
03.07.01	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.07.02	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.07.03	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.07.04	Maintenance Tools	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.07.04.a[01]	Maintenance Tools	the use of system maintenance tools is approved.	Functional	Intersects With	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management	5	Updated in 2026.2	
A.03.07.04.a[01]	Maintenance Tools	the use of system maintenance tools is approved.	Functional	Intersects With	Maintenance Operations	MNT-01	Mechanisms exist to develop, disseminate, review & update procedures to facilitate the implementation of maintenance	5	Updated in 2026.2	
A.03.07.04.a[01]	Maintenance Tools	the use of system maintenance tools is approved.	Functional	Intersects With	Maintenance Tools	MNT-04	Mechanisms exist to control and monitor the use of system maintenance tools.	5		
A.03.07.04.a[02]	Maintenance Tools	the use of system maintenance tools is controlled.	Functional	Intersects With	Security of Assets & Media	AST-05	Mechanisms exist to maintain strict control over Technology Assets, Applications, Services and/or Data (TAASD) to preserve confidentiality and integrity.	5		
A.03.07.04.a[02]	Maintenance Tools	the use of system maintenance tools is controlled.	Functional	Intersects With	Maintenance Operations	MNT-01	Mechanisms exist to develop, disseminate, review & update procedures to facilitate the implementation of maintenance	5	Updated in 2026.2	
A.03.07.04.a[02]	Maintenance Tools	the use of system maintenance tools is controlled.	Functional	Intersects With	Controlled Maintenance	MNT-02	Mechanisms exist to conduct controlled maintenance activities throughout the lifecycle of the Technology Asset, Application and/or Service (TAAS).	5	Updated in 2026.2	
A.03.07.04.a[02]	Maintenance Tools	the use of system maintenance tools is controlled.	Functional	Intersects With	Timely Maintenance	MNT-03	Mechanisms exist to obtain maintenance support and/or spare parts for Technology Assets, Applications and/or Services (TAAS) within a defined Recovery Time Objective	5	Updated in 2026.2	
A.03.07.04.a[02]	Maintenance Tools	the use of system maintenance tools is controlled.	Functional	Intersects With	Preventative Maintenance	MNT-03.1	Mechanisms exist to perform preventive maintenance on critical Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.07.04.a[02]	Maintenance Tools	the use of system maintenance tools is controlled.	Functional	Intersects With	Maintenance Tools	MNT-04	Mechanisms exist to control and monitor the use of system maintenance tools.	5		
A.03.07.04.a[02]	Maintenance Tools	the use of system maintenance tools is controlled.	Functional	Intersects With	Off-Site Maintenance	MNT-09	Mechanisms exist to ensure off-site maintenance activities are conducted securely and the asset(s) undergoing maintenance actions are secured during physical transfer and	5	Updated in 2026.2	
A.03.07.04.a[03]	Maintenance Tools	the use of system maintenance tools is monitored.	Functional	Intersects With	Maintenance Tools	MNT-04	Mechanisms exist to control and monitor the use of system maintenance tools.	5		
A.03.07.04.b	Maintenance Tools	media with diagnostic and test programs are checked for malicious code before the media are used in the system.	Functional	Intersects With	Inspect Tools	MNT-04.1	Mechanisms exist to inspect maintenance tools carried into a facility by maintenance personnel for improper or unauthorized modifications.	5	Updated in 2026.2	
A.03.07.04.b	Maintenance Tools	media with diagnostic and test programs are checked for malicious code before the media are used in the system.	Functional	Intersects With	Inspect Media	MNT-04.2	Mechanisms exist to check media containing diagnostic and test programs for malicious code before the media are used.	5		
A.03.07.04.c	Maintenance Tools	the removal of system maintenance equipment containing CUI is prevented by verifying that there is no CUI on the equipment, sanitizing or destroying the equipment, or retaining the	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from	5	Updated in 2026.2	
A.03.07.04.c	Maintenance Tools	the removal of system maintenance equipment containing CUI is prevented by verifying that there is no CUI on the equipment, sanitizing or destroying the equipment, or retaining the	Functional	Intersects With	System Media Sanitization	DCH-09	Mechanisms exist to sanitize system media with the strength and integrity commensurate with the classification or sensitivity of the information prior to disposal, release out of	5	Updated in 2026.2	
A.03.07.04.c	Maintenance Tools	the removal of system maintenance equipment containing CUI is prevented by verifying that there is no CUI on the equipment, sanitizing or destroying the equipment, or retaining the equipment within the facility.	Functional	Intersects With	Prevent Unauthorized Removal	MNT-04.3	Mechanisms exist to prevent or control the removal of equipment undergoing maintenance that contains organizational information.	5		
03.07.05	Nonlocal Maintenance	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.07.05.a[01]	Nonlocal Maintenance	nonlocal maintenance and diagnostic activities are approved.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Updated in 2026.2	
A.03.07.05.a[01]	Nonlocal Maintenance	nonlocal maintenance and diagnostic activities are approved.	Functional	Intersects With	Privileged Access by Non-Organizational	IAC-05.2	Mechanisms exist to prohibit privileged access by non-organizational users.	5	Updated in 2026.2	
A.03.07.05.a[01]	Nonlocal Maintenance	nonlocal maintenance and diagnostic activities are approved.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Updated in 2026.2	
A.03.07.05.a[01]	Nonlocal Maintenance	nonlocal maintenance and diagnostic activities are approved.	Functional	Intersects With	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	5	Updated in 2026.2	
A.03.07.05.a[01]	Nonlocal Maintenance	nonlocal maintenance and diagnostic activities are approved.	Functional	Intersects With	Controlled Maintenance	MNT-02	Mechanisms exist to conduct controlled maintenance activities throughout the lifecycle of the Technology Asset, Application and/or Service (TAAS).	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.07.05.a[01]	Nonlocal Maintenance	nonlocal maintenance and diagnostic activities are approved.	Functional	Intersects With	Remote Maintenance	MNT-05	Mechanisms exist to authorize, monitor and control remote, non-local maintenance and diagnostic activities.	5		
A.03.07.05.a[01]	Nonlocal Maintenance	nonlocal maintenance and diagnostic activities are approved.	Functional	Intersects With	Remote Maintenance Pre-Approval	MNT-05.5	Mechanisms exist to require maintenance personnel to obtain pre-approval and scheduling for remote, non-local	5	Updated in 2026.2	
A.03.07.05.a[02]	Nonlocal Maintenance	nonlocal maintenance and diagnostic activities are monitored.	Functional	Intersects With	Remote Maintenance	MNT-05	Mechanisms exist to authorize, monitor and control remote, non-local maintenance and diagnostic activities.	5		
A.03.07.05.a[02]	Nonlocal Maintenance	nonlocal maintenance and diagnostic activities are monitored.	Functional	Intersects With	Auditing Remote Maintenance	MNT-05.1	Mechanisms exist to audit remote, non-local maintenance and diagnostic sessions, as well as review the maintenance	5	Updated in 2026.2	
A.03.07.05.b[01]	Nonlocal Maintenance	multi-factor authentication is implemented in the establishment of nonlocal maintenance and diagnostic sessions.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-	5	Updated in 2026.2	
A.03.07.05.b[01]	Nonlocal Maintenance	multi-factor authentication is implemented in the establishment of nonlocal maintenance and diagnostic sessions.	Functional	Intersects With	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for:	5		
A.03.07.05.b[01]	Nonlocal Maintenance	multi-factor authentication is implemented in the establishment of nonlocal maintenance and diagnostic sessions.	Functional	Intersects With	Remote Maintenance	MNT-05	Mechanisms exist to authorize, monitor and control remote, non-local maintenance and diagnostic activities.	5	Updated in 2026.2	
A.03.07.05.b[01]	Nonlocal Maintenance	multi-factor authentication is implemented in the establishment of nonlocal maintenance and diagnostic sessions.	Functional	Intersects With	Remote Maintenance Cryptographic Protection	MNT-05.3	Cryptographic mechanisms exist to protect the integrity and confidentiality of remote, non-local maintenance and diagnostic communications.	5	Updated in 2026.2	
A.03.07.05.b[02]	Nonlocal Maintenance	replay resistance is implemented in the establishment of nonlocal maintenance and diagnostic sessions.	Functional	Intersects With	Replay-Resistant Authentication	IAC-02.2	Automated mechanisms exist to employ replay-resistant authentication.	5		
A.03.07.05.c[01]	Nonlocal Maintenance	session connections are terminated when nonlocal maintenance is completed.	Functional	Intersects With	Session Termination	IAC-25	Automated mechanisms exist to log out users, both locally on the network and for remote sessions, at the end of the session or after an organization-defined period of inactivity.	5		
A.03.07.05.c[01]	Nonlocal Maintenance	session connections are terminated when nonlocal maintenance is completed.	Functional	Intersects With	Remote Maintenance	MNT-05	Mechanisms exist to authorize, monitor and control remote, non-local maintenance and diagnostic activities.	5	Updated in 2026.2	
A.03.07.05.c[01]	Nonlocal Maintenance	session connections are terminated when nonlocal maintenance is completed.	Functional	Intersects With	Remote Maintenance Disconnect Verification	MNT-05.4	Mechanisms exist to provide remote disconnect verification to ensure remote, non-local maintenance and diagnostic	5		
A.03.07.05.c[02]	Nonlocal Maintenance	network connections are terminated when nonlocal maintenance is completed.	Functional	Intersects With	Network Connection Termination	NET-07	Mechanisms exist to terminate network connections at the end of a session or after an organization-defined time period of inactivity.	5		
03.07.06	Maintenance Personnel	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.07.06.a	Maintenance Personnel	a process for maintenance personnel authorization is established.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Updated in 2026.2	
A.03.07.06.a	Maintenance Personnel	a process for maintenance personnel authorization is established.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned	5	Updated in 2026.2	
A.03.07.06.a	Maintenance Personnel	a process for maintenance personnel authorization is established.	Functional	Intersects With	Maintenance Operations	MNT-01	Mechanisms exist to develop, disseminate, review & update procedures to facilitate the implementation of maintenance	5	Updated in 2026.2	
A.03.07.06.a	Maintenance Personnel	a process for maintenance personnel authorization is established.	Functional	Intersects With	Authorized Maintenance Personnel	MNT-06	Mechanisms exist to maintain a current list of authorized maintenance organizations or personnel.	5		
A.03.07.06.a	Maintenance Personnel	a process for maintenance personnel authorization is established.	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	5	Updated in 2026.2	
A.03.07.06.a	Maintenance Personnel	a process for maintenance personnel authorization is established.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to	5	Updated in 2026.2	
A.03.07.06.b	Maintenance Personnel	a list of authorized maintenance organizations or personnel is maintained.	Functional	Intersects With	Authorized Maintenance Personnel	MNT-06	Mechanisms exist to maintain a current list of authorized maintenance organizations or personnel.	5		
A.03.07.06.b	Maintenance Personnel	a list of authorized maintenance organizations or personnel is maintained.	Functional	Intersects With	Third-Party Inventories	TPM-01.1	Mechanisms exist to maintain a current, accurate and complete list of External Service Providers (ESPs) that can	5	Updated in 2026.2	
A.03.07.06.b	Maintenance Personnel	a list of authorized maintenance organizations or personnel is maintained.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASC) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASC) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5		
A.03.07.06.c	Maintenance Personnel	non-escorted personnel who perform maintenance on the system possess the required access authorizations.	Functional	Intersects With	Authorized Maintenance Personnel	MNT-06	Mechanisms exist to maintain a current list of authorized maintenance organizations or personnel.	5		
A.03.07.06.c	Maintenance Personnel	non-escorted personnel who perform maintenance on the system possess the required access authorizations.	Functional	Intersects With	Maintenance Personnel Without Appropriate Access	MNT-06.1	Mechanisms exist to ensure the risks associated with maintenance personnel who do not have appropriate access authorizations, clearances or formal access approvals are appropriately mitigated.	5		
A.03.07.06.c	Maintenance Personnel	non-escorted personnel who perform maintenance on the system possess the required access authorizations.	Functional	Intersects With	Non-System Related Maintenance	MNT-06.2	Mechanisms exist to ensure that non-escorted personnel performing non-IT maintenance activities in the physical proximity of systems have required access authorizations.	5		
A.03.07.06.d[01]	Maintenance Personnel	organizational personnel with required access authorizations are designated to supervise the maintenance activities of personnel who do not possess the required access	Functional	Intersects With	Competency Requirements for Security-Related	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	5	Updated in 2026.2	
A.03.07.06.d[01]	Maintenance Personnel	organizational personnel with required access authorizations are designated to supervise the maintenance activities of personnel who do not possess the required access authorizations.	Functional	Intersects With	Authorized Maintenance Personnel	MNT-06	Mechanisms exist to maintain a current list of authorized maintenance organizations or personnel.	5		
A.03.07.06.d[01]	Maintenance Personnel	organizational personnel with required access authorizations are designated to supervise the maintenance activities of personnel who do not possess the required access	Functional	Intersects With	Maintenance Personnel Without Appropriate Access	MNT-06.1	Mechanisms exist to ensure the risks associated with maintenance personnel who do not have appropriate access authorizations, clearances or formal access approvals are	5	Updated in 2026.2	
A.03.07.06.d[02]	Maintenance Personnel	organizational personnel with required technical competence are designated to supervise the maintenance activities of personnel who do not possess the required access authorizations.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Updated in 2026.2	
A.03.07.06.d[02]	Maintenance Personnel	organizational personnel with required technical competence are designated to supervise the maintenance activities of personnel who do not possess the required access authorizations.	Functional	Intersects With	Maintenance Personnel Without Appropriate Access	MNT-06.1	Mechanisms exist to ensure the risks associated with maintenance personnel who do not have appropriate access authorizations, clearances or formal access approvals are appropriately mitigated.	5	Updated in 2026.2	
03.08.01	Media Storage	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	Updated in 2026.2	
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Data Stewardship	DCH-01.1	Mechanisms exist to ensure data stewardship is assigned, documented and communicated.	5	Updated in 2026.2	
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Defining Access Authorizations for	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and/or physical	5	Updated in 2026.2	
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and	5	Updated in 2026.2	
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Media Access	DCH-03	Mechanisms exist to control and restrict access to digital and non-digital media to authorized individuals.	5	Updated in 2026.2	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Media Storage	DCH-06	Mechanisms exist to: (1) Physically control and securely store digital and non-digital media within controlled areas using organization-defined security measures; and	5		
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Physically Secure All Media	DCH-06.1	Mechanisms exist to physically secure all media that contains sensitive information.	5	Updated in 2026.2	
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Making Sensitive Data Unreadable in Storage	DCH-06.4	Mechanisms exist to ensure sensitive and/or regulated data is rendered human unreadable anywhere sensitive and/or	5	Updated in 2026.2	
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	5	Updated in 2026.2	
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to	5	Updated in 2026.2	
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of the individual.	5	Updated in 2026.2	
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls	5	Updated in 2026.2	
A.03.08.01[01]	Media Storage	system media that contain CUI are physically controlled.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Data Stewardship	DCH-01.1	Mechanisms exist to ensure data stewardship is assigned, documented and communicated.	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Defining Access Authorizations for	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and/or physical	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Media Access	DCH-03	Mechanisms exist to control and restrict access to digital and non-digital media to authorized individuals.	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Media Storage	DCH-06	Mechanisms exist to: (1) Physically control and securely store digital and non-digital media within controlled areas using organization-defined security measures; and	5		
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Physically Secure All Media	DCH-06.1	Mechanisms exist to physically secure all media that contains sensitive information.	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Making Sensitive Data Unreadable in Storage	DCH-06.4	Mechanisms exist to ensure sensitive and/or regulated data is rendered human unreadable anywhere sensitive and/or	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of the individual.	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls	5	Updated in 2026.2	
A.03.08.01[02]	Media Storage	system media that contain CUI are securely stored.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Updated in 2026.2	
03.08.02	Media Access	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.08.02	Media Access	access to CUI on system media is restricted to authorized personnel or roles.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	
A.03.08.02	Media Access	access to CUI on system media is restricted to authorized personnel or roles.	Functional	Intersects With	Defining Access Authorizations for	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and/or physical	5	Updated in 2026.2	
A.03.08.02	Media Access	access to CUI on system media is restricted to authorized personnel or roles.	Functional	Intersects With	Media Access	DCH-03	Mechanisms exist to control and restrict access to digital and non-digital media to authorized individuals.	5		
A.03.08.02	Media Access	access to CUI on system media is restricted to authorized personnel or roles.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Updated in 2026.2	
A.03.08.02	Media Access	access to CUI on system media is restricted to authorized personnel or roles.	Functional	Intersects With	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	5	Updated in 2026.2	
A.03.08.02	Media Access	access to CUI on system media is restricted to authorized personnel or roles.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to	5	Updated in 2026.2	
A.03.08.02	Media Access	access to CUI on system media is restricted to authorized personnel or roles.	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of	5	Updated in 2026.2	
A.03.08.02	Media Access	access to CUI on system media is restricted to authorized personnel or roles.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls	5	Updated in 2026.2	
A.03.08.02	Media Access	access to CUI on system media is restricted to authorized personnel or roles.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Updated in 2026.2	
03.08.03	Media Sanitization	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.08.03	Media Sanitization	system media that contain CUI are sanitized prior to disposal, release out of organizational control, or release for reuse.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	5	Updated in 2026.2	
A.03.08.03	Media Sanitization	system media that contain CUI are sanitized prior to disposal, release out of organizational control, or release for reuse.	Functional	Intersects With	Physical Media Disposal	DCH-08	Mechanisms exist to securely dispose of media when it is no longer required, using formal procedures.	5	Updated in 2026.2	
A.03.08.03	Media Sanitization	system media that contain CUI are sanitized prior to disposal, release out of organizational control, or release for reuse.	Functional	Intersects With	System Media Sanitization	DCH-09	Mechanisms exist to sanitize system media with the strength and integrity commensurate with the classification or	5		
A.03.08.03	Media Sanitization	system media that contain CUI are sanitized prior to disposal, release out of organizational control, or release for reuse.	Functional	Intersects With	Information Disposal	DCH-21	Mechanisms exist to securely dispose of, destroy or erase information.	5	Updated in 2026.2	
03.08.04	Media Marking	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.08.04[01]	Media Marking	system media that contain CUI are marked to indicate distribution limitations.	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	5	Updated in 2026.2	
A.03.08.04[01]	Media Marking	system media that contain CUI are marked to indicate distribution limitations.	Functional	Intersects With	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable	5		
A.03.08.04[02]	Media Marking	system media that contain CUI are marked to indicate distribution limitations.	Functional	Intersects With	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable	5		
A.03.08.04[03]	Media Marking	system media that contain CUI are marked to indicate applicable CUI markings.	Functional	Intersects With	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable	5		
03.08.05	Media Transport	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.08.05.a[01]	Media Transport	system media that contain CUI are protected during transport outside of controlled areas.	Functional	Intersects With	Data Stewardship	DCH-01.1	Mechanisms exist to ensure data stewardship is assigned, documented and communicated.	5	Updated in 2026.2	
A.03.08.05.a[01]	Media Transport	system media that contain CUI are protected during transport outside of controlled areas.	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5		
A.03.08.05.a[02]	Media Transport	system media that contain CUI are controlled during transport outside of controlled areas.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	
A.03.08.05.a[02]	Media Transport	system media that contain CUI are controlled during transport outside of controlled areas.	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas	5		
A.03.08.05.a[02]	Media Transport	system media that contain CUI are controlled during transport outside of controlled areas.	Functional	Intersects With	Custodians	DCH-07.1	Mechanisms exist to identify custodians throughout the transport of digital or non-digital media.	5	Updated in 2026.2	
A.03.08.05.a[02]	Media Transport	system media that contain CUI are controlled during transport outside of controlled areas.	Functional	Intersects With	Encrypting Data In Storage Media	DCH-07.2	Cryptographic mechanisms exist to protect the confidentiality and integrity of information stored on digital media during	5	Updated in 2026.2	
A.03.08.05.b	Media Transport	accountability for system media that contain CUI is maintained during transport outside of controlled areas.	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5		
A.03.08.05.b	Media Transport	accountability for system media that contain CUI is maintained during transport outside of controlled areas.	Functional	Intersects With	Custodians	DCH-07.1	Mechanisms exist to identify custodians throughout the transport of digital or non-digital media.	5	Updated in 2026.2	
A.03.08.05.c	Media Transport	activities associated with the transport of system media that contain CUI are documented.	Functional	Intersects With	Sensitive / Regulated Media Records	DCH-01.3	Mechanisms exist to ensure media records for sensitive and/or regulated data contain sufficient information to determine the potential impact in the event of a data loss incident.	5	Updated in 2026.2	
A.03.08.05.c	Media Transport	activities associated with the transport of system media that contain CUI are documented.	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5		
03.08.06	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.08.07	Media Use	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.08.07.ODP[01]	Media Use	types of system media with usage restrictions or that are prohibited from use are defined.	Functional	Intersects With	Media Use	DCH-10	Mechanisms exist to restrict the use of types of digital media on systems or system components.	5		
A.03.08.07.a	Media Use	the use of the following types of system media is restricted or prohibited: <A.03.08.07.ODP[01]: types of system media>.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications	8	Updated in 2026.2	US DoD ODP Value: any removable media not
A.03.08.07.a	Media Use	the use of the following types of system media is restricted or prohibited: <A.03.08.07.ODP[01]: types of system media>.	Functional	Intersects With	Media Use	DCH-10	Mechanisms exist to restrict the use of types of digital media on systems or system components.	8		US DoD ODP Value: any removable media not
A.03.08.07.a	Media Use	the use of the following types of system media is restricted or prohibited: <A.03.08.07.ODP[01]: types of system media>.	Functional	Intersects With	Removable Media Security	DCH-12	Mechanisms exist to restrict removable media in accordance with data handling and acceptable usage parameters.	8	Updated in 2026.2	US DoD ODP Value: any removable media not
A.03.08.07.b	Media Use	the use of removable system media without an identifiable owner is prohibited.	Functional	Intersects With	Prohibit Use Without Owner	DCH-10.2	Mechanisms exist to prohibit the use of portable storage devices in organizational systems when such devices have no identifiable owner.	5		
03.08.08	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.08.09	System Backup – Cryptographic Protection	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.08.09.a	System Backup – Cryptographic Protection	the confidentiality of backup information is protected.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to	5	Updated in 2026.2	
A.03.08.09.a	System Backup – Cryptographic Protection	the confidentiality of backup information is protected.	Functional	Intersects With	Cryptographic Protection	BCD-11.4	Cryptographic mechanisms exist to prevent the unauthorized disclosure and/or modification of backup information.	5		
A.03.08.09.b	System Backup – Cryptographic Protection	cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI at backup storage locations.	Functional	Intersects With	Cryptographic Protection	BCD-11.4	Cryptographic mechanisms exist to prevent the unauthorized disclosure and/or modification of backup information.	5		
03.09.01	Personnel Screening	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.09.01.ODP[01]	Personnel Screening	conditions that require the rescreening of individuals are defined.	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	5		
A.03.09.01.ODP[01]	Personnel Screening	conditions that require the rescreening of individuals are defined.	Functional	Intersects With	Roles With Special Protection Measures	HRS-04.1	Mechanisms exist to ensure that individuals accessing a system that stores, transmits or processes information requiring special protection satisfy organization-defined	5		
A.03.09.01.a	Personnel Screening	individuals are screened prior to authorizing access to the system.	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing screening criteria for individuals filling those positions.	5	Updated in 2026.2	
A.03.09.01.a	Personnel Screening	individuals are screened prior to authorizing access to the system.	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	5		
A.03.09.01.a	Personnel Screening	individuals are screened prior to authorizing access to the system.	Functional	Intersects With	Roles With Special Protection Measures	HRS-04.1	Mechanisms exist to ensure that individuals accessing a system that stores, transmits or processes information requiring special protection satisfy organization-defined personnel screening criteria.	5	Updated in 2026.2	
A.03.09.01.b	Personnel Screening	individuals are rescreened in accordance with the following conditions: <A.03.09.01.ODP[01]: conditions>.	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing screening criteria for individuals filling those positions.	8	Updated in 2026.2	US DoD ODP Value: an organizational policy requiring rescreening when
A.03.09.01.b	Personnel Screening	individuals are rescreened in accordance with the following conditions: <A.03.09.01.ODP[01]: conditions>.	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	8		US DoD ODP Value: an organizational policy
A.03.09.01.b	Personnel Screening	individuals are rescreened in accordance with the following conditions: <A.03.09.01.ODP[01]: conditions>.	Functional	Intersects With	Roles With Special Protection Measures	HRS-04.1	Mechanisms exist to ensure that individuals accessing a system that stores, transmits or processes information requiring special protection satisfy organization-defined personnel screening criteria.	8	Updated in 2026.2	US DoD ODP Value: an organizational policy requiring rescreening when there is a significant incident.
03.09.02	Personnel Termination and Transfer	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.09.02.ODP[01]	Personnel Termination and Transfer	the time period within which to disable system access is defined.	Functional	Intersects With	Personnel Transfer	HRS-08	Mechanisms exist to adjust logical and physical access authorizations to Technology Assets, Applications and/or Services (TAAS) and facilities upon personnel reassignment or transfer, in a timely manner.	5		

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.09.02.ODP[01]	Personnel Termination and Transfer	the time period within which to disable system access is defined.	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	5		
A.03.09.02.a.01	Personnel Termination and Transfer	upon termination of individual employment, system access is disabled within <A.03.09.02.ODP[01]: time period>.	Functional	Intersects With	Personnel Transfer	HRS-08	Mechanisms exist to adjust logical and physical access authorizations to Technology Assets, Applications and/or	8	Updated in 2026.2	US DoD ODP Value: four (4) hours
A.03.09.02.a.01	Personnel Termination and Transfer	upon termination of individual employment, system access is disabled within <A.03.09.02.ODP[01]: time period>.	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	8		US DoD ODP Value: four (4) hours
A.03.09.02.a.01	Personnel Termination and Transfer	upon termination of individual employment, system access is disabled within <A.03.09.02.ODP[01]: time period>.	Functional	Intersects With	High-Risk Terminations	HRS-09.2	Mechanisms exist to expedite the process of removing "high risk" individual's access to Technology Assets, Applications,	8	Updated in 2026.2	US DoD ODP Value: four (4) hours
A.03.09.02.a.01	Personnel Termination and Transfer	upon termination of individual employment, system access is disabled within <A.03.09.02.ODP[01]: time period>.	Functional	Intersects With	Automated Employment Status Notifications	HRS-09.4	Automated mechanisms exist to notify Identity and Access Management (IAM) personnel or roles upon termination of an individual employment or contract.	8	Updated in 2026.2	US DoD ODP Value: four (4) hours
A.03.09.02.a.01	Personnel Termination and Transfer	upon termination of individual employment, system access is disabled within <A.03.09.02.ODP[01]: time period>.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access	8	Updated in 2026.2	US DoD ODP Value: four (4) hours
A.03.09.02.a.01	Personnel Termination and Transfer	upon termination of individual employment, system access is disabled within <A.03.09.02.ODP[01]: time period>.	Functional	Intersects With	Termination of Employment	IAC-07.2	Mechanisms exist to revoke user access rights in a timely manner, upon termination of employment or contract.	8	Updated in 2026.2	US DoD ODP Value: four (4) hours
A.03.09.02.a.02[01]	Personnel Termination and Transfer	upon termination of individual employment, authenticators associated with the individual are terminated or revoked.	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	5		
A.03.09.02.a.02[01]	Personnel Termination and Transfer	upon termination of individual employment, authenticators associated with the individual are terminated or revoked.	Functional	Intersects With	High-Risk Terminations	HRS-09.2	Mechanisms exist to expedite the process of removing "high risk" individual's access to Technology Assets, Applications, Services and/or Data (TAASD) upon termination, as	5	Updated in 2026.2	
A.03.09.02.a.02[01]	Personnel Termination and Transfer	upon termination of individual employment, authenticators associated with the individual are terminated or revoked.	Functional	Intersects With	Automated Employment Status Notifications	HRS-09.4	Automated mechanisms exist to notify Identity and Access Management (IAM) personnel or roles upon termination of an	5	Updated in 2026.2	
A.03.09.02.a.02[01]	Personnel Termination and Transfer	upon termination of individual employment, authenticators associated with the individual are terminated or revoked.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access	5	Updated in 2026.2	
A.03.09.02.a.02[01]	Personnel Termination and Transfer	upon termination of individual employment, authenticators associated with the individual are terminated or revoked.	Functional	Intersects With	Termination of Employment	IAC-07.2	Mechanisms exist to revoke user access rights in a timely manner, upon termination of employment or contract.	5	Updated in 2026.2	
A.03.09.02.a.02[02]	Personnel Termination and Transfer	upon termination of individual employment, credentials associated with the individual are terminated or revoked.	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	5		
A.03.09.02.a.02[02]	Personnel Termination and Transfer	upon termination of individual employment, credentials associated with the individual are terminated or revoked.	Functional	Intersects With	High-Risk Terminations	HRS-09.2	Mechanisms exist to expedite the process of removing "high risk" individual's access to Technology Assets, Applications, Services and/or Data (TAASD) upon termination, as	5	Updated in 2026.2	
A.03.09.02.a.02[02]	Personnel Termination and Transfer	upon termination of individual employment, credentials associated with the individual are terminated or revoked.	Functional	Intersects With	Automated Employment Status Notifications	HRS-09.4	Automated mechanisms exist to notify Identity and Access Management (IAM) personnel or roles upon termination of an	5	Updated in 2026.2	
A.03.09.02.a.02[02]	Personnel Termination and Transfer	upon termination of individual employment, credentials associated with the individual are terminated or revoked.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access	5	Updated in 2026.2	
A.03.09.02.a.02[02]	Personnel Termination and Transfer	upon termination of individual employment, credentials associated with the individual are terminated or revoked.	Functional	Intersects With	Termination of Employment	IAC-07.2	Mechanisms exist to revoke user access rights in a timely manner, upon termination of employment or contract.	5	Updated in 2026.2	
A.03.09.02.a.03	Personnel Termination and Transfer	upon termination of individual employment, security-related system property is retrieved.	Functional	Intersects With	Asset Ownership Assignment	AST-03	Mechanisms exist to ensure asset ownership responsibilities are assigned, tracked and managed at a team, individual, or responsible organization level to establish a common	5	Updated in 2026.2	
A.03.09.02.a.03	Personnel Termination and Transfer	upon termination of individual employment, security-related system property is retrieved.	Functional	Intersects With	Accountability Information	AST-03.1	Mechanisms exist to include capturing the name, position and/or role of individuals responsible/accountable for administering assets as part of the technology asset inventory	5	Updated in 2026.2	
A.03.09.02.a.03	Personnel Termination and Transfer	upon termination of individual employment, security-related system property is retrieved.	Functional	Intersects With	Return of Assets	AST-10	Mechanisms exist to ensure that employees and third-party users return all organizational assets in their possession upon	5		
A.03.09.02.a.03	Personnel Termination and Transfer	upon termination of individual employment, security-related system property is retrieved.	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	5		
A.03.09.02.a.03	Personnel Termination and Transfer	upon termination of individual employment, security-related system property is retrieved.	Functional	Intersects With	Asset Collection	HRS-09.1	Mechanisms exist to retrieve organization-owned assets upon termination of an individual's employment.	5		
A.03.09.02.b.01[01]	Personnel Termination and Transfer	upon individual reassignment or transfer to other positions in the organization, the ongoing operational need for current logical and physical access authorizations to the system and upon individual reassignment or transfer to other positions in the organization, the ongoing operational need for current	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	5		
A.03.09.02.b.01[01]	Personnel Termination and Transfer	upon individual reassignment or transfer to other positions in the organization, the ongoing operational need for current	Functional	Intersects With	Personnel Transfer	HRS-08	Mechanisms exist to adjust logical and physical access authorizations to Technology Assets, Applications and/or	5		
A.03.09.02.b.01[01]	Personnel Termination and Transfer	upon individual reassignment or transfer to other positions in the organization, the ongoing operational need for current logical and physical access authorizations to the system and facility is reviewed.	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	5	Updated in 2026.2	
A.03.09.02.b.01[01]	Personnel Termination and Transfer	upon individual reassignment or transfer to other positions in the organization, the ongoing operational need for current logical and physical access authorizations to the system and facility is reviewed.	Functional	Intersects With	High-Risk Terminations	HRS-09.2	Mechanisms exist to expedite the process of removing "high risk" individual's access to Technology Assets, Applications, Services and/or Data (TAASD) upon termination, as determined by management.	5	Updated in 2026.2	
A.03.09.02.b.01[02]	Personnel Termination and Transfer	upon individual reassignment or transfer to other positions in the organization, the ongoing operational need for current logical and physical access authorizations to the system and facility is confirmed.	Functional	Intersects With	Change of Roles & Duties	IAC-07.1	Mechanisms exist to revoke user access rights following changes in personnel roles and duties, if no longer necessary or permitted.	5	Updated in 2026.2	
A.03.09.02.b.01[02]	Personnel Termination and Transfer	upon individual reassignment or transfer to other positions in the organization, the ongoing operational need for current logical and physical access authorizations to the system and facility is confirmed.	Functional	Intersects With	Personnel Transfer	HRS-08	Mechanisms exist to adjust logical and physical access authorizations to Technology Assets, Applications and/or Services (TAAS) and facilities upon personnel reassignment or transfer, in a timely manner.	5		
A.03.09.02.b.01[02]	Personnel Termination and Transfer	upon individual reassignment or transfer to other positions in the organization, the ongoing operational need for current logical and physical access authorizations to the system and facility is confirmed.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	Updated in 2026.2	
A.03.09.02.b.02	Personnel Termination and Transfer	upon individual reassignment or transfer to other positions in the organization, access authorization is modified to correspond with any changes in operational need.	Functional	Intersects With	Change of Roles & Duties	IAC-07.1	Mechanisms exist to revoke user access rights following changes in personnel roles and duties, if no longer necessary or permitted.	5	Updated in 2026.2	
A.03.09.02.b.02	Personnel Termination and Transfer	upon individual reassignment or transfer to other positions in the organization, access authorization is modified to correspond with any changes in operational need.	Functional	Intersects With	Personnel Transfer	HRS-08	Mechanisms exist to adjust logical and physical access authorizations to Technology Assets, Applications and/or Services (TAAS) and facilities upon personnel reassignment or transfer, in a timely manner.	5		
A.03.09.02.b.02	Personnel Termination and Transfer	upon individual reassignment or transfer to other positions in the organization, access authorization is modified to correspond with any changes in operational need.	Functional	Intersects With	Access Enforcement	IAC-20	Mechanisms exist to enforce Logical Access Control (LAC) permissions that conform to the principle of "least privilege."	5	Updated in 2026.2	
03.10.01	Physical Access Authorizations	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.10.01.ODP[01]	Physical Access Authorizations	the frequency at which to review the access list detailing authorized facility access by individuals is defined.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5		
A.03.10.01.ODP[01]	Physical Access Authorizations	the frequency at which to review the access list detailing authorized facility access by individuals is defined.	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of the individual.	5		
A.03.10.01.a[01]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is developed.	Functional	Intersects With	Defining Access Authorizations for	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and/or physical	5	Updated in 2026.2	
A.03.10.01.a[01]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is developed.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.10.01.a[01]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is developed.	Functional	Intersects With	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	5	Updated in 2026.2	
A.03.10.01.a[01]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is developed.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5		
A.03.10.01.a[02]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is approved.	Functional	Intersects With	Defining Access Authorizations for Sensitive / Regulated	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and /or physical access to sensitive and/or regulated data.	5	Updated in 2026.2	
A.03.10.01.a[02]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is approved.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	
A.03.10.01.a[02]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is approved.	Functional	Intersects With	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	5	Updated in 2026.2	
A.03.10.01.a[02]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is approved.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5		
A.03.10.01.a[02]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is approved.	Functional	Intersects With	Visitor Control	PES-06	Physical access control mechanisms exist to identify, authorize and monitor visitors before allowing access to the facility (other than areas designated as publicly accessible).	5	Updated in 2026.2	
A.03.10.01.a[02]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is approved.	Functional	Intersects With	Distinguish Visitors from On-Site Personnel	PES-06.1	Physical access control mechanisms exist to easily distinguish between onsite personnel and visitors, especially in areas where sensitive and/or regulated data is accessible.	5	Updated in 2026.2	
A.03.10.01.a[03]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is maintained.	Functional	Intersects With	Defining Access Authorizations for Sensitive / Regulated Data	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and /or physical access to sensitive and/or regulated data.	5	Updated in 2026.2	
A.03.10.01.a[03]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is maintained.	Functional	Intersects With	Access To Sensitive / Regulated Data	IAC-20.1	Mechanisms exist to limit access to sensitive and/or regulated data to only those individuals whose job requires such access.	5	Updated in 2026.2	
A.03.10.01.a[03]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is maintained.	Functional	Intersects With	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	5	Updated in 2026.2	
A.03.10.01.a[03]	Physical Access Authorizations	a list of individuals with authorized access to the facility where the system resides is maintained.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5		
A.03.10.01.b	Physical Access Authorizations	authorization credentials for facility access are issued.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5	Updated in 2026.2	
A.03.10.01.b	Physical Access Authorizations	authorization credentials for facility access are issued.	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of the individual.	5		
A.03.10.01.c	Physical Access Authorizations	the facility access list is reviewed <A.03.10.01.ODP[01]: frequency>.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.10.01.c	Physical Access Authorizations	the facility access list is reviewed <A.03.10.01.ODP[01]: frequency>.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	8		US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.10.01.d	Physical Access Authorizations	individuals from the facility access list are removed when access is no longer required.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary	5	Updated in 2026.2	
A.03.10.01.d	Physical Access Authorizations	individuals from the facility access list are removed when access is no longer required.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5		
A.03.10.01.d	Physical Access Authorizations	individuals from the facility access list are removed when access is no longer required.	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of the individual.	5	Updated in 2026.2	
03.10.02	Monitoring Physical Access	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.10.02.ODP[01]	Monitoring Physical Access	the frequency at which to review physical access logs is defined.	Functional	Intersects With	Monitoring Physical Access	PES-05	Physical access control mechanisms exist to monitor for, detect and respond to physical security incidents.	5		
A.03.10.02.ODP[02]	Monitoring Physical Access	events or potential indications of events requiring physical access logs to be reviewed are defined.	Functional	Intersects With	Monitoring Physical Access	PES-05	Physical access control mechanisms exist to monitor for, detect and respond to physical security incidents.	5		
A.03.10.02.a[01]	Monitoring Physical Access	physical access to the facility where the system resides is monitored to detect physical security incidents.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including	5	Updated in 2026.2	
A.03.10.02.a[01]	Monitoring Physical Access	physical access to the facility where the system resides is monitored to detect physical security incidents.	Functional	Intersects With	Controlled Ingress & Egress Points	PES-03.1	Physical access control mechanisms exist to limit and monitor physical access through controlled ingress and egress	5	Updated in 2026.2	
A.03.10.02.a[01]	Monitoring Physical Access	physical access to the facility where the system resides is monitored to detect physical security incidents.	Functional	Intersects With	Physical Access Logs	PES-03.3	Physical access control mechanisms generate a log entry for each access attempt through controlled ingress and egress	5	Updated in 2026.2	
A.03.10.02.a[01]	Monitoring Physical Access	physical access to the facility where the system resides is monitored to detect physical security incidents.	Functional	Intersects With	Monitoring Physical Access	PES-05	Physical access control mechanisms exist to monitor for, detect and respond to physical security incidents.	5		
A.03.10.02.a[01]	Monitoring Physical Access	physical access to the facility where the system resides is monitored to detect physical security incidents.	Functional	Intersects With	Intrusion Alarms / Surveillance Equipment	PES-05.1	Physical access control mechanisms exist to monitor physical intrusion alarms and surveillance equipment.	5	Updated in 2026.2	
A.03.10.02.a[01]	Monitoring Physical Access	physical access to the facility where the system resides is monitored to detect physical security incidents.	Functional	Intersects With	Monitoring Physical Access To Critical Systems	PES-05.2	Facility security mechanisms exist to monitor physical access to critical systems or sensitive and/or regulated data, in addition to the physical access monitoring of the facility.	5	Updated in 2026.2	
A.03.10.02.a[02]	Monitoring Physical Access	physical security incidents are responded to.	Functional	Intersects With	Monitoring Physical Access	PES-05	Physical access control mechanisms exist to monitor for, detect and respond to physical security incidents.	5		
A.03.10.02.b[01]	Monitoring Physical Access	physical access logs are reviewed <A.03.10.02.ODP[01]: frequency>.	Functional	Intersects With	Monitoring Physical Access	PES-05	Physical access control mechanisms exist to monitor for, detect and respond to physical security incidents.	8		US DoD ODP Values: at least every 45 days
A.03.10.02.b[01]	Monitoring Physical Access	physical access logs are reviewed <A.03.10.02.ODP[01]: frequency>.	Functional	Intersects With	Monitoring Physical Access To Critical Systems	PES-05.2	Facility security mechanisms exist to monitor physical access to critical systems or sensitive and/or regulated data, in addition to the physical access monitoring of the facility.	8	Updated in 2026.2	US DoD ODP Values: at least every 45 days
A.03.10.02.b[02]	Monitoring Physical Access	physical access logs are reviewed upon occurrence of <A.03.10.02.ODP[02]: events or potential indicators of	Functional	Intersects With	Monitoring Physical Access	PES-05	Physical access control mechanisms exist to monitor for, detect and respond to physical security incidents.	8		US DoD ODP Values: significant, novel incidents, or
A.03.10.02.b[02]	Monitoring Physical Access	physical access logs are reviewed upon occurrence of <A.03.10.02.ODP[02]: events or potential indicators of	Functional	Intersects With	Monitoring Physical Access To Critical	PES-05.2	Facility security mechanisms exist to monitor physical access to critical systems or sensitive and/or regulated data, in	8	Updated in 2026.2	US DoD ODP Values: significant, novel incidents, or
03.10.03	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.10.04	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.10.05	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
03.10.06	Alternate Work Site	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.10.06.ODP[01]	Alternate Work Site	security requirements to be employed at alternate work sites are defined.	Functional	Intersects With	Alternate Work Site	PES-11	Physical security mechanisms exist to utilize appropriate management, operational and technical controls at alternate	5		
A.03.10.06.ODP[01]	Alternate Work Site	security requirements to be employed at alternate work sites are defined.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications,	5		
A.03.10.06.a	Alternate Work Site	alternate work sites allowed for use by employees are determined.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications,	5		
A.03.10.06.a	Alternate Work Site	alternate work sites allowed for use by employees are determined.	Functional	Intersects With	Alternate Work Site	PES-11	Physical security mechanisms exist to utilize appropriate management, operational and technical controls at alternate work sites.	5		
A.03.10.06.b	Alternate Work Site	the following security requirements are employed at alternate work sites: <A.03.10.06.ODP[01]: security requirements>.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	8		US DoD ODP Value: adequate security, comparable to organizational security requirements at the primary
A.03.10.06.b	Alternate Work Site	the following security requirements are employed at alternate work sites: <A.03.10.06.ODP[01]: security requirements>.	Functional	Intersects With	Alternate Work Site	PES-11	Physical security mechanisms exist to utilize appropriate management, operational and technical controls at alternate work sites.	8		US DoD ODP Value: adequate security, comparable to organizational security requirements at the primary
03.10.07	Physical Access Control	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.10.07.a.01	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by verifying individual physical access authorizations before granting access.	Functional	Intersects With	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	5	Updated in 2026.2	
A.03.10.07.a.01	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by verifying individual physical access authorizations before granting access.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5		
A.03.10.07.a.01	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by verifying individual physical access authorizations before granting access.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including	5	Updated in 2026.2	
A.03.10.07.a.01	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by verifying individual physical access authorizations before granting access.	Functional	Intersects With	Controlled Ingress & Egress Points	PES-03.1	Physical access control mechanisms exist to limit and monitor physical access through controlled ingress and egress points.	5	Updated in 2026.2	
A.03.10.07.a.01	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by verifying individual physical access authorizations before granting access.	Functional	Intersects With	Access To Critical Systems	PES-03.4	Physical access control mechanisms exist to enforce physical access to critical systems or sensitive and/or regulated data, in addition to the physical access controls for the facility.	5	Updated in 2026.2	
A.03.10.07.a.01	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by verifying individual physical access authorizations before granting access.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Updated in 2026.2	
A.03.10.07.a.01	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by verifying individual physical access authorizations before granting access.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Updated in 2026.2	
A.03.10.07.a.02	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by controlling ingress and egress with physical access control systems, devices, or guards.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly	5		
A.03.10.07.a.02	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by controlling ingress and egress with physical access control systems, devices, or guards.	Functional	Intersects With	Controlled Ingress & Egress Points	PES-03.1	Physical access control mechanisms exist to limit and monitor physical access through controlled ingress and egress points.	5	Updated in 2026.2	
A.03.10.07.a.02	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by controlling ingress and egress with physical access control systems, devices, or guards.	Functional	Intersects With	Physical Access Logs	PES-03.3	Physical access control mechanisms generate a log entry for each access attempt through controlled ingress and egress points.	5	Updated in 2026.2	
A.03.10.07.a.02	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by controlling ingress and egress with physical access control systems, devices, or guards.	Functional	Intersects With	Access To Critical Systems	PES-03.4	Physical access control mechanisms exist to enforce physical access to critical systems or sensitive and/or regulated data, in addition to the physical access controls for the facility.	5	Updated in 2026.2	
A.03.10.07.a.02	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by controlling ingress and egress with physical access control systems, devices, or guards.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and	5	Updated in 2026.2	
A.03.10.07.a.02	Physical Access Control	physical access authorizations are enforced at entry and exit points to the facility where the system resides by controlling ingress and egress with physical access control systems, devices, or guards.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Updated in 2026.2	
A.03.10.07.b	Physical Access Control	physical access audit logs for entry or exit points are maintained.	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	5	Updated in 2026.2	
A.03.10.07.b	Physical Access Control	physical access audit logs for entry or exit points are maintained.	Functional	Intersects With	Physical Access Logs	PES-03.3	Physical access control mechanisms generate a log entry for each access attempt through controlled ingress and egress points.	5		
A.03.10.07.c[01]	Physical Access Control	visitors are escorted.	Functional	Intersects With	Visitor Control	PES-06	Physical access control mechanisms exist to identify, authorize and monitor visitors before allowing access to the facility (other than areas designated as publicly accessible).	5		
A.03.10.07.c[01]	Physical Access Control	visitors are escorted.	Functional	Intersects With	Distinguish Visitors from On-Site Personnel	PES-06.1	Physical access control mechanisms exist to easily distinguish between onsite personnel and visitors, especially in areas where sensitive and/or regulated data is accessible.	5		
A.03.10.07.c[01]	Physical Access Control	visitors are escorted.	Functional	Intersects With	Identification Requirement	PES-06.2	Physical access control mechanisms exist to requires at least one(1) form of government-issued or organization-issued photo identification to authenticate individuals before they	5	Updated in 2026.2	
A.03.10.07.c[01]	Physical Access Control	visitors are escorted.	Functional	Intersects With	Restrict Unescorted Access	PES-06.3	Physical access control mechanisms exist to restrict unescorted access to facilities to personnel with required security clearances, formal access authorizations and validate the need for access.	5		
A.03.10.07.c[01]	Physical Access Control	visitors are escorted.	Functional	Intersects With	Visitor Access Revocation	PES-06.6	Mechanisms exist to ensure visitor badges, or other issued identification, are surrendered before visitors leave the facility or are deactivated at a pre-determined time/date of expiration.	5	Updated in 2026.2	
A.03.10.07.c[02]	Physical Access Control	visitor activity is controlled.	Functional	Intersects With	Visitor Control	PES-06	Physical access control mechanisms exist to identify, authorize and monitor visitors before allowing access to the facility (other than areas designated as publicly accessible).	5		
A.03.10.07.c[02]	Physical Access Control	visitor activity is controlled.	Functional	Intersects With	Distinguish Visitors from On-Site Personnel	PES-06.1	Physical access control mechanisms exist to easily distinguish between onsite personnel and visitors, especially in areas where sensitive and/or regulated data is accessible.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.10.07.c[02]	Physical Access Control	visitor activity is controlled.	Functional	Intersects With	Identification Requirement	PES-06.2	Physical access control mechanisms exist to require at least one(1) form of government-issued or organization-issued photo identification to authenticate individuals before they can gain access to the facility.	5	Updated in 2026.2	
A.03.10.07.c[02]	Physical Access Control	visitor activity is controlled.	Functional	Intersects With	Restrict Unescorted Access	PES-06.3	Physical access control mechanisms exist to restrict unescorted access to facilities to personnel with required security clearances, formal access authorizations and validate the need for access.	5		
A.03.10.07.c[02]	Physical Access Control	visitor activity is controlled.	Functional	Intersects With	Visitor Access Revocation	PES-06.6	Mechanisms exist to ensure visitor badges, or other issued identification, are surrendered before visitors leave the facility or are deactivated at a pre-determined time/date of expiration.	5	Updated in 2026.2	
A.03.10.07.d	Physical Access Control	keys, combinations, and other physical access devices are secured.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly	5		
A.03.10.07.d	Physical Access Control	keys, combinations, and other physical access devices are secured.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and	5	Updated in 2026.2	
A.03.10.07.d	Physical Access Control	keys, combinations, and other physical access devices are secured.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Updated in 2026.2	
A.03.10.07.e	Physical Access Control	physical access to output devices is controlled to prevent unauthorized individuals from obtaining access to CUI.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	Updated in 2026.2	
A.03.10.07.e	Physical Access Control	physical access to output devices is controlled to prevent unauthorized individuals from obtaining access to CUI.	Functional	Intersects With	Access Control for Output Devices	PES-12.2	Physical security mechanisms exist to restrict access to printers and other system output devices to prevent unauthorized individuals from obtaining the output.	5		
03.10.08	Access Control for Transmission	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.10.08	Access Control for Transmission	physical access to system distribution and transmission lines within organizational facilities is controlled.	Functional	Intersects With	Supporting Utilities	PES-07	Facility security mechanisms exist to protect power equipment and power cabling for the system from damage and destruction.	5	Updated in 2026.2	
A.03.10.08	Access Control for Transmission	physical access to system distribution and transmission lines within organizational facilities is controlled.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the	5	Updated in 2026.2	
A.03.10.08	Access Control for Transmission	physical access to system distribution and transmission lines within organizational facilities is controlled.	Functional	Intersects With	Transmission Medium Security	PES-12.1	Physical security mechanisms exist to protect power and telecommunications cabling carrying data or supporting	5		
03.11.01	Risk Assessment	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.11.01.ODP[01]	Risk Assessment	the frequency at which to update the risk assessment is defined.	Functional	Intersects With	Risk Assessment Update	RSK-07	Mechanisms exist to routinely update risk assessments and react accordingly upon identifying new security vulnerabilities, including using outside sources for security vulnerability information.	5		
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Intersects With	Prohibited Equipment & Services	AST-17	Mechanisms exist to govern Supply Chain Risk Management (SCRM) sanctions that require the removal and prohibition of certain Technology Assets, Applications and/or Services (TAAS) that are designated as supply chain threats by a	5	Updated in 2026.2	
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Intersects With	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls	5	Updated in 2026.2	
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Intersects With	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and	5		
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Intersects With	Risk-Based Security Categorization	RSK-02	Mechanisms exist to categorize Technology Assets, Applications, Services and/or Data (TAASD) in accordance with applicable laws, regulations and contractual obligations that: (1) Document the security categorization results (including	5	Updated in 2026.2	
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Intersects With	Impact-Level Prioritization	RSK-02.1	Mechanisms exist to prioritize the impact level for Technology Assets, Applications and/or Services (TAAS) to prevent potential disruptions.	5	Updated in 2026.2	
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Intersects With	Risk Identification	RSK-03	Mechanisms exist to identify and document risks, both internal and external.	5		
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Intersects With	Risk Catalog	RSK-03.1	Mechanisms exist to develop and keep current a catalog of applicable risks associated with the organization's business operations and technologies in use.	5		
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification	5		
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Subset Of	Risk Ranking	RSK-05	Mechanisms exist to identify and assign a risk ranking to newly discovered security vulnerabilities that is based on industry-recognized practices.	10	Updated in 2026.2	
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets,	10		
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Subset Of	Supply Chain Risk Assessment	RSK-09.1	Mechanisms exist to periodically assess supply chain risks associated with Technology Assets, Applications and/or Services (TAAS).	10	Updated in 2026.2	
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Subset Of	Third-Party Criticality Assessments	TPM-02	Mechanisms exist to identify, prioritize and assess suppliers and partners of critical Technology Assets, Applications and/or Services (TAAS) using a supply chain risk assessment	10	Updated in 2026.2	
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Subset Of	Supply Chain Risk Management (SCRM)	TPM-03	Mechanisms exist to: (1) Evaluate security risks and threats associated with Technology Assets, Applications and/or Services (TAAS) supply chains; and (2) Take appropriate remediation actions to minimize the organization's exposure to these risks and threats, as	10	Updated in 2026.2	
A.03.11.01.a	Risk Assessment	the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed.	Functional	Subset Of	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	10	Updated in 2026.2	
A.03.11.01.b	Risk Assessment	risk assessments are updated <A.03.11.01.ODP[01]: frequency>.	Functional	Intersects With	Risk Assessment Update	RSK-07	Mechanisms exist to routinely update risk assessments and react accordingly upon identifying new security vulnerabilities, including using outside sources for security vulnerability information.	8		US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.11.01.b	Risk Assessment	risk assessments are updated <A.03.11.01.ODP[01]: frequency>.	Functional	Intersects With	Supply Chain Risk Assessment	RSK-09.1	Mechanisms exist to periodically assess supply chain risks associated with Technology Assets, Applications and/or Services (TAAS).	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
03.11.02	Vulnerability Monitoring and Scanning	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.11.02.ODP[01]	Vulnerability Monitoring and Scanning	the frequency at which the system is monitored for vulnerabilities is defined.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	5		
A.03.11.02.ODP[02]	Vulnerability Monitoring and Scanning	the frequency at which the system is scanned for vulnerabilities is defined.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	5		
A.03.11.02.ODP[03]	Vulnerability Monitoring and Scanning	response times to remediate system vulnerabilities are defined.	Functional	Subset Of	Vulnerability & Patch Management Program	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10		
A.03.11.02.ODP[03]	Vulnerability Monitoring and Scanning	response times to remediate system vulnerabilities are defined.	Functional	Intersects With	Vulnerability Remediation Process	VPM-02	Mechanisms exist to ensure that vulnerabilities are properly identified, tracked and remediated.	5		
A.03.11.02.ODP[04]	Vulnerability Monitoring and Scanning	the frequency at which to update system vulnerabilities to be scanned is defined.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	5		
A.03.11.02.ODP[04]	Vulnerability Monitoring and Scanning	the frequency at which to update system vulnerabilities to be scanned is defined.	Functional	Intersects With	Update Tool Capability	VPM-06.1	Mechanisms exist to update vulnerability scanning tools.	5		
A.03.11.02.a[01]	Vulnerability Monitoring and Scanning	the system is monitored for vulnerabilities <A.03.11.02.ODP[01]: frequency>.	Functional	Intersects With	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing	8	Updated in 2026.2	US DoD ODP Value: at least monthly, or when there are
A.03.11.02.a[01]	Vulnerability Monitoring and Scanning	the system is monitored for vulnerabilities <A.03.11.02.ODP[01]: frequency>.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to	8	Updated in 2026.2	US DoD ODP Value: at least monthly, or when there are significant incidents or
A.03.11.02.a[01]	Vulnerability Monitoring and Scanning	the system is monitored for vulnerabilities <A.03.11.02.ODP[01]: frequency>.	Functional	Intersects With	Vulnerability & Patch Management Program	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	8	Updated in 2026.2	US DoD ODP Value: at least monthly, or when there are
A.03.11.02.a[01]	Vulnerability Monitoring and Scanning	the system is monitored for vulnerabilities <A.03.11.02.ODP[01]: frequency>.	Functional	Intersects With	Attack Surface Scope	VPM-01.1	Mechanisms exist to define and manage the scope for its attack surface management activities.	8		US DoD ODP Value: at least monthly, or when there are significant incidents or significant changes to risks
A.03.11.02.a[01]	Vulnerability Monitoring and Scanning	the system is monitored for vulnerabilities <A.03.11.02.ODP[01]: frequency>.	Functional	Intersects With	Vulnerability Ranking	VPM-03	Mechanisms exist to identify and assign a risk ranking to newly discovered security vulnerabilities using reputable outside sources for security vulnerability information.	8	Updated in 2026.2	US DoD ODP Value: at least monthly, or when there are significant incidents or significant changes to risks
A.03.11.02.a[01]	Vulnerability Monitoring and Scanning	the system is monitored for vulnerabilities <A.03.11.02.ODP[01]: frequency>.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	8		US DoD ODP Value: at least monthly, or when there are significant incidents or significant changes to risks
A.03.11.02.a[02]	Vulnerability Monitoring and Scanning	the system is scanned for vulnerabilities <A.03.11.02.ODP[02]: frequency>.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	8		US DoD ODP Value: at least monthly, or when there are significant incidents or significant changes to risks
A.03.11.02.a[03]	Vulnerability Monitoring and Scanning	the system is monitored for vulnerabilities when new vulnerabilities that affect the system are identified.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	5		
A.03.11.02.a[04]	Vulnerability Monitoring and Scanning	the system is scanned for vulnerabilities when new vulnerabilities that affect the system are identified.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	5		
A.03.11.02.b	Vulnerability Monitoring and Scanning	system vulnerabilities are remediated within <A.03.11.02.ODP[03]: response times>.	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	8	Updated in 2026.2	US DoD ODP Value: thirty (30) days from date of discovery for high-risk vulnerabilities (including both critical and
A.03.11.02.b	Vulnerability Monitoring and Scanning	system vulnerabilities are remediated within <A.03.11.02.ODP[03]: response times>.	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or resilience-related:	8	Updated in 2026.2	US DoD ODP Value: thirty (30) days from date of discovery for high-risk vulnerabilities
A.03.11.02.b	Vulnerability Monitoring and Scanning	system vulnerabilities are remediated within <A.03.11.02.ODP[03]: response times>.	Functional	Intersects With	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	8	Updated in 2026.2	US DoD ODP Value: thirty (30) days from date of discovery for high-risk vulnerabilities
A.03.11.02.b	Vulnerability Monitoring and Scanning	system vulnerabilities are remediated within <A.03.11.02.ODP[03]: response times>.	Functional	Intersects With	Vulnerability Remediation Process	VPM-02	Mechanisms exist to ensure that vulnerabilities are properly identified, tracked and remediated.	8	Updated in 2026.2	US DoD ODP Value: thirty (30) days from date of discovery for high-risk vulnerabilities (including both critical and high); 90 days from date of discovery for moderate-risk vulnerabilities; and 180 days from date of discovery for low-risk vulnerabilities
A.03.11.02.b	Vulnerability Monitoring and Scanning	system vulnerabilities are remediated within <A.03.11.02.ODP[03]: response times>.	Functional	Intersects With	Continuous Vulnerability Remediation Activities	VPM-04	Mechanisms exist to address new threats and vulnerabilities on an ongoing basis and ensure assets are protected against known attacks.	8		US DoD ODP Value: thirty (30) days from date of discovery for high-risk vulnerabilities (including both critical and high); 90 days from date of discovery for moderate-risk vulnerabilities; and 180 days from date of discovery for low-risk vulnerabilities
A.03.11.02.b	Vulnerability Monitoring and Scanning	system vulnerabilities are remediated within <A.03.11.02.ODP[03]: response times>.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	8		US DoD ODP Value: thirty (30) days from date of discovery for high-risk vulnerabilities (including both critical and high); 90 days from date of discovery for moderate-risk vulnerabilities; and 180 days from date of discovery for low-risk vulnerabilities
A.03.11.02.c[01]	Vulnerability Monitoring and Scanning	system vulnerabilities to be scanned are updated <A.03.11.02.ODP[04]: frequency>.	Functional	Intersects With	Update Tool Capability	VPM-06.1	Mechanisms exist to update vulnerability scanning tools.	8		US DoD ODP Value: no more than 24 hours prior to running the scans

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.11.02.c[02]	Vulnerability Monitoring and Scanning	system vulnerabilities to be scanned are updated when new vulnerabilities are identified and reported.	Functional	Intersects With	Update Tool Capability	VPM-06.1	Mechanisms exist to update vulnerability scanning tools.	5		
03.11.03	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.11.04	Risk Response	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.11.04[01]	Risk Response	findings from security assessments are responded to.	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance	5		
A.03.11.04[02]	Risk Response	findings from security monitoring are responded to.	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance	5		
A.03.11.04[03]	Risk Response	findings from security audits are responded to.	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance	5		
03.12.01	Security Assessment	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.12.01.ODP[01]	Security Assessment	the frequency at which to assess the security requirements for the system and its environment of operation is defined.	Functional	Intersects With	Internal Audit Function	CPL-02.1	Mechanisms exist to implement an internal audit function that is capable of providing senior organization management with insights into the appropriateness of the organization's technology and information governance processes.	5		
A.03.12.01	Security Assessment	the security requirements for the system and its environment of operation are assessed <A.03.12.01.ODP[01]: frequency> to determine if the requirements have been satisfied.	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.12.01	Security Assessment	the security requirements for the system and its environment of operation are assessed <A.03.12.01.ODP[01]: frequency> to determine if the requirements have been satisfied.	Functional	Intersects With	Security, Compliance & Resilience Controls	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.12.01	Security Assessment	the security requirements for the system and its environment of operation are assessed <A.03.12.01.ODP[01]: frequency> to determine if the requirements have been satisfied.	Functional	Intersects With	Internal Audit Function	CPL-02.1	Mechanisms exist to implement an internal audit function that is capable of providing senior organization management with insights into the appropriateness of the organization's technology and information governance processes.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.12.01	Security Assessment	the security requirements for the system and its environment of operation are assessed <A.03.12.01.ODP[01]: frequency> to determine if the requirements have been satisfied.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	8		US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.12.01	Security Assessment	the security requirements for the system and its environment of operation are assessed <A.03.12.01.ODP[01]: frequency> to determine if the requirements have been satisfied.	Functional	Intersects With	Information Assurance (IA) Operations	IAO-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience assessment and authorization controls.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.12.01	Security Assessment	the security requirements for the system and its environment of operation are assessed <A.03.12.01.ODP[01]: frequency> to determine if the requirements have been satisfied.	Functional	Intersects With	Assessment Boundaries	IAO-01.1	Mechanisms exist to establish the scope of assessments by defining the assessment boundary, according to people, processes and technology that directly or indirectly impact the confidentiality, integrity, availability and safety of the Technology Assets, Applications, Services and/or Data	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.12.01	Security Assessment	the security requirements for the system and its environment of operation are assessed <A.03.12.01.ODP[01]: frequency> to determine if the requirements have been satisfied.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.12.01	Security Assessment	the security requirements for the system and its environment of operation are assessed <A.03.12.01.ODP[01]: frequency> to determine if the requirements have been satisfied.	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.12.01	Security Assessment	the security requirements for the system and its environment of operation are assessed <A.03.12.01.ODP[01]: frequency> to determine if the requirements have been satisfied.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
03.12.02	Plan of Action and Milestones	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.12.02.a.01	Plan of Action and Milestones	a plan of action and milestones for the system is developed to document the planned remediation actions for correcting weaknesses or deficiencies noted during security assessments.	Functional	Intersects With	Capabilities Deficiency Tracking	IAQ-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum: (1) Deficiency tracking number; (2) Applicable security, compliance and/or resilience control;	5		
A.03.12.02.a.01	Plan of Action and Milestones	a plan of action and milestones for the system is developed to document the planned remediation actions for correcting weaknesses or deficiencies noted during security assessments.	Functional	Intersects With	Non-Compliance Oversight	CPL-01.1	Mechanisms exist to document and review instances of non-compliance with statutory, regulatory and/or contractual obligations to develop appropriate risk mitigation actions.	5	Updated in 2026.2	
A.03.12.02.a.01	Plan of Action and Milestones	a plan of action and milestones for the system is developed to document the planned remediation actions for correcting	Functional	Intersects With	Risk Register	RSK-04.1	Mechanisms exist to maintain a risk register that facilitates monitoring and reporting of risks.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.12.02.a.02	Plan of Action and Milestones	a plan of action and milestones for the system is developed to reduce or eliminate known system vulnerabilities.	Functional	Intersects With	Non-Compliance Oversight	CPL-01.1	Mechanisms exist to document and review instances of non-compliance with statutory, regulatory and/or contractual obligations to develop appropriate risk mitigation actions.	5	Updated in 2026.2	
A.03.12.02.a.02	Plan of Action and Milestones	a plan of action and milestones for the system is developed to reduce or eliminate known system vulnerabilities.	Functional	Intersects With	Capabilities Deficiency Tracking	IAQ-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum: (1) Deficiency tracking number;	5		
A.03.12.02.a.02	Plan of Action and Milestones	a plan of action and milestones for the system is developed to reduce or eliminate known system vulnerabilities.	Functional	Intersects With	Risk Register	RSK-04.1	Mechanisms exist to maintain a risk register that facilitates monitoring and reporting of risks.	5	Updated in 2026.2	
A.03.12.02.a.02	Plan of Action and Milestones	a plan of action and milestones for the system is developed to reduce or eliminate known system vulnerabilities.	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	5	Updated in 2026.2	
A.03.12.02.a.02	Plan of Action and Milestones	a plan of action and milestones for the system is developed to reduce or eliminate known system vulnerabilities.	Functional	Intersects With	Vulnerability Remediation Process	VPM-02	Mechanisms exist to ensure that vulnerabilities are properly identified, tracked and remediated.	5	Updated in 2026.2	
A.03.12.02.a.02	Plan of Action and Milestones	a plan of action and milestones for the system is developed to reduce or eliminate known system vulnerabilities.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	5	Updated in 2026.2	
A.03.12.02.b.01	Plan of Action and Milestones	the existing plan of action and milestones is updated based on the findings from security assessments.	Functional	Intersects With	Capabilities Deficiency Tracking	IAQ-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology)	5		
A.03.12.02.b.02	Plan of Action and Milestones	the existing plan of action and milestones is updated based on the findings from audits or reviews.	Functional	Intersects With	Capabilities Deficiency Tracking	IAQ-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology)	5		
A.03.12.02.b.03	Plan of Action and Milestones	the existing plan of action and milestones is updated based on the findings from continuous monitoring activities.	Functional	Intersects With	Capabilities Deficiency Tracking	IAQ-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology)	5		
03.12.03	Continuous Monitoring	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.12.03[01]	Continuous Monitoring	a system-level continuous monitoring strategy is developed.	Functional	Intersects With	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	5		
A.03.12.03[01]	Continuous Monitoring	a system-level continuous monitoring strategy is developed.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	Updated in 2026.2	
A.03.12.03[01]	Continuous Monitoring	a system-level continuous monitoring strategy is developed.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	Updated in 2026.2	
A.03.12.03[01]	Continuous Monitoring	a system-level continuous monitoring strategy is developed.	Functional	Intersects With	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive	5	Updated in 2026.2	
A.03.12.03[01]	Continuous Monitoring	a system-level continuous monitoring strategy is developed.	Functional	Intersects With	Measures of Performance	GOV-05	Mechanisms exist to develop, report and monitor Security, Compliance & Resilience Program (SCRPR) measures of performance.	5	Updated in 2026.2	
A.03.12.03[01]	Continuous Monitoring	a system-level continuous monitoring strategy is developed.	Functional	Intersects With	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.12.03[01]	Continuous Monitoring	a system-level continuous monitoring strategy is developed.	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	5	Updated in 2026.2	
A.03.12.03[01]	Continuous Monitoring	a system-level continuous monitoring strategy is developed.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to:	5	Updated in 2026.2	
A.03.12.03[01]	Continuous Monitoring	a system-level continuous monitoring strategy is developed.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to:	5	Updated in 2026.2	
A.03.12.03[01]	Continuous Monitoring	a system-level continuous monitoring strategy is developed.	Functional	Intersects With	Continuous Monitoring Plan	TDA-09.1	Mechanisms exist to require the developers of Technology Assets, Applications and/or Services (TAAS) to produce a plan	5	Updated in 2026.2	
A.03.12.03[02]	Continuous Monitoring	a system-level continuous monitoring strategy is implemented.	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to require system developers/integrators to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5		
A.03.12.03[03]	Continuous Monitoring	ongoing monitoring is included in the continuous monitoring strategy.	Functional	Intersects With	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	5		
A.03.12.03[04]	Continuous Monitoring	security assessments are included in the continuous monitoring strategy.	Functional	Intersects With	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	5		
03.12.04	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.12.05	Information Exchange	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.12.05.ODP[01]	Information Exchange	one or more of the following PARAMETER VALUES are selected: (interconnection security agreements; information exchange security agreements; memoranda of understanding or the frequency at which to review and update agreements is defined.	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each	5		
A.03.12.05.ODP[02]	Information Exchange	the exchange of CUI between the system and other systems is approved using <A.03.12.05.ODP[01]: SELECTED PARAMETER VALUES>.	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each	5		
A.03.12.05.a[01]	Information Exchange	the exchange of CUI between the system and other systems is approved using <A.03.12.05.ODP[01]: SELECTED PARAMETER VALUES>.	Functional	Intersects With	Transfer Authorizations	DCH-14.2	Mechanisms exist to verify that individuals or Technology Assets, Applications and/or Services (TAAS) transferring data	8	Updated in 2026.2	US DoD ODP Value: requirements as described in
A.03.12.05.a[01]	Information Exchange	the exchange of CUI between the system and other systems is approved using <A.03.12.05.ODP[01]: SELECTED PARAMETER VALUES>.	Functional	Intersects With	Data Access Mapping	DCH-14.3	Mechanisms exist to leverage data-specific Access Control Lists (ACL) or Interconnection Security Agreements (ISAs) to	8	Updated in 2026.2	US DoD ODP Value: requirements as described in
A.03.12.05.a[01]	Information Exchange	the exchange of CUI between the system and other systems is approved using <A.03.12.05.ODP[01]: SELECTED PARAMETER VALUES>.	Functional	Intersects With	Access Agreements	HRS-06	Mechanisms exist to require internal and third-party users to sign appropriate access agreements prior to being granted access.	8	Updated in 2026.2	US DoD ODP Value: requirements as described in the contract
A.03.12.05.a[01]	Information Exchange	the exchange of CUI between the system and other systems is approved using <A.03.12.05.ODP[01]: SELECTED PARAMETER VALUES>.	Functional	Intersects With	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	8	Updated in 2026.2	US DoD ODP Value: requirements as described in the contract
A.03.12.05.a[01]	Information Exchange	the exchange of CUI between the system and other systems is approved using <A.03.12.05.ODP[01]: SELECTED PARAMETER VALUES>.	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each interconnection: (1) Interface characteristics;	8		US DoD ODP Value: requirements as described in the contract
A.03.12.05.a[02]	Information Exchange	the exchange of CUI between the system and other systems is managed using <A.03.12.05.ODP[01]: SELECTED PARAMETER VALUES>.	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each interconnection:	8		US DoD ODP Value: requirements as described in the contract
A.03.12.05.b[01]	Information Exchange	interface characteristics for each system are documented as part of the exchange agreements.	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each interconnection:	5		
A.03.12.05.b[02]	Information Exchange	security requirements for each system are documented as part of the exchange agreements.	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each interconnection:	5		
A.03.12.05.b[03]	Information Exchange	responsibilities for each system are documented as part of the exchange agreements.	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each interconnection: (1) Interface characteristics;	5		
A.03.12.05.c[01]	Information Exchange	exchange agreements are reviewed <A.03.12.05.ODP[02]: frequency>.	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each interconnection: (1) Interface characteristics;	8		US DoD ODP Value: at least every 12 months
A.03.12.05.c[02]	Information Exchange	exchange agreements are updated <A.03.12.05.ODP[02]: frequency>.	Functional	Intersects With	Interconnection Security Agreements (ISAs)	NET-05	Mechanisms exist to authorize connections from systems to other systems using Interconnection Security Agreements (ISAs), or similar methods, that document, for each interconnection: (1) Interface characteristics;	8		US DoD ODP Value: at least every 12 months
03.13.01	Boundary Protection	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.13.01.a[01]	Boundary Protection	communications at external managed interfaces to the system are monitored.	Functional	Intersects With	Intrusion Detection & Prevention Systems (IDS & IPS)	MON-01.1	Mechanisms exist to implement Intrusion Detection / Prevention Systems (IDS / IPS) technologies on critical systems, key network segments and network choke points.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.13.01.a[01]	Boundary Protection	communications at external managed interfaces to the system are monitored.	Functional	Intersects With	Inbound & Outbound Communications Traffic	MON-01.3	Mechanisms exist to continuously monitor inbound and outbound communications traffic for unusual or unauthorized activities or conditions.	5		
A.03.13.01.a[02]	Boundary Protection	communications at external managed interfaces to the system are controlled.	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	5	Updated in 2026.2	
A.03.13.01.a[02]	Boundary Protection	communications at external managed interfaces to the system are controlled.	Functional	Intersects With	Boundary Protection	NET-03	Mechanisms exist to monitor and control communications at the external network boundary and at key internal boundaries	5		
A.03.13.01.a[02]	Boundary Protection	communications at external managed interfaces to the system are controlled.	Functional	Intersects With	Data Flow Enforcement - Access Control Lists (ACLs)	NET-04	Mechanisms exist to implement and govern Access Control Lists (ACLs) to provide data flow enforcement that explicitly restrict network traffic to only what is authorized.	5	Updated in 2026.2	
A.03.13.01.a[02]	Boundary Protection	communications at external managed interfaces to the system are controlled.	Functional	Intersects With	Deny Traffic by Default & Allow Traffic by Exception	NET-04.1	Mechanisms exist to configure firewall and router configurations to deny network traffic by default and allow network traffic by exception (e.g., deny all, permit by exception).	5	Updated in 2026.2	
A.03.13.01.a[02]	Boundary Protection	communications at external managed interfaces to the system are controlled.	Functional	Intersects With	Network Intrusion Detection / Prevention Systems (NIDS / NIPS)	NET-08	Mechanisms exist to employ Network Intrusion Detection / Prevention Systems (NIDS/NIPS) to detect and/or prevent intrusions into the network.	5	Updated in 2026.2	
A.03.13.01.a[03]	Boundary Protection	communications at key internal managed interfaces within the system are monitored.	Functional	Intersects With	Inbound & Outbound Communications Traffic	MON-01.3	Mechanisms exist to continuously monitor inbound and outbound communications traffic for unusual or unauthorized activities or conditions.	5		
A.03.13.01.a[04]	Boundary Protection	communications at key internal managed interfaces within the system are controlled.	Functional	Intersects With	Boundary Protection	NET-03	Mechanisms exist to monitor and control communications at the external network boundary and at key internal boundaries within the network.	5		
A.03.13.01.b	Boundary Protection	subnetworks are implemented for publicly accessible system components that are physically or logically separated from internal networks.	Functional	Intersects With	Layered Network Defenses	NET-02	Mechanisms exist to implement security functions as a layered structure that minimizes interactions between layers of the design and avoids any dependence by lower layers on the functionality or correctness of higher layers.	5	Updated in 2026.2	
A.03.13.01.b	Boundary Protection	subnetworks are implemented for publicly accessible system components that are physically or logically separated from internal networks.	Functional	Intersects With	Boundary Protection	NET-03	Mechanisms exist to monitor and control communications at the external network boundary and at key internal boundaries within the network.	5	Updated in 2026.2	
A.03.13.01.b	Boundary Protection	subnetworks are implemented for publicly accessible system components that are physically or logically separated from internal networks.	Functional	Intersects With	Separate Subnet for Connecting to Different Security Domains	NET-03.8	Mechanisms exist to implement separate network addresses (e.g., different subnets) to connect to systems in different security domains.	5	Updated in 2026.2	
A.03.13.01.b	Boundary Protection	subnetworks are implemented for publicly accessible system components that are physically or logically separated from internal networks.	Functional	Intersects With	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network.	5		
A.03.13.01.b	Boundary Protection	subnetworks are implemented for publicly accessible system components that are physically or logically separated from internal networks.	Functional	Intersects With	Sensitive / Regulated Data Enclave (Secure Zone)	NET-06.3	Mechanisms exist to implement segmentation controls to restrict inbound and outbound connectivity for sensitive and/or regulated data enclaves (secure zones).	5	Updated in 2026.2	
A.03.13.01.b	Boundary Protection	subnetworks are implemented for publicly accessible system components that are physically or logically separated from internal networks.	Functional	Intersects With	DMZ Networks	NET-08.1	Mechanisms exist to monitor De-Militarized Zone (DMZ) network segments to separate untrusted networks from trusted networks.	5	Updated in 2026.2	
A.03.13.01.c	Boundary Protection	external system connections are only made through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.	Functional	Intersects With	Boundary Protection	NET-03	Mechanisms exist to monitor and control communications at the external network boundary and at key internal boundaries within the network.	5		
A.03.13.01.c	Boundary Protection	external system connections are only made through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.	Functional	Intersects With	Data Flow Enforcement - Access Control Lists (ACLs)	NET-04	Mechanisms exist to implement and govern Access Control Lists (ACLs) to provide data flow enforcement that explicitly restrict network traffic to only what is authorized.	5	Updated in 2026.2	
A.03.13.01.c	Boundary Protection	external system connections are only made through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and	5	Updated in 2026.2	
A.03.13.01.c	Boundary Protection	external system connections are only made through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture.	Functional	Intersects With	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience	5	Updated in 2026.2	
03.13.02	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.13.03	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.13.04	Information in Shared System Resources	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.13.04[01]	Information in Shared System Resources	unauthorized information transfer via shared system resources is prevented.	Functional	Intersects With	Information In Shared Resources	SEA-05	Mechanisms exist to prevent unauthorized and unintended information transfer via shared system resources.	5		
A.03.13.04[02]	Information in Shared System Resources	unintended information transfer via shared system resources is prevented.	Functional	Intersects With	Information In Shared Resources	SEA-05	Mechanisms exist to prevent unauthorized and unintended information transfer via shared system resources.	5		
03.13.05	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.13.06	Network Communications -	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.13.06[01]	Network Communications -	network communications traffic is denied by default.	Functional	Intersects With	Deny Traffic by Default & Allow Traffic by	NET-04.1	Mechanisms exist to configure firewall and router configurations to deny network traffic by default and allow	5		
A.03.13.06[02]	Network Communications -	network communications traffic is allowed by exception.	Functional	Intersects With	Deny Traffic by Default & Allow Traffic by	NET-04.1	Mechanisms exist to configure firewall and router configurations to deny network traffic by default and allow	5		
03.13.07	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.13.08	Transmission and Storage Confidentiality	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.13.08[01]	Transmission and Storage Confidentiality	cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI during transmission.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10		
A.03.13.08[01]	Transmission and Storage Confidentiality	cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI during transmission.	Functional	Intersects With	Transmission Confidentiality	CRY-03	Cryptographic mechanisms exist to protect the confidentiality of data being transmitted.	5		
A.03.13.08[02]	Transmission and Storage Confidentiality	cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI while in storage.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public	10		
A.03.13.08[02]	Transmission and Storage Confidentiality	cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI while in storage.	Functional	Subset Of	Alternate Physical Protection	CRY-01.1	Cryptographic mechanisms exist to prevent unauthorized disclosure of information as an alternative to physical	10	Updated in 2026.2	
A.03.13.08[02]	Transmission and Storage Confidentiality	cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI while in storage.	Functional	Intersects With	Encrypting Data At Rest	CRY-05	Cryptographic mechanisms exist to prevent unauthorized disclosure of data at rest.	5		
A.03.13.08[02]	Transmission and Storage Confidentiality	cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI while in storage.	Functional	Intersects With	Storage Media	CRY-05.1	Cryptographic mechanisms exist to protect the confidentiality and integrity of sensitive and/or regulated data residing on	5	Updated in 2026.2	
03.13.09	Network Disconnect	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.13.09.ODP[01]	Network Disconnect	the time period of inactivity after which the system terminates a network connection associated with a communications session is defined.	Functional	Intersects With	Network Connection Termination	NET-07	Mechanisms exist to terminate network connections at the end of a session or after an organization-defined time period of inactivity.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.13.09	Network Disconnect	the network connection associated with a communications session is terminated at the end of the session or after Determine If:	Functional	Intersects With	Network Connection Termination	NET-07	Mechanisms exist to terminate network connections at the end of a session or after an organization-defined time period of	8		US DoD ODP Value: no longer than 15 minutes
03.13.10	Cryptographic Key Establishment and Management	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.13.10.ODP[01]	Cryptographic Key Establishment and Management	requirements for key generation, distribution, storage, access, and destruction are defined.	Functional	Intersects With	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability	5		
A.03.13.10[01]	Cryptographic Key Establishment and Management	cryptographic keys are established in the system in accordance with the following key management requirements: <A.03.13.10.ODP[01]: requirements>.	Functional	Intersects With	Public Key Infrastructure (PKI)	CRY-08	Mechanisms exist to securely implement an internal Public Key Infrastructure (PKI) infrastructure or obtain PKI services from a reputable PKI service provider.	8	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, establish a policy and
A.03.13.10[01]	Cryptographic Key Establishment and Management	cryptographic keys are established in the system in accordance with the following key management requirements: <A.03.13.10.ODP[01]: requirements>.	Functional	Intersects With	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	8		US DoD ODP Value: Guidance: At a minimum, establish a policy and
A.03.13.10[02]	Cryptographic Key Establishment and Management	cryptographic keys are managed in the system in accordance with the following key management requirements: <A.03.13.10.ODP[01]: requirements>.	Functional	Intersects With	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	8		US DoD ODP Value: Guidance: At a minimum, establish a policy and
A.03.13.10[02]	Cryptographic Key Establishment and Management	cryptographic keys are managed in the system in accordance with the following key management requirements: <A.03.13.10.ODP[01]: requirements>.	Functional	Intersects With	Cryptographic Key Loss or Change	CRY-09.3	Mechanisms exist to ensure the availability of information in the event of the loss of cryptographic keys by individual users.	8	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, establish a policy and
A.03.13.10[02]	Cryptographic Key Establishment and Management	cryptographic keys are managed in the system in accordance with the following key management requirements: <A.03.13.10.ODP[01]: requirements>.	Functional	Intersects With	Control & Distribution of Cryptographic Keys	CRY-09.4	Mechanisms exist to facilitate the secure distribution of symmetric and asymmetric cryptographic keys using industry recognized key management technology and processes.	8	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, establish a policy and procedure in line with the latest Cryptographic key management guidance
03.13.11	Cryptographic Protection	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.13.11.ODP[01]	Cryptographic Protection	the types of cryptography for protecting the confidentiality of CUI are defined.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10		
A.03.13.11.ODP[01]	Cryptographic Protection	the types of cryptography for protecting the confidentiality of CUI are defined.	Functional	Intersects With	Transmission Confidentiality	CRY-03	Cryptographic mechanisms exist to protect the confidentiality of data being transmitted.	5		
A.03.13.11.ODP[01]	Cryptographic Protection	the types of cryptography for protecting the confidentiality of CUI are defined.	Functional	Intersects With	Encrypting Data At Rest	CRY-05	Cryptographic mechanisms exist to prevent unauthorized disclosure of data at rest.	5		
A.03.13.11	Cryptographic Protection	the following types of cryptography are implemented to protect the confidentiality of CUI: <A.03.13.11.ODP[01]: types of the following types of cryptography are implemented to protect the confidentiality of CUI: <A.03.13.11.ODP[01]: types of cryptography>.	Functional	Subset Of	Baseline Tailoring	CFG-02.9	Mechanisms exist to allow baseline controls to be specialized or customized by applying a defined set of tailoring actions	10	Updated in 2026.2	US DoD ODP Value: FIPS Validated Cryptography
A.03.13.11	Cryptographic Protection	the following types of cryptography are implemented to protect the confidentiality of CUI: <A.03.13.11.ODP[01]: types of cryptography>.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10		US DoD ODP Value: FIPS Validated Cryptography (https://csrc.nist.gov/Projects
A.03.13.11	Cryptographic Protection	the following types of cryptography are implemented to protect the confidentiality of CUI: <A.03.13.11.ODP[01]: types of the following types of cryptography are implemented to protect the confidentiality of CUI: <A.03.13.11.ODP[01]: types of cryptography>.	Functional	Intersects With	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public	8	Updated in 2026.2	US DoD ODP Value: FIPS Validated Cryptography
A.03.13.11	Cryptographic Protection	the following types of cryptography are implemented to protect the confidentiality of CUI: <A.03.13.11.ODP[01]: types of the following types of cryptography are implemented to protect the confidentiality of CUI: <A.03.13.11.ODP[01]: types of cryptography>.	Functional	Intersects With	Cryptographic Cipher Suites and Protocols	CRY-01.5	Mechanisms exist to identify, document and review deployed cryptographic cipher suites and protocols to proactively	8	Updated in 2026.2	US DoD ODP Value: FIPS Validated Cryptography
A.03.13.11	Cryptographic Protection	the following types of cryptography are implemented to protect the confidentiality of CUI: <A.03.13.11.ODP[01]: types of cryptography>.	Functional	Intersects With	Transmission Confidentiality	CRY-03	Cryptographic mechanisms exist to protect the confidentiality of data being transmitted.	8		US DoD ODP Value: FIPS Validated Cryptography (https://csrc.nist.gov/Projects /Cryptographic-ModuleValidation-Program/Validated-Modules)
A.03.13.11	Cryptographic Protection	the following types of cryptography are implemented to protect the confidentiality of CUI: <A.03.13.11.ODP[01]: types of cryptography>.	Functional	Intersects With	Encrypting Data At Rest	CRY-05	Cryptographic mechanisms exist to prevent unauthorized disclosure of data at rest.	8		US DoD ODP Value: FIPS Validated Cryptography (https://csrc.nist.gov/Projects /Cryptographic-ModuleValidation-Program/Validated-Modules)
03.13.12	Collaborative Computing Devices and Applications	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.13.12.ODP[01]	Collaborative Computing Devices and Applications	exceptions where remote activation is to be allowed are defined.	Functional	Intersects With	Collaborative Computing Devices	END-14	Mechanisms exist to unplug or prohibit the remote activation of collaborative computing devices with the following exceptions: (1) Networked whiteboards; (2) Video teleconference cameras; and (3) Teleconference microphones.	5		
A.03.13.12.a	Collaborative Computing Devices and Applications	the remote activation of collaborative computing devices and applications is prohibited with the following exceptions: <A.03.13.12.ODP[01]: exceptions>.	Functional	Intersects With	Collaborative Computing Devices	END-14	Mechanisms exist to unplug or prohibit the remote activation of collaborative computing devices with the following exceptions: (1) Networked whiteboards; (2) Video teleconference cameras; and (3) Teleconference microphones.	8		US DoD ODP Value: only as enumerated and justified in the System Security Plan before such remote activation occurs, and only when there are no other options, and the
A.03.13.12.b	Collaborative Computing Devices and Applications	an explicit indication of use is provided to users who are physically present at the devices.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	Updated in 2026.2	
A.03.13.12.b	Collaborative Computing Devices and Applications	an explicit indication of use is provided to users who are physically present at the devices.	Functional	Intersects With	Explicit Indication Of Use	END-14.6	Mechanisms exist to configure collaborative computing devices to provide physically-present individuals with an explicit indication of use.	5		
03.13.13	Mobile Code	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.13.13.a[01]	Mobile Code	acceptable mobile code is defined.	Functional	Intersects With	Explicitly Allow / Deny Applications	CFG-03.3	Mechanisms exist to explicitly allow (allowlist / whitelist) and/or block (denylist / blacklist) applications that are authorized to execute on systems.	5	Updated in 2026.2	
A.03.13.13.a[01]	Mobile Code	acceptable mobile code is defined.	Functional	Intersects With	Mobile Code	END-10	Mechanisms exist to address mobile code / operating system-independent applications.	5		
A.03.13.13.a[02]	Mobile Code	acceptable mobile code technologies are defined.	Functional	Intersects With	Explicitly Allow / Deny Applications	CFG-03.3	Mechanisms exist to explicitly allow (allowlist / whitelist) and/or block (denylist / blacklist) applications that are authorized to execute on systems.	5	Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.13.13.a[02]	Mobile Code	acceptable mobile code technologies are defined.	Functional	Intersects With	Software Usage Restrictions	CFG-04	Mechanisms exist to enforce software usage restrictions to comply with applicable contract agreements and copyright	5	Updated in 2026.2	
A.03.13.13.a[02]	Mobile Code	acceptable mobile code technologies are defined.	Functional	Intersects With	Open Source Software	CFG-04.1	Mechanisms exist to establish parameters for the secure use of open source software.	5	Updated in 2026.2	
A.03.13.13.a[02]	Mobile Code	acceptable mobile code technologies are defined.	Functional	Intersects With	User-Installed Software	CFG-05	Mechanisms exist to restrict the ability of non-privileged users to install unauthorized software.	5	Updated in 2026.2	
A.03.13.13.a[02]	Mobile Code	acceptable mobile code technologies are defined.	Functional	Intersects With	Mobile Code	END-10	Mechanisms exist to address mobile code / operating system-independent applications.	5		
A.03.13.13.b[01]	Mobile Code	the use of mobile code is authorized.	Functional	Intersects With	Explicitly Allow / Deny Applications	CFG-03.3	Mechanisms exist to explicitly allow (allowlist / whitelist) and/or block (denylist / blacklist) applications that are authorized to execute on systems.	5	Updated in 2026.2	
A.03.13.13.b[01]	Mobile Code	the use of mobile code is authorized.	Functional	Intersects With	Software Usage Restrictions	CFG-04	Mechanisms exist to enforce software usage restrictions to comply with applicable contract agreements and copyright	5	Updated in 2026.2	
A.03.13.13.b[01]	Mobile Code	the use of mobile code is authorized.	Functional	Intersects With	Mobile Code	END-10	Mechanisms exist to address mobile code / operating system-independent applications.	5		
A.03.13.13.b[02]	Mobile Code	the use of mobile code is monitored.	Functional	Intersects With	Automated Central Management &	CFG-02.2	Automated mechanisms exist to govern and report on baseline configurations of Technology Assets, Applications	5	Updated in 2026.2	
A.03.13.13.b[03]	Mobile Code	the use of mobile code is controlled.	Functional	Intersects With	Explicitly Allow / Deny Applications	CFG-03.3	Mechanisms exist to explicitly allow (allowlist / whitelist) and/or block (denylist / blacklist) applications that are authorized to execute on systems.	5	Updated in 2026.2	
A.03.13.13.b[03]	Mobile Code	the use of mobile code is controlled.	Functional	Intersects With	Software Usage Restrictions	CFG-04	Mechanisms exist to enforce software usage restrictions to comply with applicable contract agreements and copyright laws.	5	Updated in 2026.2	
A.03.13.13.b[03]	Mobile Code	the use of mobile code is controlled.	Functional	Intersects With	Open Source Software	CFG-04.1	Mechanisms exist to establish parameters for the secure use of open source software.	5	Updated in 2026.2	
A.03.13.13.b[03]	Mobile Code	the use of mobile code is controlled.	Functional	Intersects With	User-Installed Software	CFG-05	Mechanisms exist to restrict the ability of non-privileged users to install unauthorized software.	5	Updated in 2026.2	
A.03.13.13.b[03]	Mobile Code	the use of mobile code is controlled.	Functional	Intersects With	Mobile Code	END-10	Mechanisms exist to address mobile code / operating system-independent applications.	5		
03.13.14	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.13.15	Session Authenticity	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.13.15	Session Authenticity	the authenticity of communications sessions is protected.	Functional	Intersects With	Session Integrity	NET-09	Mechanisms exist to protect the authenticity and integrity of communications sessions.	5		
03.13.16	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.14.01	Flaw Remediation	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.14.01.ODP[01]	Flaw Remediation	the time period within which to install security-relevant software updates after the release of the updates is defined.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services	5		
A.03.14.01.ODP[02]	Flaw Remediation	the time period within which to install security-relevant firmware updates after the release of the updates is defined.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services	5		
A.03.14.01.a[01]	Flaw Remediation	system flaws are identified.	Functional	Intersects With	Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology)	5	Updated in 2026.2	
A.03.14.01.a[01]	Flaw Remediation	system flaws are identified.	Functional	Intersects With	Technology Development &	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and	5	Updated in 2026.2	
A.03.14.01.a[01]	Flaw Remediation	system flaws are identified.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to:	5	Updated in 2026.2	
A.03.14.01.a[01]	Flaw Remediation	system flaws are identified.	Functional	Intersects With	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system	5	Updated in 2026.2	
A.03.14.01.a[01]	Flaw Remediation	system flaws are identified.	Functional	Intersects With	Vulnerability Disclosure Program (VDP)	THR-06	Mechanisms exist to establish a Vulnerability Disclosure Program (VDP) to assist with the secure development and maintenance of Technology Assets, Applications and/or Services (TAAS) that receives unsolicited input from the public about vulnerabilities in organizational TAAS.	5	Updated in 2026.2	
A.03.14.01.a[01]	Flaw Remediation	system flaws are identified.	Functional	Intersects With	Vulnerability & Patch Management Program (VPMF)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	5	Updated in 2026.2	
A.03.14.01.a[01]	Flaw Remediation	system flaws are identified.	Functional	Intersects With	Attack Surface Scope	VPM-01.1	Mechanisms exist to define and manage the scope for its attack surface management activities.	5	Updated in 2026.2	
A.03.14.01.a[01]	Flaw Remediation	system flaws are identified.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	5	Updated in 2026.2	
A.03.14.01.a[02]	Flaw Remediation	system flaws are reported.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability	5	Updated in 2026.2	
A.03.14.01.a[02]	Flaw Remediation	system flaws are reported.	Functional	Intersects With	Vulnerability Disclosure Program (VDP)	THR-06	Mechanisms exist to establish a Vulnerability Disclosure Program (VDP) to assist with the secure development and maintenance of Technology Assets, Applications and/or	5	Updated in 2026.2	
A.03.14.01.a[02]	Flaw Remediation	system flaws are reported.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and	5	Updated in 2026.2	
A.03.14.01.a[03]	Flaw Remediation	system flaws are corrected.	Functional	Intersects With	Continuous Vulnerability Remediation Activities	VPM-04	Mechanisms exist to address new threats and vulnerabilities on an ongoing basis and ensure assets are protected against known attacks.	5		
A.03.14.01.a[03]	Flaw Remediation	system flaws are corrected.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	5		
A.03.14.01.b[01]	Flaw Remediation	security-relevant software updates are installed within <A.03.14.01.ODP[01: time period> of the release of the updates.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	8		US DoD ODP Value: thirty (30) days for high-risk flaws (including both critical and high), 90 days for moderate-risk flaws, and 180 days for

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.14.01.b[02]	Flaw Remediation	security-relevant firmware updates are installed within <A.03.14.01.ODP[02]: time period> of the release of the updates.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	8		US DoD ODP Value: thirty (30) days for high-risk flaws (including both critical and
03.14.02	Malicious Code Protection	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.14.02.ODP[01]	Malicious Code Protection	the frequency at which malicious code protection mechanisms perform scans is defined.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antimalware technologies to detect and eradicate malicious code.	5		
A.03.14.02.a[01]	Malicious Code Protection	malicious code protection mechanisms are implemented at system entry and exit points to detect malicious code.	Functional	Intersects With	Endpoint Device Management (EDM)	END-01	Mechanisms exist to facilitate the implementation of Endpoint Device Management (EDM) controls.	5	Updated in 2026.2	
A.03.14.02.a[01]	Malicious Code Protection	malicious code protection mechanisms are implemented at system entry and exit points to detect malicious code.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antimalware technologies to detect and eradicate malicious code.	5		
A.03.14.02.a[01]	Malicious Code Protection	malicious code protection mechanisms are implemented at system entry and exit points to detect malicious code.	Functional	Intersects With	Centralized Management of	END-04.3	Mechanisms exist to centrally-manage antimalware technologies.	5	Updated in 2026.2	
A.03.14.02.a[01]	Malicious Code Protection	malicious code protection mechanisms are implemented at system entry and exit points to detect malicious code.	Functional	Intersects With	Always On Protection	END-04.7	Mechanisms exist to ensure that anti-malware technologies are continuously running in real-time and cannot be disabled or altered by non-privileged users, unless specifically	5	Updated in 2026.2	
A.03.14.02.a[02]	Malicious Code Protection	malicious code protection mechanisms are implemented at system entry and exit points to detect malicious code.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antimalware technologies to detect and eradicate malicious code.	5		
A.03.14.02.b	Malicious Code Protection	malicious code protection mechanisms are updated as new releases are available in accordance with configuration management policy and procedures.	Functional	Intersects With	Automatic Antimalware Signature Updates	END-04.1	Automated mechanisms exist to update antimalware technologies, including signature definitions.	5		
A.03.14.02.c.01[01]	Malicious Code Protection	malicious code protection mechanisms are configured to perform scans of the system <A.03.14.02.ODP[01]: frequency>.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antimalware technologies to detect and eradicate malicious code.	8	Updated in 2026.2	US DoD ODP Value: at least weekly
A.03.14.02.c.01[01]	Malicious Code Protection	malicious code protection mechanisms are configured to perform real-time scans of files from external sources at endpoints or system entry and exit points as the files are	Functional	Intersects With	Always On Protection	END-04.7	Mechanisms exist to ensure that anti-malware technologies are continuously running in real-time and cannot be disabled or altered by non-privileged users, unless specifically authorized by management on a case-by-case basis for a limited time period.	8		US DoD ODP Value: at least weekly
A.03.14.02.c.01[02]	Malicious Code Protection	malicious code protection mechanisms are configured to block malicious code, quarantine malicious code, or take other actions in response to malicious code detection.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antimalware technologies to detect and eradicate malicious code.	5		
03.14.03	Security Alerts, Advisories, and Directives	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.14.03.a	Security Alerts, Advisories, and Directives	system security alerts, advisories, and directives from external organizations are received on an ongoing basis.	Functional	Intersects With	Impact-Level Prioritization	RSK-02.1	Mechanisms exist to prioritize the impact level for Technology Assets, Applications and/or Services (TAAS) to prevent potential disruptions.	5		
A.03.14.03.a	Security Alerts, Advisories, and Directives	system security alerts, advisories, and directives from external organizations are received on an ongoing basis.	Functional	Intersects With	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures, selection of security solutions, monitoring, threat hunting, response and recovery activities.	5	Updated in 2026.2	
A.03.14.03.a	Security Alerts, Advisories, and Directives	system security alerts, advisories, and directives from external organizations are received on an ongoing basis.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to	5		
A.03.14.03.a	Security Alerts, Advisories, and Directives	system security alerts, advisories, and directives from external organizations are received on an ongoing basis.	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5		
A.03.14.03.a	Security Alerts, Advisories, and Directives	system security alerts, advisories, and directives from external organizations are received on an ongoing basis.	Functional	Intersects With	Threat Analysis	THR-10	Mechanisms exist to identify, assess, prioritize and document the potential impact(s) and likelihood(s) of applicable internal and external threats.	5		
A.03.14.03.b[01]	Security Alerts, Advisories, and Directives	internal security alerts, advisories, and directives are generated, as necessary.	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5		
A.03.14.03.b[02]	Security Alerts, Advisories, and Directives	internal security alerts, advisories, and directives are disseminated, as necessary.	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5		
03.14.04	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.14.05	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.14.06	System Monitoring	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.14.06.a.01[01]	System Monitoring	the system is monitored to detect attacks.	Functional	Subset Of	Host Intrusion Detection and Prevention Systems	END-07	Mechanisms exist to utilize Host-based Intrusion Detection / Prevention Systems (HIDS / HIPS), or similar technologies, to monitor for and protect against anomalous host activity.	10	Updated in 2026.2	
A.03.14.06.a.01[01]	System Monitoring	the system is monitored to detect attacks.	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10		
A.03.14.06.a.01[01]	System Monitoring	the system is monitored to detect attacks.	Functional	Subset Of	System Generated Alerts	MON-01.4	Mechanisms exist to generate, monitor, correlate and respond to alerts from physical, cybersecurity, data protection and	10	Updated in 2026.2	
A.03.14.06.a.01[01]	System Monitoring	the system is monitored to detect attacks.	Functional	Subset Of	Monitoring for Indicators of	MON-11.3	Automated mechanisms exist to identify and alert on Indicators of Compromise (IoC).	10	Updated in 2026.2	
A.03.14.06.a.01[01]	System Monitoring	the system is monitored to detect attacks.	Functional	Subset Of	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	10	Updated in 2026.2	
A.03.14.06.a.01[02]	System Monitoring	the system is monitored to detect indicators of potential attacks.	Functional	Subset Of	Host Intrusion Detection and	END-07	Mechanisms exist to utilize Host-based Intrusion Detection / Prevention Systems (HIDS / HIPS), or similar technologies, to	10	Updated in 2026.2	
A.03.14.06.a.01[02]	System Monitoring	the system is monitored to detect indicators of potential attacks.	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10		
A.03.14.06.a.01[02]	System Monitoring	the system is monitored to detect indicators of potential attacks.	Functional	Subset Of	System Generated Alerts	MON-01.4	Mechanisms exist to generate, monitor, correlate and respond to alerts from physical, cybersecurity, data protection and supply chain activities to achieve integrated situational	10	Updated in 2026.2	
A.03.14.06.a.01[02]	System Monitoring	the system is monitored to detect indicators of potential attacks.	Functional	Subset Of	Monitoring for Indicators of Compromise (IOC)	MON-11.3	Automated mechanisms exist to identify and alert on Indicators of Compromise (IoC).	10	Updated in 2026.2	
A.03.14.06.a.01[02]	System Monitoring	the system is monitored to detect indicators of potential attacks.	Functional	Subset Of	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	10	Updated in 2026.2	
A.03.14.06.a.02	System Monitoring	the system is monitored to detect unauthorized connections.	Functional	Intersects With	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.14.06.a.02	System Monitoring	the system is monitored to detect unauthorized connections.	Functional	Intersects With	Monitoring for Indicators of Compromise (IOC)	MON-11.3	Automated mechanisms exist to identify and alert on Indicators of Compromise (IoC).	5	Updated in 2026.2	
A.03.14.06.a.02	System Monitoring	the system is monitored to detect unauthorized connections.	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate	5	Updated in 2026.2	
A.03.14.06.b	System Monitoring	unauthorized use of the system is identified.	Functional	Intersects With	Host Intrusion Detection and Prevention Systems (HIDS / HIPS)	END-07	Mechanisms exist to utilize Host-based Intrusion Detection / Prevention Systems (HIDS / HIPS), or similar technologies, to monitor for and protect against anomalous host activity, including lateral movement across the network.	5	Updated in 2026.2	
A.03.14.06.b	System Monitoring	unauthorized use of the system is identified.	Functional	Intersects With	System Generated Alerts	MON-01.4	Mechanisms exist to generate, monitor, correlate and respond to alerts from physical, cybersecurity, data protection and	5	Updated in 2026.2	
A.03.14.06.b	System Monitoring	unauthorized use of the system is identified.	Functional	Intersects With	Monitoring for Indicators of Compromise (IOC)	MON-11.3	Automated mechanisms exist to identify and alert on Indicators of Compromise (IoC).	5	Updated in 2026.2	
A.03.14.06.b	System Monitoring	unauthorized use of the system is identified.	Functional	Intersects With	Inbound & Outbound Communications Traffic	MON-01.3	Mechanisms exist to continuously monitor inbound and outbound communications traffic for unusual or unauthorized activities or conditions.	5	Updated in 2026.2	
A.03.14.06.b	System Monitoring	unauthorized use of the system is identified.	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	5		
A.03.14.06.c[01]	System Monitoring	inbound communications traffic is monitored to detect unusual or unauthorized activities or conditions.	Functional	Intersects With	Inbound & Outbound Communications Traffic	MON-01.3	Mechanisms exist to continuously monitor inbound and outbound communications traffic for unusual or unauthorized activities or conditions.	5		
A.03.14.06.c[01]	System Monitoring	inbound communications traffic is monitored to detect unusual or unauthorized activities or conditions.	Functional	Intersects With	Network Intrusion Detection / Prevention Systems (NIDS / NIPS)	NET-08	Mechanisms exist to employ Network Intrusion Detection / Prevention Systems (NIDS/NIPS) to detect and/or prevent intrusions into the network.	5	Updated in 2026.2	
A.03.14.06.c[02]	System Monitoring	outbound communications traffic is monitored to detect unusual or unauthorized activities or conditions.	Functional	Intersects With	DNS & Content Filtering	NET-18	Mechanisms exist to force Internet-bound network traffic through a proxy device (e.g., Policy Enforcement Point (PEP)) for URL content filtering and DNS filtering to limit a user's ability to connect to dangerous or prohibited Internet sites.	5	Updated in 2026.2	
03.14.07	Withdrawn	N/A	Functional	No Relationship	N/A	N/A	N/A	0		
03.14.08	Information Management and Retention	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.14.08[01]	Information Management and Retention	CUI within the system is managed in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, guidelines, and operational requirements.	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	5		
A.03.14.08[02]	Information Management and Retention	CUI within the system is retained in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, guidelines, and operational requirements.	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	5		
A.03.14.08[03]	Information Management and Retention	CUI output from the system is managed in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, guidelines, and operational requirements.	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	5		
A.03.14.08[04]	Information Management and Retention	CUI output from the system is retained in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, guidelines, and operational requirements.	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	5		
03.15.01	Policy and Procedures	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.15.01.ODP[01]	Policy and Procedures	the frequency at which the policies and procedures for satisfying security requirements are reviewed and updated is	Functional	Intersects With	Periodic Review & Update of Security	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRPP), including policies, standards and	5		
A.03.15.01.a[01]	Policy and Procedures	policies needed to satisfy the security requirements for the protection of CUI are developed and documented.	Functional	Intersects With	Security, Compliance & Resilience Program (SCRPP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	5	Updated in 2026.2	
A.03.15.01.a[01]	Policy and Procedures	policies needed to satisfy the security requirements for the protection of CUI are developed and documented.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5		
A.03.15.01.a[02]	Policy and Procedures	policies needed to satisfy the security requirements for the protection of CUI are disseminated to organizational personnel or roles.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5		
A.03.15.01.a[03]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are developed and documented.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5		
A.03.15.01.a[03]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are developed and documented.	Functional	Intersects With	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	Updated in 2026.2	
A.03.15.01.a[03]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are developed and documented.	Functional	Intersects With	Select Controls	GOV-15.1	Mechanisms exist to compel data and/or process owners to select required security, compliance and resilience controls	5	Updated in 2026.2	
A.03.15.01.a[03]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are developed and documented.	Functional	Intersects With	Implement Controls	GOV-15.2	Mechanisms exist to compel data and/or process owners to implement required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	Updated in 2026.2	
A.03.15.01.a[03]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are developed and documented.	Functional	Intersects With	Assess Controls	GOV-15.3	Mechanisms exist to compel data and/or process owners to assess if required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	Updated in 2026.2	
A.03.15.01.a[03]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are developed and documented.	Functional	Intersects With	Authorize Technology Assets, Applications and/or Services (TAAS)	GOV-15.4	Mechanisms exist to compel data and/or process owners to obtain authorization for the production use of each Technology Asset, Application and/or Service (TAAS) under their control.	5	Updated in 2026.2	
A.03.15.01.a[03]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are developed and documented.	Functional	Intersects With	Monitor Controls	GOV-15.5	Mechanisms exist to compel data and/or process owners to monitor Technology Assets, Applications, Services and/or Data (TAASD) under their control on an ongoing basis for applicable threats and risks, as well as to ensure security.	5	Updated in 2026.2	
A.03.15.01.a[03]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are developed and documented.	Functional	Intersects With	Operations Security	OPS-01	Mechanisms exist to facilitate the implementation of operational security controls.	5	Updated in 2026.2	
A.03.15.01.a[03]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are developed and documented.	Functional	Intersects With	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	5		
A.03.15.01.a[04]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are disseminated to organizational personnel or roles.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5		
A.03.15.01.a[04]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are disseminated to organizational personnel or roles.	Functional	Intersects With	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.15.01.a[04]	Policy and Procedures	procedures needed to satisfy the security requirements for the protection of CUI are disseminated to organizational personnel or roles.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the	5	Updated in 2026.2	
A.03.15.01.b[01]	Policy and Procedures	policies and procedures are reviewed <A.03.15.01.ODP[01]: frequency>.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRPR), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and	8		US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.15.01.b[02]	Policy and Procedures	policies and procedures are updated <A.03.15.01.ODP[01]: frequency>.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRPR), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	8		US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
03.15.02	System Security Plan	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.15.02.ODP[01]	System Security Plan	the frequency at which the system security plan is reviewed and updated is defined.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation	10		
A.03.15.02.a.01	System Security Plan	a system security plan that defines the constituent system components is developed.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications	10		
A.03.15.02.a.02	System Security Plan	a system security plan that identifies the information types processed, stored, and transmitted by the system is developed.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation	10		
A.03.15.02.a.03	System Security Plan	a system security plan that describes specific threats to the system that are of concern to the organization is developed.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, and	10		
A.03.15.02.a.04	System Security Plan	a system security plan that describes the operational environment for the system and any dependencies on or connections to other systems or system components is developed.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS);	10		
A.03.15.02.a.05	System Security Plan	a system security plan that provides an overview of the security requirements for the system is developed.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS);	10		
A.03.15.02.a.06	System Security Plan	a system security plan that describes the safeguards in place or planned for meeting the security requirements is developed.	Functional	Subset Of	Applied Security, Compliance and	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that:	10		
A.03.15.02.a.07	System Security Plan	a system security plan that identifies individuals that fulfill system roles and responsibilities is developed.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10		
A.03.15.02.a.08	System Security Plan	a system security plan that includes other relevant information necessary for the protection of CUI is developed.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10		
A.03.15.02.b[01]	System Security Plan	the system security plan is reviewed <A.03.15.02.ODP[01]: frequency>.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10		US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.15.02.b[02]	System Security Plan	the system security plan is updated <A.03.15.02.ODP[01]: frequency>.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10		US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.15.02.c	System Security Plan	the system security plan is protected from unauthorized disclosure.	Functional	Intersects With	Defining Access Authorizations for Sensitive / Regulated Data	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and/or physical access to sensitive and/or regulated data.	5		
A.03.15.02.c	System Security Plan	the system security plan is protected from unauthorized disclosure.	Functional	Intersects With	Disclosure of Information	DCH-03.1	Mechanisms exist to restrict the disclosure of sensitive and/or regulated data to authorized parties with a need to know.	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
03.15.03	Rules of Behavior	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.15.03.ODP[01]	Rules of Behavior	the frequency at which the rules of behavior are reviewed and updated is defined.	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	5		
A.03.15.03.a	Rules of Behavior	rules that describe responsibilities and expected behavior for system usage and protecting CUI are established.	Functional	Intersects With	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	5	Updated in 2026.2	
A.03.15.03.a	Rules of Behavior	rules that describe responsibilities and expected behavior for system usage and protecting CUI are established.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Updated in 2026.2	
A.03.15.03.a	Rules of Behavior	rules that describe responsibilities and expected behavior for system usage and protecting CUI are established.	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	5		
A.03.15.03.a	Rules of Behavior	rules that describe responsibilities and expected behavior for system usage and protecting CUI are established.	Functional	Intersects With	Social Media & Social Networking Restrictions	HRS-05.2	Mechanisms exist to define rules of behavior that contain explicit restrictions on the use of social media and networking sites, posting information on commercial websites and sharing account information.	5		
A.03.15.03.a	Rules of Behavior	rules that describe responsibilities and expected behavior for system usage and protecting CUI are established.	Functional	Intersects With	Technology Use Restrictions	HRS-05.3	Mechanisms exist to establish usage restrictions and implementation guidance for organizational technologies based on the potential to cause damage to Technology Assets.	5		
A.03.15.03.a	Rules of Behavior	rules that describe responsibilities and expected behavior for system usage and protecting CUI are established.	Functional	Intersects With	Use of Critical Technologies	HRS-05.4	Mechanisms exist to govern usage policies for critical technologies.	5	Updated in 2026.2	
A.03.15.03.a	Rules of Behavior	rules that describe responsibilities and expected behavior for system usage and protecting CUI are established.	Functional	Intersects With	Use of Mobile Devices	HRS-05.5	Mechanisms exist to manage business risks associated with permitting mobile device access to organizational resources.	5		
A.03.15.03.b	Rules of Behavior	rules are provided to individuals who require access to the system.	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing	5	Updated in 2026.2	
A.03.15.03.b	Rules of Behavior	rules are provided to individuals who require access to the system.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Updated in 2026.2	
A.03.15.03.b	Rules of Behavior	rules are provided to individuals who require access to the system.	Functional	Intersects With	User Awareness	HRS-03.1	Mechanisms exist to communicate with users about their roles and responsibilities to maintain a safe and secure working environment.	5	Updated in 2026.2	
A.03.15.03.b	Rules of Behavior	rules are provided to individuals who require access to the system.	Functional	Intersects With	Formal Indoctrination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	5	Updated in 2026.2	
A.03.15.03.b	Rules of Behavior	rules are provided to individuals who require access to the system.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5		
A.03.15.03.c	Rules of Behavior	a documented acknowledgement from individuals indicating that they have read, understand, and agree to abide by the	Functional	Intersects With	Policy Familiarization & Acknowledgement	HRS-05.7	Mechanisms exist to ensure personnel receive recurring familiarization with the organization's security, compliance	5		
A.03.15.03.c	Rules of Behavior	a documented acknowledgement from individuals indicating that they have read, understand, and agree to abide by the rules of behavior is received before authorizing access to CUI	Functional	Intersects With	Access Agreements	HRS-06	Mechanisms exist to require internal and third-party users to sign appropriate access agreements prior to being granted access.	5	Updated in 2026.2	
A.03.15.03.c	Rules of Behavior	a documented acknowledgement from individuals indicating that they have read, understand, and agree to abide by the rules of behavior is received before authorizing access to CUI	Functional	Intersects With	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both	5	Updated in 2026.2	
A.03.15.03.d[01]	Rules of Behavior	the rules of behavior are reviewed <A.03.15.03.ODP[01]: frequency>.	Functional	Intersects With	Periodic Review & Update of Security,	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRPR), including policies, standards and	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when
A.03.15.03.d[01]	Rules of Behavior	the rules of behavior are reviewed <A.03.15.03.ODP[01]: frequency>.	Functional	Intersects With	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents
A.03.15.03.d[01]	Rules of Behavior	the rules of behavior are reviewed <A.03.15.03.ODP[01]: frequency>.	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	8		US DoD ODP Value: at least every 12 months, or when there are significant incidents
A.03.15.03.d[02]	Rules of Behavior	the rules of behavior are updated <A.03.15.03.ODP[01]: frequency>.	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	8		US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.15.03.d[02]	Rules of Behavior	the rules of behavior are updated <A.03.15.03.ODP[01]: frequency>.	Functional	Intersects With	Policy Familiarization & Acknowledgement	HRS-05.7	Mechanisms exist to ensure personnel receive recurring familiarization with the organization's security, compliance and resilience policies and provide acknowledgement.	8	Updated in 2026.2	US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
03.16.01	Security Engineering Principles	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.16.01.ODP[01]	Security Engineering Principles	systems security engineering principles to be applied to the development or modification of the system and system components are defined.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or	10		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.16.01.ODP[01]	Security Engineering Principles	systems security engineering principles to be applied to the development or modification of the system and system components are defined.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10		
A.03.16.01.ODP[01]	Security Engineering Principles	systems security engineering principles to be applied to the development or modification of the system and system components are defined.	Functional	Subset Of	Development Methods, Techniques & Processes	TDA-02.3	Mechanisms exist to require software developers to ensure that their software development processes employ industry-recognized secure practices for secure programming, engineering methods, quality control processes and validation techniques to minimize flawed and/or malformed software.	10		
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Intersects With	Prohibited Equipment & Services	AST-17	Mechanisms exist to govern Supply Chain Risk Management (SCRM) sanctions that require the removal and prohibition of certain Technology Assets, Applications and/or Services (TAAS) that are designated as supply chain threats by a statutory or regulatory body.	5	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Intersects With	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5		US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Security, Compliance & Resilience	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by:	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations,	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the implementation and
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the implementation and operation of controls. The level of detail required in such documentation should be based on the degree to which organizations depend on the capabilities, functions, or mechanisms to meet risk response expectations. Requirements can include mandated configuration settings that specify allowed functions, ports, protocols, and services. Acceptance criteria for systems, system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement.
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Development Methods, Techniques & Processes	TDA-02.3	Mechanisms exist to require software developers to ensure that their software development processes employ industry-recognized secure practices for secure programming, engineering methods, quality control processes and validation techniques to minimize flawed and/or malformed software.	10		US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the implementation and operation of controls. The level of detail required in such documentation should be based on the degree to which organizations depend on the capabilities, functions, or mechanisms to meet risk response expectations. Requirements can include mandated configuration settings that specify allowed functions, ports, protocols, and services. Acceptance criteria for systems, system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement.
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Pre-Established Secure Configurations	TDA-02.4	Mechanisms exist to ensure vendors / manufacturers: (1) Deliver the Technology Asset, Application and/or Service (TAAS) with a pre-established, secure configuration implemented; and (2) Use the pre-established, secure configuration as the default for any subsequent TAAS reinstallation or upgrade.	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the implementation and operation of controls. The level of detail required in such documentation should be based on the degree to which organizations depend on the capabilities, functions, or mechanisms to meet risk response expectations. Requirements can include mandated configuration settings that specify allowed functions, ports, protocols, and services. Acceptance criteria for systems, system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement.

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Commercial Off-The-Shelf (COTS) Security Solutions	TDA-03	Mechanisms exist to utilize only Commercial Off-the-Shelf (COTS) security products.	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the implementation and operation of controls. The level of detail required in such documentation should be based on the degree to which organizations depend on the capabilities, functions, or mechanisms to meet risk response expectations. Requirements can include mandated configuration settings that specify allowed functions, ports, protocols, and services. Acceptance criteria for systems, system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement.
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Developer Architecture & Design	TDA-05	Mechanisms exist to require the developers of Technology Assets, Applications and/or Services (TAAS) to produce a design specification and security architecture that: (1) Is consistent with and supportive of the organization's security architecture which is established within and is an integrated part of the organization's enterprise architecture; (2) Accurately and completely describes the required security functionality and the allocation of security, compliance and resilience controls among physical and logical components; and (3) Expresses how individual security functions, mechanisms and services work together to provide required security capabilities and a unified approach to protection.	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the implementation and operation of controls. The level of detail required in such documentation should be based on the degree to which organizations depend on the capabilities, functions, or mechanisms to meet risk response expectations. Requirements can include mandated configuration settings that specify allowed functions, ports, protocols, and services. Acceptance criteria for systems, system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement.
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the implementation and operation of controls. The level of detail required in such documentation should be based on the degree to which organizations depend on the capabilities, functions, or mechanisms to meet risk response expectations. Requirements can include mandated configuration settings that specify allowed functions, ports, protocols, and services. Acceptance criteria for systems, system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement.
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the implementation and operation of controls. The level of detail required in such documentation should be based on the degree to which organizations depend on the capabilities, functions, or mechanisms to meet risk response expectations. Requirements can include mandated configuration settings that specify allowed functions, ports, protocols, and services. Acceptance criteria for systems, system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement.

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.16.01	Security Engineering Principles	<A.03.16.01.ODP[01]: systems security engineering principles> are applied to the development or modification of the system and system components.	Functional	Subset Of	Managing Changes To Third-Party Services	TPM-10	Mechanisms exist to control changes to services by suppliers, taking into account the criticality of business Technology Assets, Applications, Services and/or Data (TAASD) that are in scope by the third-party.	10	Updated in 2026.2	US DoD ODP Value: Guidance: At a minimum, documentation that provides user and administrator guidance for the implementation and operation of controls. The level of detail required in such documentation should be based on the degree to which organizations depend on the capabilities, functions, or mechanisms to meet risk response expectations. Requirements can include mandated configuration settings that specify allowed functions, ports, protocols, and services. Acceptance criteria for systems, system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement.
03.16.02	Unsupported System Components	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.16.02.a	Unsupported System Components	system components are replaced when support for the components is no longer available from the developer, vendor, or manufacturer.	Functional	Intersects With	Technology Lifecycle Management	SEA-07.1	Mechanisms exist to manage the usable lifecycles of Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.16.02.a	Unsupported System Components	system components are replaced when support for the components is no longer available from the developer, vendor, or manufacturer.	Functional	Intersects With	Unsupported Technology Assets, Applications and/or Services (TAAS)	TDA-17	Mechanisms exist to prevent unsupported Technology Assets, Applications and/or Services (TAAS) by: (1) Removing and/or replacing TAAS when support for the components is no longer available from the developer, vendor or manufacturer; and (2) Requiring justification and documented approval for the continued use of unsupported TAAS required to satisfy mission/business needs.	5		

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.16.02.b	Unsupported System Components	options for risk mitigation or alternative sources for continued support for unsupported components that cannot be replaced are provided.	Functional	Intersects With	Predictable Failure Analysis	SEA-07	Mechanisms exist to determine the Mean Time to Failure (MTTF) for system components in specific environments of operation.	5	Updated in 2026.2	
A.03.16.02.b	Unsupported System Components	options for risk mitigation or alternative sources for continued support for unsupported components that cannot be replaced are provided.	Functional	Intersects With	Technology Lifecycle Management	SEA-07.1	Mechanisms exist to manage the usable lifecycles of Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.16.02.b	Unsupported System Components	options for risk mitigation or alternative sources for continued support for unsupported components that cannot be replaced are provided.	Functional	Intersects With	Alternate Sources for Continued Support	TDA-17.1	Mechanisms exist to provide in-house support or contract external providers for support with unsupported Technology Assets, Applications and/or Services (TAAS).	5		
03.16.03	External System Services	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.16.03.ODP[01]	External System Services	security requirements to be satisfied by external system service providers are defined.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements	5		
A.03.16.03.ODP[01]	External System Services	security requirements to be satisfied by external system service providers are defined.	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5		
A.03.16.03.a	External System Services	the providers of external system services used for the processing, storage, or transmission of CUI comply with the following security requirements: <A.03.16.03.ODP[01]: security requirements>.	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	8	Updated in 2026.2	US DoD ODP Values: (1) For cloud service providers: (i) FedRAMP Authorized at the FedRAMP Moderate (or higher) baseline in accordance with the FedRAMP Marketplace; or
A.03.16.03.a	External System Services	the providers of external system services used for the processing, storage, or transmission of CUI comply with the following security requirements: <A.03.16.03.ODP[01]: security	Functional	Intersects With	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	8	Updated in 2026.2	US DoD ODP Values: (1) For cloud service providers:

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.16.03.a	External System Services	the providers of external system services used for the processing, storage, or transmission of CUI comply with the following security requirements: <A.03.16.03.ODP[01]: security	Functional	Intersects With	Third-Party Processing, Storage and Service Locations	TPM-04.4	Mechanisms exist to restrict the location of information processing/storage based on business requirements.	8	Updated in 2026.2	US DoD ODP Values: (1) For cloud service providers:
A.03.16.03.a	External System Services	the providers of external system services used for the processing, storage, or transmission of CUI comply with the following security requirements: <A.03.16.03.ODP[01]: security	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to	8		US DoD ODP Values: (1) For cloud service providers:
A.03.16.03.a	External System Services	the providers of external system services used for the processing, storage, or transmission of CUI comply with the following security requirements: <A.03.16.03.ODP[01]: security	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that	8	Updated in 2026.2	US DoD ODP Values: (1) For cloud service providers:
A.03.16.03.a	External System Services	the providers of external system services used for the processing, storage, or transmission of CUI comply with the following security requirements: <A.03.16.03.ODP[01]: security requirements>.	Functional	Intersects With	Third-Party Attestation (3PA)	TPM-05.8	Mechanisms exist to obtain an attestation from an independent Third-Party Assessment Organization (3PAO) that provides assurance of conformity with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down	8	Updated in 2026.2	US DoD ODP Values: (1) For cloud service providers: (i) FedRAMP Authorized at the FedRAMP Moderate (or
A.03.16.03.b	External System Services	user roles and responsibilities with regard to external system services, including shared responsibilities with external service providers, are defined and documented.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Updated in 2026.2	
A.03.16.03.b	External System Services	user roles and responsibilities with regard to external system services, including shared responsibilities with external service providers, are defined and documented.	Functional	Intersects With	Third-Party Personnel	HRS-10	Mechanisms exist to govern third-party personnel by reviewing and monitoring third-party security, compliance and/or resilience roles and responsibilities.	5	Updated in 2026.2	
A.03.16.03.b	External System Services	user roles and responsibilities with regard to external system services, including shared responsibilities with external service providers, are defined and documented.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Updated in 2026.2	
A.03.16.03.b	External System Services	user roles and responsibilities with regard to external system services, including shared responsibilities with external service providers, are defined and documented.	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5	Updated in 2026.2	
A.03.16.03.b	External System Services	user roles and responsibilities with regard to external system services, including shared responsibilities with external service providers, are defined and documented.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCI) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5		
A.03.16.03.c	External System Services	processes, methods, and techniques to monitor security requirement compliance by external service providers on an ongoing basis are implemented.	Functional	Intersects With	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	Updated in 2026.2	
A.03.16.03.c	External System Services	processes, methods, and techniques to monitor security requirement compliance by external service providers on an ongoing basis are implemented.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Updated in 2026.2	
A.03.16.03.c	External System Services	processes, methods, and techniques to monitor security requirement compliance by external service providers on an ongoing basis are implemented.	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5	Updated in 2026.2	
A.03.16.03.c	External System Services	processes, methods, and techniques to monitor security requirement compliance by external service providers on an ongoing basis are implemented.	Functional	Intersects With	Third-Party Scope Review	TPM-05.5	Mechanisms exist to perform recurring validation of the Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to ensure security,	5		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.16.03.c	External System Services	processes, methods, and techniques to monitor security requirement compliance by external service providers on an ongoing basis are implemented.	Functional	Intersects With	First-Party Declaration (1PD)	TPM-05.6	Mechanisms exist to obtain a First-Party Declaration (1PD) from applicable External Service Providers (ESPs) that provides assurance of compliance with specified statutory, regulatory and contractual obligations for security, compliance and resilience controls, including any flow-down	5		
A.03.16.03.c	External System Services	processes, methods, and techniques to monitor security requirement compliance by external service providers on an ongoing basis are implemented.	Functional	Intersects With	Third-Party Attestation (3PA)	TPM-05.8	Mechanisms exist to obtain an attestation from an independent Third-Party Assessment Organization (3PAO) that provides assurance of conformity with specified statutory, regulatory and contractual obligations for security,	5		
A.03.16.03.c	External System Services	processes, methods, and techniques to monitor security requirement compliance by external service providers on an ongoing basis are implemented.	Functional	Intersects With	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	5		
03.17.01	Supply Chain Risk Management Plan	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.17.01.ODP[01]	Supply Chain Risk Management Plan	the frequency at which to review and update the supply chain risk management plan is defined.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance	10		
A.03.17.01.a[01]	Supply Chain Risk Management Plan	a plan for managing supply chain risks is developed.	Functional	Subset Of	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	10	Updated in 2026.2	
A.03.17.01.a[01]	Supply Chain Risk Management Plan	a plan for managing supply chain risks is developed.	Functional	Subset Of	Select Controls	GOV-15.1	Mechanisms exist to compel data and/or process owners to select required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	10	Updated in 2026.2	
A.03.17.01.a[01]	Supply Chain Risk Management Plan	a plan for managing supply chain risks is developed.	Functional	Subset Of	Implement Controls	GOV-15.2	Mechanisms exist to compel data and/or process owners to implement required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	10	Updated in 2026.2	
A.03.17.01.a[01]	Supply Chain Risk Management Plan	a plan for managing supply chain risks is developed.	Functional	Subset Of	Assess Controls	GOV-15.3	Mechanisms exist to compel data and/or process owners to assess if required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control are: (1) Implemented correctly; and (2) Operating as intended.	10	Updated in 2026.2	
A.03.17.01.a[01]	Supply Chain Risk Management Plan	a plan for managing supply chain risks is developed.	Functional	Subset Of	Authorize Technology Assets, Applications and/or Services (TAAS)	GOV-15.4	Mechanisms exist to compel data and/or process owners to obtain authorization for the production use of each Technology Asset, Application and/or Service (TAAS) under their control.	10	Updated in 2026.2	
A.03.17.01.a[01]	Supply Chain Risk Management Plan	a plan for managing supply chain risks is developed.	Functional	Subset Of	Monitor Controls	GOV-15.5	Mechanisms exist to compel data and/or process owners to monitor Technology Assets, Applications, Services and/or	10	Updated in 2026.2	
A.03.17.01.a[01]	Supply Chain Risk Management Plan	a plan for managing supply chain risks is developed.	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	10	Updated in 2026.2	
A.03.17.01.a[01]	Supply Chain Risk Management Plan	a plan for managing supply chain risks is developed.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting	10		
A.03.17.01.a[01]	Supply Chain Risk Management Plan	a plan for managing supply chain risks is developed.	Functional	Subset Of	Supply Chain Risk Management (SCRM)	TPM-03	Mechanisms exist to: (1) Evaluate security risks and threats associated with Technology Assets, Applications and/or Services (TAAS) supply chains; and	10	Updated in 2026.2	
A.03.17.01.a[01]	Supply Chain Risk Management Plan	a plan for managing supply chain risks is developed.	Functional	Subset Of	Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services (TAAS).	10	Updated in 2026.2	
A.03.17.01.a[01]	Supply Chain Risk Management Plan	a plan for managing supply chain risks is developed.	Functional	Subset Of	Break Clauses	TPM-05.7	Mechanisms exist to include "break clauses" within contracts for failure to meet contract criteria for security, compliance and/or resilience controls.	10	Updated in 2026.2	
A.03.17.01.a[02]	Supply Chain Risk Management Plan	the SCRM plan addresses risks associated with the research and development of the system, system components, or system services.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting	10		
A.03.17.01.a[03]	Supply Chain Risk Management Plan	the SCRM plan addresses risks associated with the design of the system, system components, or system services.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans.	10		
A.03.17.01.a[04]	Supply Chain Risk Management Plan	the SCRM plan addresses risks associated with the manufacturing of the system, system components, or system services.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting	10		
A.03.17.01.a[05]	Supply Chain Risk Management Plan	the SCRM plan addresses risks associated with the acquisition of the system, system components, or system services.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans.	10		
A.03.17.01.a[06]	Supply Chain Risk Management Plan	the SCRM plan addresses risks associated with the delivery of the system, system components, or system services.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans.	10		
A.03.17.01.a[07]	Supply Chain Risk Management Plan	the SCRM plan addresses risks associated with the integration of the system, system components, or system services.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting	10		
A.03.17.01.a[08]	Supply Chain Risk Management Plan	the SCRM plan addresses risks associated with the operation of the system, system components, or system services.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets,	10		
A.03.17.01.a[09]	Supply Chain Risk Management Plan	the SCRM plan addresses risks associated with the maintenance of the system, system components, or system services.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans.	10		

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.17.01.a[10]	Supply Chain Risk Management Plan	the SCRM plan addresses risks associated with the disposal of the system, system components, or system services.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans.	10		
A.03.17.01.b[01]	Supply Chain Risk Management Plan	the SCRM plan is reviewed <A.03.17.01.ODP[01]: frequency>.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans.	10		US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.17.01.b[02]	Supply Chain Risk Management Plan	the SCRM plan is updated <A.03.17.01.ODP[01]: frequency>.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans.	10		US DoD ODP Value: at least every 12 months, or when there are significant incidents or significant changes to risks
A.03.17.01.c	Supply Chain Risk Management Plan	the SCRM plan is protected from unauthorized disclosure.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	Updated in 2026.2	
A.03.17.01.c	Supply Chain Risk Management Plan	the SCRM plan is protected from unauthorized disclosure.	Functional	Intersects With	Defining Access Authorizations for Sensitive / Regulated Data	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and/or physical access to sensitive and/or regulated data.	5		
A.03.17.01.c	Supply Chain Risk Management Plan	the SCRM plan is protected from unauthorized disclosure.	Functional	Subset Of	Disclosure of Information	DCH-03.1	Mechanisms exist to restrict the disclosure of sensitive and/or regulated data to authorized parties with a need to know.	10		
03.17.02	Acquisition Strategies, Tools, and Methods	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.17.02[01]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are developed to identify supply chain risks.	Functional	Intersects With	Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services (TAAS).	5		
A.03.17.02[02]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are developed to protect against supply chain risks.	Functional	Intersects With	Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services (TAAS).	5		
A.03.17.02[02]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are developed to protect against supply chain risks.	Functional	Intersects With	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	Updated in 2026.2	
A.03.17.02[02]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are developed to protect against supply chain risks.	Functional	Intersects With	Third-Party Risk Assessments &	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services	5	Updated in 2026.2	
A.03.17.02[03]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are developed to mitigate supply chain risks.	Functional	Intersects With	Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services (TAAS).	5		
A.03.17.02[03]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are developed to mitigate supply chain risks.	Functional	Intersects With	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	Updated in 2026.2	
A.03.17.02[03]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are developed to mitigate supply chain risks.	Functional	Intersects With	Third-Party Risk Assessments &	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services	5	Updated in 2026.2	
A.03.17.02[04]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to identify supply chain risks.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10		
A.03.17.02[04]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to identify supply chain risks.			Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.		Updated in 2026.2	
A.03.17.02[04]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to identify supply chain risks.			Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services		Updated in 2026.2	
A.03.17.02[05]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10		
A.03.17.02[05]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.			Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.		Updated in 2026.2	
A.03.17.02[05]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.			Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services		Updated in 2026.2	
A.03.17.02[05]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.			Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).		Updated in 2026.2	
A.03.17.02[05]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.			Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).		Updated in 2026.2	
A.03.17.02[05]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.			Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements		Updated in 2026.2	
A.03.17.02[05]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.			Security Compromise Notification Agreements	TPM-05.1	Mechanisms exist to compel External Service Providers (ESPs) to provide notification of actual or potential compromises in the supply chain that can potentially affect or have adversely affected Technology Assets, Applications and/or Services		Updated in 2026.2	
A.03.17.02[05]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.			Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.		Updated in 2026.2	
A.03.17.02[05]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.			Third-Party Scope Review	TPM-05.5	Mechanisms exist to perform recurring validation of the Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to ensure security,		Updated in 2026.2	
A.03.17.02[05]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.			Break Clauses	TPM-05.7	Mechanisms exist to include "break clauses" within contracts for failure to meet contract criteria for security, compliance and/or resilience controls.		Updated in 2026.2	
A.03.17.02[05]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.			Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security,		Updated in 2026.2	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information**

Focal Document URL: <https://csrc.nist.gov/pubs/sp/800/171/a/r3/final>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
A.03.17.02[06]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to mitigate supply chain risks.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10		
A.03.17.02[06]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to mitigate supply chain risks.			Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	5	Updated in 2026.2	
A.03.17.02[06]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to mitigate supply chain risks.			Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	Updated in 2026.2	
A.03.17.02[06]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to mitigate supply chain risks.			Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.17.02[06]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to mitigate supply chain risks.			Third-Party Scope Review	TPM-05.5	Mechanisms exist to perform recurring validation of the Responsible, Accountable, Supportive, Consulted & Informed (RASC) matrix, or similar documentation, to ensure security, compliance and resilience control assignments accurately reflect current: (1) Contractual obligations for the External Service Provider (ESP); (2) Business practices; (3) Applicable stakeholders; and (4) Deployed Technology Assets, Applications and/or Services (TAAS).	5	Updated in 2026.2	
A.03.17.02[06]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to mitigate supply chain risks.			Break Clauses	TPM-05.7	Mechanisms exist to include "break clauses" within contracts for failure to meet contract criteria for security, compliance and/or resilience controls.	5	Updated in 2026.2	
A.03.17.02[06]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to mitigate supply chain risks.			Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	5	Updated in 2026.2	
A.03.17.02[06]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to mitigate supply chain risks.			Third-Party Deficiency Remediation	TPM-09	Mechanisms exist to address weaknesses or deficiencies in supply chain elements identified during independent or organizational assessments of such elements.	5	Updated in 2026.2	
A.03.17.02[06]	Acquisition Strategies, Tools, and Methods	acquisition strategies, contract tools, and procurement methods are implemented to mitigate supply chain risks.			Managing Changes To Third-Party Services	TPM-10	Mechanisms exist to control changes to services by suppliers, taking into account the criticality of business Technology			
03.17.03	Supply Chain Requirements and Processes	Determine If:	Functional	No Relationship	N/A	N/A	N/A	0		
A.03.17.03.ODP[01]	Supply Chain Requirements and Processes	security requirements to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences from supply chain-related security requirements to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences from supply chain-related events are defined.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets,	10		
A.03.17.03.ODP[01]	Supply Chain Requirements and Processes		Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10		
A.03.17.03.a[01]	Supply Chain Requirements and Processes	a process for identifying weaknesses or deficiencies in the supply chain elements and processes is established.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets,	10		
A.03.17.03.a[01]	Supply Chain Requirements and Processes	a process for identifying weaknesses or deficiencies in the supply chain elements and processes is established.	Functional	Subset Of	Supply Chain Risk Assessment	RSK-09.1	Mechanisms exist to periodically assess supply chain risks associated with Technology Assets, Applications and/or Services (TAAS).	10	Updated in 2026.2	
A.03.17.03.a[01]	Supply Chain Requirements and Processes	a process for identifying weaknesses or deficiencies in the supply chain elements and processes is established.	Functional	Subset Of	Third-Party Criticality Assessments	TPM-02	Mechanisms exist to identify, prioritize and assess suppliers and partners of critical Technology Assets, Applications and/or Services (TAAS) using a supply chain risk assessment	10	Updated in 2026.2	
A.03.17.03.a[01]	Supply Chain Requirements and Processes	a process for identifying weaknesses or deficiencies in the supply chain elements and processes is established.	Functional	Subset Of	Supply Chain Risk Management (SCRM)	TPM-03	Mechanisms exist to: (1) Evaluate security risks and threats associated with Technology Assets, Applications and/or Services (TAAS) supply chains; and	10	Updated in 2026.2	
A.03.17.03.a[01]	Supply Chain Requirements and Processes	a process for identifying weaknesses or deficiencies in the supply chain elements and processes is established.	Functional	Subset Of	Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services	10	Updated in 2026.2	
A.03.17.03.a[01]	Supply Chain Requirements and Processes	a process for identifying weaknesses or deficiencies in the supply chain elements and processes is established.	Functional	Subset Of	Limit Potential Harm	TPM-03.2	Mechanisms exist to utilize security safeguards to limit harm from potential adversaries who identify and target the organization's supply chain.	10	Updated in 2026.2	
A.03.17.03.a[01]	Supply Chain Requirements and Processes	a process for identifying weaknesses or deficiencies in the supply chain elements and processes is established.	Functional	Subset Of	Processes To Address Weaknesses or Deficiencies	TPM-03.3	Mechanisms exist to address identified weaknesses or deficiencies in the security of the supply chain	10	Updated in 2026.2	
A.03.17.03.a[01]	Supply Chain Requirements and Processes	a process for identifying weaknesses or deficiencies in the supply chain elements and processes is established.	Functional	Subset Of	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10	Updated in 2026.2	
A.03.17.03.a[01]	Supply Chain Requirements and Processes	a process for identifying weaknesses or deficiencies in the supply chain elements and processes is established.	Functional	Intersects With	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	5		
A.03.17.03.a[02]	Supply Chain Requirements and Processes	a process for addressing weaknesses or deficiencies in the supply chain elements and processes is established.	Functional	Subset Of	Third-Party Scope Review	TPM-05.5	Mechanisms exist to perform recurring validation of the Responsible, Accountable, Supportive, Consulted & Informed (RASC) matrix, or similar documentation, to ensure security, compliance and resilience control assignments accurately reflect current:	10	Updated in 2026.2	
A.03.17.03.a[02]	Supply Chain Requirements and Processes	a process for addressing weaknesses or deficiencies in the supply chain elements and processes is established.	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans.	10		
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of supply chain-related events: <A.03.17.03.ODP[01]: security the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) The organization's Supply Chain Risk Management (SCRM) into	10		US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management (SCRM) into
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of	Functional	Subset Of	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets,	10		US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of	Functional	Subset Of	Supply Chain Risk Management (SCRM)	TPM-03	Mechanisms exist to: (1) Evaluate security risks and threats associated with Technology Assets, Applications and/or Services (TAAS)	10	Updated in 2026.2	US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of	Functional	Subset Of	Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services	10	Updated in 2026.2	US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)
Reference Document: Secure Controls Framework (SCF) version 2026.2
STRM Guidance: https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/

Focal Document: NIST SP 800 - 171A R3 - Assessing Security Requirements for Controlled Unclassified Information
Focal Document URL: https://csrc.nist.gov/pubs/sp/800/171a/r3/final
Published STRM URL: https://content.securecontrolsframework.com/strm/scf-strm-general-nist-800-171a-r3.pdf

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoD ODP Values
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of supply chain-related events: <A.03.17.03.ODP[01]: security requirements>.	Functional	Subset Of	Limit Potential Harm	TPM-03.2	Mechanisms exist to utilize security safeguards to limit harm from potential adversaries who identify and target the organization's supply chain.	10	Updated in 2026.2	US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of supply chain-related events: <A.03.17.03.ODP[01]: security requirements>.	Functional	Subset Of	Processes To Address Weaknesses or Deficiencies	TPM-03.3	Mechanisms exist to address identified weaknesses or deficiencies in the security of the supply chain	10	Updated in 2026.2	US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management (SCRM) into acquisition/procurement policies, provide adequate SCRM resources, define the SCRM control baseline, establish processes to ensure suppliers disclose significant vulnerabilities and significant incidents
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of supply chain-related events: <A.03.17.03.ODP[01]: security requirements>.	Functional	Subset Of	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10	Updated in 2026.2	US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management (SCRM) into acquisition/procurement policies, provide adequate
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of supply chain-related events: <A.03.17.03.ODP[01]: security requirements>.	Functional	Subset Of	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	10	Updated in 2026.2	US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management (SCRM) into acquisition/procurement policies, provide adequate SCRM resources, define the SCRM control baseline, establish processes to ensure suppliers disclose significant vulnerabilities and significant incidents
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of supply chain-related events: <A.03.17.03.ODP[01]: security requirements>.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Updated in 2026.2	US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management (SCRM) into acquisition/procurement policies, provide adequate SCRM resources, define the SCRM control baseline, establish processes to ensure suppliers disclose significant vulnerabilities and significant incidents
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of supply chain-related events: <A.03.17.03.ODP[01]: security requirements>.	Functional	Subset Of	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	10	Updated in 2026.2	US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management (SCRM) into acquisition/procurement policies, provide adequate SCRM resources, define the SCRM control baseline, establish processes to ensure suppliers disclose significant vulnerabilities and significant incidents
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of supply chain-related events: <A.03.17.03.ODP[01]: security requirements>.	Functional	Subset Of	Third-Party Scope Review	TPM-05.5	Mechanisms exist to perform recurring validation of the Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to ensure security, compliance and resilience control assignments accurately reflect current: (1) Contractual obligations for the External Service Provider (ESP); (2) Business practices; (3) Applicable stakeholders; and (4) Deployed Technology Assets, Applications and/or Services (TAAS).	10	Updated in 2026.2	US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management (SCRM) into acquisition/procurement policies, provide adequate SCRM resources, define the SCRM control baseline, establish processes to ensure suppliers disclose significant vulnerabilities and significant incidents
A.03.17.03.b	Supply Chain Requirements and Processes	the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of supply chain-related events: <A.03.17.03.ODP[01]: security requirements>.	Functional	Subset Of	Break Clauses	TPM-05.7	Mechanisms exist to include "break clauses" within contracts for failure to meet contract criteria for security, compliance and/or resilience controls.	10	Updated in 2026.2	US DoD ODP Value: at a minimum, integrate Supply Chain Risk Management (SCRM) into acquisition/procurement policies, provide adequate SCRM resources, define the SCRM control baseline, establish processes to ensure suppliers disclose significant vulnerabilities and significant incidents

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes	US DoW ODP Values
-------	----------	--	-------------------	----------------------	-------------	-------	--	-----------------------------	-------	-------------------